VOLUME I

The Cyber Dictionary

Technology and cybersecurity, defined plainly — from the protocol on the wire to the agency that investigates when it goes wrong.

1,213 terms · 15 domains

Ethical Tech CoLab · 2026 ·

How to use this volume

Every term in the dictionary, set A to Z across two columns. Each entry gives the term, its abbreviation or expansion where it has one, a definition of a sentence or two in plain English, the other names it goes by, and the domain it belongs to.

The domains are a way of dividing the subject, not a hierarchy: a term appears once, under the domain where someone would most likely go looking for it. The companion volume, *The Database Library*, catalogues the open data sources and open-source technologies to build with.

Definitions are written in-house and released under CC BY 4.0. Coverage of the classical vocabulary was checked against the SANS Institute's *Glossary of Security Terms*; the wording here is our own throughout.

Networking & Protocols	211
Cryptography	81
Identity & Access	89
Attacks & Exploitation	116
Malware & Threat Actors	61
Application Security	62
Cloud & Infrastructure	44
Endpoints & Systems	87
Defense & Operations	82
Governance, Risk & Compliance	80
AI & Emerging Tech	54
Dev & Delivery	65
Compute & Hardware	54
Intelligence & Investigations	96
Classification & Personal Data	31
Total	**1213**

# #

.gitignore — A list of paths Git should never track — build output, local config, secrets. The first line of defence against committing a key by accident. DEV & DELIVERY

1999 Brooklyn credit card case — An early US case where stolen card details were used at scale — investigated as identity theft rather than as hacking. An illustration of how cyber cases get charged under whatever law already exists. INTELLIGENCE & INVESTIGATIONS

3-2-1 rule — Three copies of data, on two media types, with one off-site. Modern versions add one offline or immutable copy. CLOUD & INFRASTRUCTURE

A

ABAC *Attribute-Based Access Control* — Access decided by attributes — department, device posture, location, time — evaluated as policy. More expressive than roles, and harder to reason about. IDENTITY & ACCESS

Access control — Deciding who may reach which resource, and enforcing it. Everything else in identity — accounts, roles, permissions — exists to make this decision reliably. NETWORKING & PROTOCOLS

Access control list *ACL* — A list attached to a resource naming who may use it and how. Simple, explicit, and still the model behind file permissions and router rules. NETWORKING & PROTOCOLS

Access control service — A service whose job is to keep unauthorised users away from system resources, usually through lists of permitted identities or issued tickets. IDENTITY & ACCESS

Access management — The everyday work of keeping access information correct: creating accounts, maintaining them, watching them, and revoking them when they should end. IDENTITY & ACCESS

Access matrix — A grid of subjects against objects, with the permitted actions in each cell. Mostly a teaching model, but it is the mental picture behind every permissions system. NETWORKING & PROTOCOLS

Access on day one — The problem that a new remote hire is granted real access before anyone has met them. Staged access, and probation-limited permissions, are the counter. DEFENSE & OPERATIONS

Access review *Recertification / attestation* — A periodic check where owners confirm who still needs access. The main defence against privilege creep — and often rubber-stamped. IDENTITY & ACCESS

Accessibility service abuse — Abusing the mobile permissions meant for accessibility tools to read the screen and act on the user's behalf. Granted once, it grants almost everything. ENDPOINTS & SYSTEMS

Account harvesting — Collecting the valid account names on a system. Half of a password attack is knowing who exists. ATTACKS & EXPLOITATION

Account takeover *ATO* — An attacker gaining full control of a legitimate account, then using its normal permissions. Hard to spot precisely because nothing technically breaks. IDENTITY & ACCESS

ACK piggybacking — Sending an acknowledgement inside another packet already headed the same way, rather than on its own. ATTACKS & EXPLOITATION

Active content — Code embedded in a web page that runs on the visitor's machine when the page loads. The reason a page you merely opened can attack you. ENDPOINTS & SYSTEMS

Activity monitor — A defence that watches for malicious behaviour on a system and blocks it as it happens, rather than matching known files. DEFENSE & OPERATIONS

Adversarial example — Input perturbed slightly so a model misclassifies it while a person sees nothing unusual. The classic attack on vision systems. AI & EMERGING TECH

Adversary-in-the-middle *AiTM / MitM* — Sitting between the user and the real site, relaying traffic and capturing the session cookie after login. It defeats codes and push, but not hardware-bound factors. *Also called man in the middle, MitM, MITM, monkey in the middle, machine in the middle.* ATTACKS & EXPLOITATION

Adversary-in-the-middle phishing *AiTM phishing kit* — A phishing page that relays the login to the real site in real time, capturing the session cookie after MFA is completed. It defeats every second factor except a phishing-resistant one bound to the origin. *Also called MitM phishing, session cookie theft, EvilGinx.* ATTACKS & EXPLOITATION

Adware — Software that injects ads or hijacks searches. Mostly a nuisance, sometimes a delivery route for worse. MALWARE & THREAT ACTORS

AES *Advanced Encryption Standard* — The default symmetric cipher, normally with 128- or 256-bit keys. Unbroken in practice — failures around it are nearly always key management or mode-of-operation mistakes. CRYPTOGRAPHY

Agent swarm *Swarm* — Many AI agents working the same problem at once, dividing it up and passing results between them, rather than one model working alone. It multiplies what a single operator can attempt — in defence, in research, and in attack. *Also called multi-agent swarm, agent fleet, swarm of agents.* AI & EMERGING TECH

Agent-to-agent communication *A2A* — Agents passing instructions and results to each other without a person in between. Anything one agent will accept as input from another is an injection surface, and trust between agents is rarely authenticated. *Also called inter-agent messaging, agent handoff.* AI & EMERGING TECH

Agentic AI *AI agent* — A model given tools and the autonomy to take multi-step actions. It converts a text-generation risk into a systems-and-permissions risk. AI & EMERGING TECH

AI incident — A case where an AI system causes or nearly causes serious harm, including by evading its own operator's controls. A new category of reportable event, defined differently in each of the state laws now requiring disclosure. *Also called AI safety incident, model incident.* GOVERNANCE, RISK & COMPLIANCE

AI red teaming — Deliberately probing a model or AI system for harmful, biased, or unsafe behaviour before users find it. AI & EMERGING TECH

Air gap — Physically isolating a system from other networks. Strong in principle, routinely defeated in practice by USB drives, maintenance laptops, and forgotten management links. *Also called offline isolation, disconnected network.* NETWORKING & PROTOCOLS

Alert fatigue — Analysts becoming numb to alerts through sheer volume. The mechanism by which a genuine alert is closed unread. DEFENSE & OPERATIONS

Algorithm — A finite set of steps for solving a problem or performing a computation. ENDPOINTS & SYSTEMS

Algorithmic bias — Systematic unfairness in outputs, usually inherited from data or objectives. A safety and legal problem, not only an accuracy one. AI & EMERGING TECH

Amplification attack *Reflection* — Sending small spoofed requests to services that reply with much larger responses, aimed at the victim. DNS and NTP are classic amplifiers. ATTACKS & EXPLOITATION

Angler phishing — Impersonating a company's support account on social media to intercept customers who are already complaining publicly. The victim starts the conversation, which is what makes it work. *Also called social media phishing, fake support account.* ATTACKS & EXPLOITATION

Anonymisation vs pseudonymisation — Anonymised data cannot be linked back and leaves scope; pseudonymised data can be re-linked with a key and is still personal data. GOVERNANCE, RISK & COMPLIANCE

Anti-forensics — Deliberately destroying the evidence of an intrusion — wiping logs, resetting devices to factory state, corrupting storage. In the Polish energy attacks the intruder bricked the controller it had tunnelled through and factory-reset the firewall it entered by, erasing the record on the way out. *Also called evidence destruction, log wiping, counter-forensics.* ATTACKS & EXPLOITATION

Antivirus *AV* — Signature and heuristic detection of malicious files. Necessary, insufficient, and blind to fileless and living-off-the-land activity. *Also called AV, anti-malware, endpoint protection.* ENDPOINTS & SYSTEMS

API *Application Programming Interface* — The defined way one piece of software talks to another. Everything in the library section of this site is reached through one. DEV & DELIVERY

API endpoint *Route* — A specific URL an API exposes for one operation. Each one needs its own authorisation check — this is where broken access control usually lives. DEV & DELIVERY

API gateway — A single front door for APIs handling authentication, rate limits, routing, and logging, so services do not each reimplement them. CLOUD & INFRASTRUCTURE

Applet — A small program delivered to run inside a browser, historically in Java. The model is gone; the lesson about running untrusted code is not. ENDPOINTS & SYSTEMS

Application allow-listing *Whitelisting* — Only approved executables may run. Extremely strong, operationally demanding, and impractical for developer machines. ENDPOINTS & SYSTEMS

APT *Advanced Persistent Threat* — A well-resourced group, usually state-linked, that gets in and stays quietly for a long time. Persistence and patience matter more than sophistication. *Also called advanced persistent threat, state-sponsored actor, nation-state group.* MALWARE & THREAT ACTORS

Armed attack threshold *Use of force threshold* — The point at which a cyber operation counts, in international law, as a use of force or an armed attack — and so permits a response in self-defence. Nobody has agreed where it sits, which is precisely what makes operating just beneath it attractive. *Also called threshold of force, article 51 threshold.* INTELLIGENCE & INVESTIGATIONS

ARP *Address Resolution Protocol* — Maps IP addresses to hardware MAC addresses on a local network. It has no authentication at all, which is why ARP spoofing is trivial on a flat network. NETWORKING & PROTOCOLS

ARP spoofing *ARP poisoning* — Answering ARP requests with your own MAC address so a victim's traffic is delivered to you instead of the gateway. ARP has no authentication at all, which is why a flat network is indefensible. *Also called ARP cache poisoning, ARP attack.* NETWORKING & PROTOCOLS

ARPANET *Advanced Research Projects Agency Network* — The 1970s packet-switched research network, funded by the US government, that the internet grew out of. Decommissioned in 1990. NETWORKING & PROTOCOLS

Artifact — The output of a build: a binary, a container image, a zipped bundle. What actually gets deployed, as opposed to the source. DEV & DELIVERY

AS-REP roasting — Requesting Kerberos pre-authentication data for accounts that have pre-auth disabled, then cracking the result offline. It needs no credentials at all to start. IDENTITY & ACCESS

ASIC / FPGA *Application-Specific Integrated Circuit / Field-Programmable Gate Array* — An ASIC is a chip hard-wired for one job — fast, cheap at volume, unchangeable. An FPGA is reconfigurable hardware: slower, but you can rewrite what it is. COMPUTE & HARDWARE

Asymmetric encryption *Public-key cryptography* — A key pair: the public key encrypts or verifies, the private key decrypts or signs. Slower, but it lets strangers exchange secrets without meeting first. CRYPTOGRAPHY

Asymmetric warfare — Conflict where a small investment, well aimed, produces effects out of all proportion to its cost. The standing description of offensive cyber. ATTACKS & EXPLOITATION

ATM jackpotting — Making a cash machine dispense its contents on command, through malware or by connecting directly to the dispenser after opening the enclosure. ATTACKS & EXPLOITATION

Attack chain *Kill chain* — The ordered stages of an intrusion, from reconnaissance through to impact. Useful because breaking any single link stops the whole chain. ATTACKS & EXPLOITATION

Attack surface — Everything an attacker could touch — exposed services, endpoints, APIs, staff, suppliers. Reducing it is usually cheaper than defending it. ATTACKS & EXPLOITATION

Attack surface management *ASM / EASM* — Continuously discovering what of yours is exposed to the internet, including assets nobody remembered owning. DEFENSE & OPERATIONS

Attorney-client privileged material — Legal advice and communications with counsel, protected from disclosure. Incident investigations are often run under privilege, which changes who may see the findings and how they are written. CLASSIFICATION & PERSONAL DATA

Attribution — Assigning an attack to a specific actor. Genuinely hard, often political, and rarely changes what a defender should do next. *Also called who did it, actor identification, blame assignment.* MALWARE & THREAT ACTORS

Attribution confidence — How sure an assessment is about who acted, stated deliberately — low, moderate or high — and on what basis. Technical indicators alone rarely reach high confidence; it usually takes intelligence, financial or human sourcing that cannot be published. *Also called confidence level, assessment confidence.* INTELLIGENCE & INVESTIGATIONS

Attribution threshold — Establishing who was behind an intrusion, to a standard someone will act on. Technical indicators rarely get there alone; attribution usually needs intelligence, finance and human sources too. *Also called standard of proof for attribution, confidence level.* INTELLIGENCE & INVESTIGATIONS

Audit trail — A tamper-evident record of who did what and when. Required by most frameworks and indispensable during an investigation. GOVERNANCE, RISK & COMPLIANCE

Auditing — Gathering and examining evidence about systems to check they comply with policy and are not exposed. The routine, unglamorous half of assurance. DEFENSE & OPERATIONS

Australian Federal Police *AFP* — Australia's national police force, handling cybercrime with national or international reach. INTELLIGENCE & INVESTIGATIONS

Authentication *AuthN* — Proving who you are. Distinct from authorisation, and confusing the two is the root of a surprising number of vulnerabilities. IDENTITY & ACCESS

Authenticity — That information is genuine and unaltered — that it really is what it claims to be. IDENTITY & ACCESS

Authorisation *AuthZ* — Deciding what an already-identified user is allowed to do. A logged-in user reaching another user's record is an authorisation failure, not an authentication one. IDENTITY & ACCESS

Authoritative name server — The server that holds the real, official records for a domain. Everything else is a cached copy of what it said. NETWORKING & PROTOCOLS

Autonomous attack *Machine-speed attack* — An intrusion in which the reconnaissance, exploitation and lateral movement are driven by software making its own choices, at a rate no human defender can match. The defensive consequence is that response has to be automated too. *Also called AI-driven attack, agentic attack, machine speed intrusion.* ATTACKS & EXPLOITATION

Autonomous system *AS* — A network, or set of networks, under one organisation's routing control, identified by an AS number. BGP is the language autonomous systems use to talk to each other. NETWORKING & PROTOCOLS

Autonomous system number *ASN* — The globally unique number identifying a network in the routing system. Useful in attribution: it says which network an address belongs to. NETWORKING & PROTOCOLS

Availability — That the system can actually do its job for the people who need it. The leg of the triad security controls most often damage. *Also called uptime, accessibility, service continuity.* GOVERNANCE, RISK & COMPLIANCE

B

Backdoor — A hidden way back into a system that bypasses normal authentication. Left by attackers, and occasionally by developers who meant it as a debug feature. MALWARE & THREAT ACTORS

Backup — A separate copy of data that can be restored. Untested backups are a plan, not a control — and ransomware crews delete the ones they can reach. *Also called copy, snapshot, restore point.* CLOUD & INFRASTRUCTURE

Badge cloning *RFID cloning* — Copying a proximity card at a distance and replaying it at the door. Many building credentials still carry no cryptography at all. ENDPOINTS & SYSTEMS

Baiting — Leaving something tempting where a target will find it, physically or online, and letting curiosity do the work. The USB stick in the car park is the archetype. *Also called USB drop, lure.* ATTACKS & EXPLOITATION

Bandwidth — How much data a link can carry in a given time, usually in bits per second. Not the same as latency — a fat pipe can still be slow to respond. NETWORKING & PROTOCOLS

Banner — The text a service announces when you connect to it, often naming the software and version. Free reconnaissance for an attacker, which is why banners get trimmed. NETWORKING & PROTOCOLS

Bare metal vs virtualised — A whole physical machine versus a share of one. Bare metal gives predictable performance and no noisy neighbours, at the cost of flexibility. COMPUTE & HARDWARE

Baseline / anomaly detection — Learning what normal looks like and alerting on deviation. Catches novel attacks and generates plenty of noise doing it. DEFENSE & OPERATIONS

Baseline / benchmark *CIS Benchmarks* — A published, agreed secure configuration for a platform. Gives you something concrete to measure drift against. ENDPOINTS & SYSTEMS

Basic authentication — The simplest web authentication: the username and password are sent with every request, barely encoded. Safe only inside TLS, and not really then. CRYPTOGRAPHY

Bastion host *Jump box* — A single hardened, monitored entry point for administrative access to a private network, so nothing else needs exposing. CLOUD & INFRASTRUCTURE

Batch size — How many inputs are processed together. Larger batches use hardware more efficiently and need more memory. COMPUTE & HARDWARE

bcrypt — A password hashing function designed to be deliberately slow, with a cost factor you raise as hardware gets faster. Using a general-purpose hash for passwords is the mistake it exists to prevent. *Also called password hashing, adaptive hash, scrypt, argon2.* CRYPTOGRAPHY

Beaconing — An implant checking in with its controller at regular intervals. The rhythm of those check-ins is one of the most reliable detections available. *Also called check-in traffic, callback traffic, heartbeat to C2.* ATTACKS & EXPLOITATION

Bearer token — A credential where possession alone grants access, with no further proof required. Which is exactly why leaked tokens in logs or repos are so damaging. IDENTITY & ACCESS

BEC *Business Email Compromise* — Impersonating or hijacking a trusted business mailbox to redirect a payment or an invoice. Consistently causes larger financial losses than ransomware. ATTACKS & EXPLOITATION

BGP *Border Gateway Protocol* — How the internet's large networks tell each other which address ranges they can reach. Built on trust, so a bad or malicious announcement can hijack traffic globally. NETWORKING & PROTOCOLS

BGP hijacking *Route hijacking* — Announcing routes for address space you do not own, pulling other people's traffic through your network. The internet's routing still runs largely on trust. NETWORKING & PROTOCOLS

BIND *Berkeley Internet Name Domain* — The long-running reference implementation of DNS. Much of the internet's name resolution has run on it, so its vulnerabilities matter widely. NETWORKING & PROTOCOLS

Biometrics — Authenticating people by physical characteristics — fingerprint, face, iris. Convenient, and impossible to reissue once copied. IDENTITY & ACCESS

Birthday attack — Exploiting the mathematics of collisions: finding any two inputs that hash alike takes far less work than matching one specific hash. It is why digest length matters more than intuition suggests. CRYPTOGRAPHY

Bit — The smallest unit of storage: a single 0 or 1. ENDPOINTS & SYSTEMS

Block cipher — A cipher that encrypts fixed-size blocks of data at a time. AES is the one in use nearly everywhere. CRYPTOGRAPHY

Blockchain *Distributed ledger* — An append-only ledger replicated across many parties. Strong integrity guarantees; no confidentiality, and no help if the data entered was wrong. AI & EMERGING TECH

Blockchain analysis *Chain analysis* — Following cryptocurrency through the public ledger, clustering addresses and linking them to real identities at the points where coins meet a regulated exchange. The reason a public ledger is worse for criminals than cash. *Also called chain analysis, crypto tracing, on-chain forensics*. INTELLIGENCE & INVESTIGATIONS

Blue-green / canary deploy — Two ways to release safely: run two full environments and switch traffic, or send the new version to a small slice of users first and watch. DEV & DELIVERY

Bluesnarfing — Taking data off a device over Bluetooth without pairing. With bluejacking and bluebugging, one of the original wireless proximity attacks. ENDPOINTS & SYSTEMS

Boot record infector — Malware that writes itself into the boot sector so it runs before the operating system does. The predecessor of the modern bootkit. MALWARE & THREAT ACTORS

Bootkit — A rootkit that loads before the operating system, surviving reinstalls. Secure Boot and measured boot exist mainly to stop this. MALWARE & THREAT ACTORS

Botnet — A fleet of compromised machines under one controller, rented out for denial of service, spam, proxying, or credential stuffing. *Also called zombie network, bot army, robot network*. ATTACKS & EXPLOITATION

Botnet swarm — Compromised devices coordinating without a central controller, using peer-to-peer messaging so there is no server to seize. It removes the single point that takedowns have always relied on. *Also called P2P botnet, decentralised botnet*. ATTACKS & EXPLOITATION

Branch — A named line of work running alongside the main one. It lets you build or break something without affecting what everyone else is using. DEV & DELIVERY

Breach and attack simulation *BAS* — Automated, continuous safe replay of attack techniques to validate that controls and detections still work after changes. DEFENSE & OPERATIONS

Breach notification — The legal duty to report certain breaches within a deadline — 72 hours to a regulator under GDPR, and to affected people if the risk is high. GOVERNANCE, RISK & COMPLIANCE

Breaking change — A change that stops existing users' code or configuration working. It needs a major version bump and a note, not a quiet release. DEV & DELIVERY

Bridge — A device that joins two network segments using the same protocol, passing frames between them. A switch is essentially a bridge with many ports. NETWORKING & PROTOCOLS

British Standard 7799 *BS 7799* — The British code of practice for information security management that became ISO/IEC 17799 and then ISO/IEC 27002. GOVERNANCE, RISK & COMPLIANCE

Broadcast — Sending one message to every host on a network at once. Useful for discovery, and abusable — the Smurf attack is broadcast turned into a weapon. NETWORKING & PROTOCOLS

Broadcast address — The address that reaches every host on a network segment. Traffic sent to it multiplies, which is why routers do not forward it across networks. NETWORKING & PROTOCOLS

Broken access control — Authorisation not enforced consistently on the server. Persistently the number one web risk, because it cannot be found by scanners alone. APPLICATION SECURITY

Browser — The client program that fetches and renders web content. Now the operating system most work actually happens in, and the most attacked software on any endpoint. ENDPOINTS & SYSTEMS

Browser-in-the-browser *BitB* — Drawing a fake browser popup — title bar, padlock, plausible address — inside the page itself. Every trust signal the user checks is a picture the attacker drew. *Also called fake login popup, painted browser window.* ATTACKS & EXPLOITATION

Brute force — Trying every possibility until something works. Defeated by rate limiting, lockouts, and enough entropy to make the search space impractical. *Also called exhaustive search, guessing attack.* ATTACKS & EXPLOITATION

Bucket exposure *Public bucket* — Object storage left readable, or writable, by anyone. Not an exploit at all: a setting, and still one of the largest sources of breached records. CLOUD & INFRASTRUCTURE

Budapest Convention *Convention on Cybercrime* — The Council of Europe treaty that harmonises cybercrime offences and cooperation procedures across its parties. The closest thing to a common international framework. INTELLIGENCE & INVESTIGATIONS

Buffer overflow — Writing past the end of a memory buffer, corrupting adjacent data and often enabling code execution. Mostly a C and C++ problem. *Also called stack overflow (memory), memory corruption, overrun.* APPLICATION SECURITY

Bug bounty — Paying external researchers for valid vulnerability reports. Continuous and broad, but no substitute for internal testing. *Also called vulnerability reward programme, VRP, researcher payout.* APPLICATION SECURITY

Build — Turning source code into something runnable — compiled, bundled, containerised. A build that only works on one machine is a bug. DEV & DELIVERY

Business continuity *BCP* — How the organisation keeps operating during disruption, including manual fallbacks. Broader than technical disaster recovery. *Also called BCP, continuity planning, keeping the lights on.* DEFENSE & OPERATIONS

Business impact analysis *BIA* — Working out how much disruption to each system the organisation can actually tolerate. It is what turns recovery targets from guesses into decisions. DEFENSE & OPERATIONS

Business logic abuse *Logic flaw* — Using an application exactly as built, in an order or at a scale nobody intended — refunding more than was paid, stacking discounts, skipping a step. No payload, no signature, no scanner finds it. APPLICATION SECURITY

BYOD *Bring Your Own Device* — Staff using personal devices for work. Convenient, and it puts corporate data on hardware you do not control or get to inspect. ENDPOINTS & SYSTEMS

BYOVD *Bring Your Own Vulnerable Driver* — Installing a legitimately signed but flawed driver in order to abuse it for kernel access. A standard technique for disabling security tooling. COMPUTE & HARDWARE

BYOVD attack *Bring your own vulnerable driver* — Installing a legitimate, signed, but vulnerable driver in order to exploit it and gain kernel privileges. The driver is not malware, which is precisely the point. ENDPOINTS & SYSTEMS

Byte — The smallest individually addressable unit of storage, in practice eight bits. ENDPOINTS & SYSTEMS

C

Cache *L1 / L2 / L3* — Tiny, very fast memory close to the processor holding recently used data. Its timing behaviour leaks information, which is what Spectre-class attacks exploit. COMPUTE & HARDWARE

Cache cramming — Tricking a browser into running cached code from local disk, where it is granted more permission than code from the internet would get. ATTACKS & EXPLOITATION

Cache poisoning *DNS poisoning* — Getting a name server to store and serve a false answer, so everyone it serves is quietly sent to the wrong place. NETWORKING & PROTOCOLS

Callback phishing *TOAD, telephone-oriented attack delivery* — An email with no link and no attachment — just an invoice and a phone number to dispute it. The victim makes the call, and the attack happens over the phone, past every email control. *Also called phone-back phishing, hybrid vishing.* ATTACKS & EXPLOITATION

Capability evaluation *Eval* — A structured test of what a model can actually do, run to inform release decisions. Cyber evaluations are usually run with the production safety classifiers disabled, in order to measure the ceiling rather than the shipped behaviour — which is why the evaluation environment itself has to be treated as hostile. *Also called benchmark, capability testing, dangerous capability eval.* AI & EMERGING TECH

Card skimming — Capturing card details at the point of use with a device fitted over a reader or inside a pump, usually with a camera or overlay for the PIN. ATTACKS & EXPLOITATION

Cash-out *Off-ramp* — The point where criminal proceeds are converted into usable money. Cryptocurrency is traceable on the chain, so the exchange where it is cashed out is where investigations most often land. INTELLIGENCE & INVESTIGATIONS

CD *Continuous Delivery / Deployment* — Delivery keeps every change releasable at a button press; deployment ships it automatically once checks pass. The two are often written as one and mean different things. DEV & DELIVERY

CDN *Content Delivery Network* — Distributed edge servers caching content close to users. Also a practical place to absorb denial-of-service traffic and enforce WAF rules. CLOUD & INFRASTRUCTURE

Cell — A fixed-length unit of data in ATM networks. Fixed size made switching fast in hardware, a design later overtaken by packet-based Ethernet. NETWORKING & PROTOCOLS

Certificate *X.509 certificate* — A signed statement binding a public key to an identity such as a domain name. Trust rests entirely on trusting whoever signed it. *Also called SSL certificate, TLS certificate, x509, digital certificate.* CRYPTOGRAPHY

Certificate authority *CA* — An organisation that issues and vouches for certificates. Its root certificate ships in browsers and operating systems, so a compromised CA breaks trust everywhere. CRYPTOGRAPHY

Certificate pinning — Hard-coding which certificate or key an app will accept, so a rogue CA cannot impersonate the server. Powerful, and easy to brick your own app with. CRYPTOGRAPHY

Certificate-based authentication — Proving identity with a certificate and its private key instead of a password. Phishing-resistant, and only as good as the issuing process. CRYPTOGRAPHY

CGI *Common Gateway Interface* — The old mechanism for a web server to pass a request to an executable script and return its output. The first generation of dynamic web vulnerabilities lived here. ENDPOINTS & SYSTEMS

Chain of custody — Documented handling of evidence from collection onwards. Break it and the evidence may be worthless in a legal proceeding. *Also called evidence handling, custody log, evidence continuity.* DEFENSE & OPERATIONS

Chain-of-thought monitoring *CoT monitoring* — Reading a model's intermediate reasoning to see what it is trying to do, not just what it did. One of the few tools available for reconstructing intent after an incident, and it weakens as reasoning techniques become less legible. *Also called reasoning transparency, thought monitoring.* AI & EMERGING TECH

CHAP *Challenge-Handshake Authentication Protocol* — Authentication by responding to a fresh challenge each time, so a captured response cannot be replayed. IDENTITY & ACCESS

Chatham House Rule — A meeting convention: you may use what was said, but never say who said it. Standard for intelligence and industry threat-sharing sessions. *Also called non-attribution rule, off the record convention.* GOVERNANCE, RISK & COMPLIANCE

Checksum — A short value computed from data and stored with it, to detect whether the data changed. It catches accidents, not attackers. CRYPTOGRAPHY

Cherry-pick — Copying one specific commit onto another branch. How an urgent fix reaches a release branch without dragging everything else with it. DEV & DELIVERY

Chip supply chain *Fab, foundry* — The concentrated global pipeline that designs and manufactures processors. A geopolitical dependency as much as a technical one. COMPUTE & HARDWARE

Chosen-plaintext attack *CPA* — Attacking a cipher by getting it to encrypt data you chose and studying the results. Modern schemes are expected to survive it as a baseline. CRYPTOGRAPHY

CI *Continuous Integration* — Automatically building and testing every change as it is pushed, so problems surface in minutes rather than at release. DEV & DELIVERY

CIA *Central Intelligence Agency* — The US foreign intelligence service, collecting abroad through its own operations and through partners. It has no domestic law-enforcement role. *Also called Central Intelligence Agency, the agency, langley.* INTELLIGENCE & INVESTIGATIONS

CIA triad *Confidentiality, Integrity, Availability* — The three properties security exists to protect. Most controls trade one against another, and naming which one you are protecting sharpens the argument. *Also called confidentiality integrity availability, security triad.* GOVERNANCE, RISK & COMPLIANCE

CIDR *Classless Inter-Domain Routing* — The /24-style notation for writing a block of IP addresses. The number after the slash says how many leading bits are fixed — the bigger the number, the smaller the block. NETWORKING & PROTOCOLS

CIEM *Cloud Infrastructure Entitlement Management* — Finding and trimming excessive cloud permissions. Most cloud identities hold far more rights than they ever use. CLOUD & INFRASTRUCTURE

Cipher — An algorithm for turning readable text into unreadable text and back. The cipher is public; the key is what must stay secret. CRYPTOGRAPHY

Circuit *Tor circuit* — The path of relays Tor picks for your traffic — normally three, rebuilt every few minutes. No single relay in it knows both who you are and where you are going. NETWORKING & PROTOCOLS

Circuit-switched network — A network that reserves one continuous path for the whole conversation, as the old telephone system did. Reliable and wasteful; the internet chose packets instead. NETWORKING & PROTOCOLS

CISA *Cybersecurity and Infrastructure Security Agency* — The US civilian agency responsible for defending federal networks and helping critical infrastructure defend itself. It advises and coordinates; it does not investigate crimes. *Also called Cybersecurity and Infrastructure Security Agency, US cyber agency.* INTELLIGENCE & INVESTIGATIONS

Classification levels (government) — The US government scheme: Unclassified, then Confidential, Secret and Top Secret, according to the damage disclosure would cause. Compartments and handling caveats sit on top of the level. CLASSIFICATION & PERSONAL DATA

Classification scheme — Sorting information into levels according to the harm its disclosure would cause, so protection can follow the label rather than being argued case by case. *Also called data classification, information classification, labelling scheme.* CLASSIFICATION & PERSONAL DATA

Clickjacking *UI redress attack* — Layering an invisible frame over a page so a click the user intends for one thing lands on another — a transfer, a permission grant, a like. Framing controls exist to stop it. *Also called UI redressing, invisible overlay.* APPLICATION SECURITY

Client — The system that asks for a service. A machine can be a client and a server at once — a proxy is both. NETWORKING & PROTOCOLS

Client isolation — Preventing devices on a shared network from communicating with each other, so each can reach the gateway and nothing else. The single control that would have contained the 2025 Polish energy attacks. *Also called AP isolation, peer blocking, device isolation.* NETWORKING & PROTOCOLS

Clipboard hijacking — Malware that watches the clipboard and swaps a copied cryptocurrency address for the attacker's. The victim pastes what looks right and pays a stranger. *Also called clipper malware, address swapping.* MALWARE & THREAT ACTORS

Clock speed *GHz* — How many cycles a processor runs per second. A poor way to compare modern chips — architecture, cores and memory bandwidth matter more. COMPUTE & HARDWARE

Clone — Copying a remote repository, including its full history, onto your own machine. The first command of most working days. DEV & DELIVERY

Clone phishing — Taking a genuine email the target already received, copying it exactly, and re-sending it with the attachment or link swapped. It defeats the advice to look for something unfamiliar, because nothing is. *Also called copycat phishing, replayed email.* ATTACKS & EXPLOITATION

Cloud account takeover — Gaining control of a cloud tenant through stolen keys, a compromised administrator or an over-trusted role. The blast radius is the whole estate, not one machine. CLOUD & INFRASTRUCTURE

Cluster / node — A cluster is many machines working as one system; a node is a single machine in it. The unit of scale for both HPC and cloud training runs. COMPUTE & HARDWARE

Code review — Another engineer reading a change before it lands. The cheapest place to catch both bugs and security mistakes. DEV & DELIVERY

Code signing abuse — Signing malware with a stolen, bought or fraudulently obtained certificate so the operating system and the security tools accept it. ATTACKS & EXPLOITATION

Cold boot attack — Chilling memory chips so their contents survive a reboot long enough to be read, recovering encryption keys. Why locking a laptop is weaker than shutting it down. COMPUTE & HARDWARE

Cold, warm and hot sites *Recovery sites* — The three grades of standby facility. A hot site can take over in minutes and costs accordingly; a warm site takes hours to days; a cold site is space and power waiting for hardware to arrive. DEFENSE & OPERATIONS

Collision — Two different inputs producing the same hash. Once collisions are practical — as with MD5 and SHA-1 — the hash can no longer prove a file is unmodified. CRYPTOGRAPHY

Collision attack — Producing two different inputs with the same hash, so a signature over one is valid for the other. What killed MD5 and SHA-1 for signing. CRYPTOGRAPHY

Command and control *C2 / C&C* — The channel an attacker uses to issue instructions to compromised hosts. Increasingly hidden inside normal cloud and messaging traffic. *Also called C2, C&C, beacon server, callback server.* ATTACKS & EXPLOITATION

Command injection — User input reaching a shell command, letting an attacker run arbitrary system commands as the application's user. APPLICATION SECURITY

Command injection (OS) *Shell injection* — Getting user input into a command the server hands to a shell. It ends in arbitrary code execution as whatever account the service runs under. APPLICATION SECURITY

Commercially sensitive information *Business sensitive* — The private-sector middle tier: pricing and margins, customer and supplier lists, salary bands, unreleased results, contract terms, designs and source code, and open security findings. The impact is competitive and financial — a rival prices against your margins, a supplier renegotiates once it knows what you pay elsewhere, a leaked pay band starts a dispute inside the company, an unpatched vulnerability published early is exploited before the fix ships. Damaging, quantifiable, and usually recoverable, which is why the controls are access limits and monitoring rather than mandated handling. *Also called commercial in confidence, business confidential, competitively sensitive, trade sensitive.* CLASSIFICATION & PERSONAL DATA

Commit — A saved, described snapshot of your changes, recorded permanently in the history. The unit of work everything else — review, revert, blame — operates on. DEV & DELIVERY

Commit message — The note explaining what changed and why. The why is the part future-you cannot reconstruct from the diff. DEV & DELIVERY

Compartmentalisation — Splitting classified information into compartments so that access to one grants nothing in another. It limits the damage a single insider can do. CLASSIFICATION & PERSONAL DATA

Compensating control — An alternative measure when the required control is not feasible. Must genuinely meet the intent, not merely be documented as if it does. GOVERNANCE, RISK & COMPLIANCE

Competitive intelligence — Gathering information about competitors by means that are legal, or at least not obviously illegal. The boundary with espionage is thinner than the phrase suggests. ATTACKS & EXPLOITATION

Compromised update *Signed malicious update* — Malicious code shipped through a vendor's genuine update channel, correctly signed. SolarWinds is the case everyone means; there is no user error to point at. ATTACKS & EXPLOITATION

Computer forensics — Recovering and analysing data from computers to a standard that will stand up in court. Method and documentation matter as much as findings. *Also called digital forensics, forensic imaging, DFIR*. INTELLIGENCE & INVESTIGATIONS

Confidential (classification) — Information whose disclosure would harm the organisation or a person: contracts, salaries, customer lists, unreleased results. Access is granted by need, not by seniority. *Also called company confidential, commercially confidential.* CLASSIFICATION & PERSONAL DATA

Confidential (government) — The lowest US classification level, for information whose disclosure would cause damage to national security. Not the same thing as commercial confidential. CLASSIFICATION & PERSONAL DATA

Confidential computing *TEE / enclave* — Processing data inside a hardware-protected enclave so even the host operating system cannot read it. Closes the in-use gap left by encryption at rest and in transit. AI & EMERGING TECH

Confidentiality — That information is seen only by those authorised to see it. The first leg of the CIA triad. *Also called secrecy, privacy of information.* GOVERNANCE, RISK & COMPLIANCE

Configuration drift — Live systems gradually diverging from their defined state through manual fixes. The reason a system that passed audit fails six months later. CLOUD & INFRASTRUCTURE

Configuration management — Establishing a known-good baseline and keeping systems to it. Most incidents start with something that drifted. DEFENSE & OPERATIONS

Consent phishing *OAuth phishing* — Tricking someone into granting a malicious application permission to their account through a genuine OAuth consent screen. No password is stolen and MFA never fires, because the victim really did authorise it. *Also called OAuth consent attack, illicit consent grant, app consent phishing.* IDENTITY & ACCESS

Constant-time comparison — Comparing secrets in a way that always takes the same time, so an attacker cannot learn the value one character at a time from response timing. CRYPTOGRAPHY

Container *Docker* — An application packaged with its dependencies, sharing the host kernel. Fast and portable, but isolation is weaker than a VM's. *Also called docker container, OCI container, isolated process.* CLOUD & INFRASTRUCTURE

Container escape — Breaking out of a container to the host. Usually the result of privileged mode, a mounted socket, or an unpatched kernel. CLOUD & INFRASTRUCTURE

Container image — The read-only template a container starts from. Base images carry their own vulnerabilities, so scanning and rebuilding matter as much as your code. CLOUD & INFRASTRUCTURE

Containment — Stopping an incident spreading — isolating hosts, disabling accounts, blocking traffic — before removing the attacker. DEFENSE & OPERATIONS

Content provenance *C2PA* — Cryptographically signed metadata recording how a piece of media was made and edited. An attempt to make authenticity checkable rather than assumed. AI & EMERGING TECH

Context window — How much text a model can consider at once. Anything beyond it is dropped or summarised, which quietly changes behaviour. AI & EMERGING TECH

Contingency plan *User contingency plan* — How the business keeps working while the systems are down. Written for the people doing the work, not for the IT department. DEFENSE & OPERATIONS

Control — A safeguard reducing risk. Categorised as preventive, detective, or corrective, and as technical, administrative, or physical. GOVERNANCE, RISK & COMPLIANCE

Controlled government information *Sensitive but unclassified* — The public-sector middle tier: unclassified, and restricted anyway — law enforcement and investigative material, personal data held on citizens, procurement detail, infrastructure layouts, export-controlled technical data. The impact falls on people rather than balance sheets: an informant identified, a witness located, a site made targetable, a negotiating position lost before the round begins. Most of it cannot be undone, which is why the handling rules here are legal duties rather than policy. Each country names its own scheme — CUI in the United States, OFFICIAL-SENSITIVE in the United Kingdom. *Also called OFFICIAL-SENSITIVE, FOUO, for official use only, protectively marked.* CLASSIFICATION & PERSONAL DATA

Controlled unclassified information *CUI* — The United States' scheme for information that is unclassified but still controlled, replacing a sprawl of agency-invented markings such as FOUO with one registry of categories. Its practical weight is contractual: NIST SP 800-171 sets what a contractor must do to protect it, and failing to meet that is now a False Claims Act exposure rather than an audit finding. *Also called CUI, NIST 800-171, CMMC, controlled unclassified.* CLASSIFICATION & PERSONAL DATA

Cookie — A small piece of data a server asks a browser to store and send back, so it can recognise the same client later. Session cookies are credentials in all but name. ENDPOINTS & SYSTEMS

Core / thread — A core is an independent processing unit; a thread is one stream of instructions running on it. More cores means more genuinely simultaneous work. COMPUTE & HARDWARE

Corruption — A threat action that changes system functions or data so the system works wrongly rather than not at all. ATTACKS & EXPLOITATION

CORS *Cross-Origin Resource Sharing* — Rules for when one origin may read another's responses. Loosening it to a wildcard with credentials is a routine and serious misconfiguration. APPLICATION SECURITY

Cost benefit analysis — Weighing what a control costs against the risk it removes. The argument that gets security funded, or does not. GOVERNANCE, RISK & COMPLIANCE

Countermeasure — An action taken to stop a detected threat from succeeding — a patch, a block rule, a filter. DEFENSE & OPERATIONS

Court order — An intermediate legal instrument between a subpoena and a warrant, reaching records a subpoena cannot but stopping short of content. INTELLIGENCE & INVESTIGATIONS

Covert channel — A way to move information using system behaviour never meant to carry it — free disk space, timing, packet sizes. Hard to see and harder to stop. ATTACKS & EXPLOITATION

CPU *Central Processing Unit* — The general-purpose processor that runs the operating system and most software. Very fast at doing one complicated thing after another. COMPUTE & HARDWARE

CPU vs GPU — A CPU is a few very fast generalists; a GPU is thousands of narrow specialists working in step. If your problem is the same maths repeated across a big array, the GPU wins by orders of magnitude. COMPUTE & HARDWARE

Credential stuffing — Replaying username and password pairs from earlier breaches against other sites, betting on reuse. Cheap, automated, and depressingly effective. *Also called reused password attack, account takeover attack.* IDENTITY & ACCESS

Crime of opportunity — An offence committed because the chance appeared, not because it was planned. Most low-level cybercrime, and the reason basic hygiene removes so much of it. INTELLIGENCE & INVESTIGATIONS

Crimeware — Malware built to make its operator money — stealing keystrokes, draining accounts, renting out infected machines. MALWARE & THREAT ACTORS

CRINK *China, Russia, Iran, North Korea* — Shorthand for the four states most often named as the strategic cyber adversaries of the United States and its allies. Convenient, and it flattens four very different actors. *Also called China Russia Iran North Korea, big four adversaries.* MALWARE & THREAT ACTORS

Crisis communications — Deciding in advance who says what to staff, customers, regulators, and press. Prepared badly, it turns an incident into a reputational event. DEFENSE & OPERATIONS

Critical infrastructure — The sectors a country cannot function without — power, water, health, finance, transport, communications. Mostly privately owned, which is why defending it needs public-private arrangements. *Also called CNI, essential services, lifeline sectors.* DEFENSE & OPERATIONS

Criticality — How much a given failure actually matters — which is judged very differently by a government protecting a country and a company protecting a balance sheet. It is why the same vulnerability gets very different responses. INTELLIGENCE & INVESTIGATIONS

CRL / OCSP *Certificate Revocation List / Online Certificate Status Protocol* — The two ways to check whether a certificate has been revoked early. Both are patchy in practice, which is why short-lived certificates are now preferred. CRYPTOGRAPHY

CRLF injection *Response splitting* — Injecting carriage return and line feed characters into a header, splitting one response into two and letting the attacker write the second. *Also called HTTP response splitting.* APPLICATION SECURITY

Cross-border investigation — An investigation where evidence, suspects and victims sit in different jurisdictions. The technical work is usually the easy part. INTELLIGENCE & INVESTIGATIONS

Cross-tenant access *Tenant isolation failure* — Reaching another customer's data or compute on shared infrastructure. The most serious class of cloud vulnerability, because no action by the victim could have prevented it. *Also called tenant escape, cross-account access.* CLOUD & INFRASTRUCTURE

Crossover cable — A cable wired to swap transmit and receive pairs so two devices can be connected directly. Modern hardware auto-detects, so it is mostly history. NETWORKING & PROTOCOLS

Cryptanalysis — The science of breaking cryptography — recovering plaintext or keys without being given them. What a cipher has to survive to be trusted. CRYPTOGRAPHY

Cryptojacking — Using someone else's compute to mine cryptocurrency. It rarely destroys anything, which is why it runs undetected for months on the cloud bill. *Also called cryptomining malware, unauthorised mining.* MALWARE & THREAT ACTORS

Cryptominer *Cryptojacking* — Malware that quietly uses your compute to mine cryptocurrency. Low drama, but it signals that something else could have run instead. MALWARE & THREAT ACTORS

CSP *Content Security Policy* — A header telling the browser which sources of script, style, and frames are allowed. A strong second line of defence when XSS slips through. APPLICATION SECURITY

CSPM *Cloud Security Posture Management* — Continuously checking cloud configuration against policy — public buckets, open groups, missing encryption, over-broad roles. CLOUD & INFRASTRUCTURE

CSPRNG *Cryptographically Secure Pseudo-Random Number Generator* — A random source safe for keys and tokens. Ordinary language random() functions are not, and using one for a session token is a classic bug. CRYPTOGRAPHY

CSRF *Cross-Site Request Forgery* — Tricking a logged-in browser into sending a state-changing request the user never intended. Blocked with anti-CSRF tokens and SameSite cookies. *Also called cross-site request forgery, XSRF, session riding.* APPLICATION SECURITY

Cut-through — Switching that starts forwarding as soon as the header is read, before the whole packet arrives. Lower latency, at the cost of passing on damaged frames. NETWORKING & PROTOCOLS

CVE / CVSS *Common Vulnerabilities and Exposures / Scoring System* — CVE is the unique identifier for a known flaw; CVSS scores its severity out of ten. CVSS ignores your context, so it is an input, not a decision. *Also called vulnerability identifier, severity score, CVE number.* GOVERNANCE, RISK & COMPLIANCE

CWPP / CNAPP *Cloud Workload / Native Application Protection Platform* — Runtime protection for cloud workloads, and the bundled platforms that combine posture, workload, and identity checks. CLOUD & INFRASTRUCTURE

Cyber crime economy *Crime-as-a-service* — The market that makes cybercrime a business rather than a craft: access brokers, malware developers, affiliates, bulletproof hosting, negotiation services and laundering, each specialised and rented. It is why the skill required to attack has fallen while the damage has risen. *Also called crime as a service, underground economy, cybercrime ecosystem.* ATTACKS & EXPLOITATION

Cyber deterrence — Discouraging attacks by making them costly or futile. Classical deterrence needs attribution, credible retaliation and clear thresholds, and cyberspace supplies none reliably — which is why the emphasis has shifted toward deterrence by denial: making yourself expensive to attack. *Also called deterrence by denial, deterrence by punishment.* INTELLIGENCE & INVESTIGATIONS

Cyber in warfare *Cyber-enabled operations* — Cyber operations used alongside conventional force rather than instead of it — blinding air defence, disrupting logistics, cutting communications ahead of a strike. Ukraine is the standing case study, and its lesson is that cyber effects are supporting fires, not a substitute for them. *Also called combined arms cyber, integrated operations.* INTELLIGENCE & INVESTIGATIONS

Cyber intelligence — Collecting and analysing information about adversaries in cyberspace to inform decisions, rather than to prosecute. Different standard of proof, different consumers, different timelines from an investigation. *Also called cyber threat intelligence, CTI, intelligence collection.* INTELLIGENCE & INVESTIGATIONS

Cyber investigation — Establishing what happened on a system, who did it and what can be proved about it. Distinct from incident response, which is about stopping it: an investigation has to survive scrutiny afterwards. *Also called digital investigation, computer crime investigation.* INTELLIGENCE & INVESTIGATIONS

Cyber power — A state's capacity to achieve its aims through cyberspace — offence, defence, intelligence, and the ability to shape the norms, standards and infrastructure everyone else uses. It is not the same as technical skill: it includes legal authority, industrial base, talent, and the willingness to act. *Also called national cyber capability, state cyber strength.* INTELLIGENCE & INVESTIGATIONS

Cyber war — Armed conflict conducted through, or substantially through, cyberspace. Contested as a term: most of what is called cyber war is espionage, sabotage or coercion below the threshold at which the law of armed conflict applies. *Also called cyber conflict, digital war.* INTELLIGENCE & INVESTIGATIONS

Cyber warfare — The use of cyber operations as an instrument of armed conflict. High impact for low cost, which is precisely what makes proportional response so contested. *Also called cyber conflict, information warfare (military), digital warfare.* INTELLIGENCE & INVESTIGATIONS

Cyber-enabled vs cyber-dependent crime — Cyber-enabled crime is an old crime committed with new tools — fraud, extortion, harassment. Cyber-dependent crime could not exist without computers — intrusion, malware, denial of service. INTELLIGENCE & INVESTIGATIONS

Cybercrime — Crime committed using a computer, or against one. The distinction matters in law: cyber as the means of an ordinary crime is charged differently from cyber as the target. *Also called computer crime, internet crime, digital crime.* INTELLIGENCE & INVESTIGATIONS

Cyclic redundancy check *CRC* — A checksum designed to catch transmission errors. Fast, standard, and trivially forged — never use it as a security control. CRYPTOGRAPHY

D

Daemon — A program that starts at boot and runs continuously in the background, serving requests. Windows calls the equivalent a service. ENDPOINTS & SYSTEMS

Dark web — Sites reachable only through anonymising networks like Tor. It hosts marketplaces and leak sites, and also censorship-resistant journalism. *Also called darknet, dark net, deep web (confused with), hidden services.* NETWORKING & PROTOCOLS

Dark web archive *Marketplace archive* — Preserved copies of seized or defunct hidden services — page captures, listings, vendor profiles and forum threads — held by researchers and law enforcement. The Silk Road archives are the worked example: the site is gone, and years of its listings, PGP keys and forum posts remain searchable evidence. *Also called marketplace archive, seized site archive, darknet archive.* INTELLIGENCE & INVESTIGATIONS

Dark web marketplace — A hidden service selling illicit goods, run with escrow, vendor ratings and dispute handling like any other marketplace. They are seized regularly and reconstitute under new names within weeks. INTELLIGENCE & INVESTIGATIONS

DAST *Dynamic Application Security Testing* — Testing a running application from the outside. Fewer false positives, but it only finds what it can reach. APPLICATION SECURITY

Data aggregation — Combining several kinds of record to build a fuller picture than any of them gives alone. It is why individually harmless datasets can become sensitive together. GOVERNANCE, RISK & COMPLIANCE

Data classification — Labelling data by sensitivity so handling rules can follow the label. Three or four tiers work; ten do not. GOVERNANCE, RISK & COMPLIANCE

Data custodian — Whoever is currently holding or processing the data and is responsible for protecting it while they do. The database team is a custodian, not an owner. GOVERNANCE, RISK & COMPLIANCE

Data handling rules — What each classification actually requires in practice — who may access it, how it is stored and transmitted, whether it may leave the country or the device, how it is disposed of. A classification without handling rules is decoration. CLASSIFICATION & PERSONAL DATA

Data minimisation — Collect only what you need and keep it only as long as you need it. The control that shrinks breach impact more than any tool. GOVERNANCE, RISK & COMPLIANCE

Data mining — Analysing existing data to find patterns worth acting on. The same technique serves fraud detection and intrusive profiling. GOVERNANCE, RISK & COMPLIANCE

Data owner — The person accountable for a set of data — what it is for, who may see it, how long it is kept. Accountability, not custody. GOVERNANCE, RISK & COMPLIANCE

Data poisoning — Corrupting training or retrieval data so the model learns something the attacker chose. Very hard to detect after the fact. AI & EMERGING TECH

Data residency *Data sovereignty* — Legal requirements about where data physically lives and which government can compel access to it. A cloud region choice with legal consequences. CLOUD & INFRASTRUCTURE

Data subject rights *DSAR* — Individuals' rights to access, correct, delete, or port their data, with statutory response deadlines. GOVERNANCE, RISK & COMPLIANCE

Data warehousing — Consolidating separate databases into one place for analysis. It also concentrates the consequences of one breach. GOVERNANCE, RISK & COMPLIANCE

Datacentre *Rack, colocation* — The building full of racked servers behind every cloud service. Physical security, power and cooling are as much a part of availability as any software control. COMPUTE & HARDWARE

Datagram — A self-contained packet that carries everything needed to be routed, without relying on any earlier exchange. The basis of connectionless protocols like UDP. NETWORKING & PROTOCOLS

DCSync — Impersonating a domain controller to ask another one to replicate password hashes. It looks like normal replication traffic, which is what makes it hard to see. IDENTITY & ACCESS

De-identification — Removing identifiers so data no longer points to a person. It is a spectrum, not a switch: weakly de-identified data is routinely re-identified by linking it to something else. CLASSIFICATION & PERSONAL DATA

Dead drop — Leaving a message somewhere both parties can reach, so they never communicate directly. Spycraft moved to the internet: a wiki page, an image comment, a paste site, a blockchain field. There is no server to seize, and the traffic looks like browsing. *Also called dead letter box, covert channel, C2 over public service.* INTELLIGENCE & INVESTIGATIONS

Deauthentication attack *Deauth* — Forging management frames that kick clients off a wireless network, to force a reconnection that can be captured or steered to an evil twin. *Also called wifi jamming, disassociation attack.* NETWORKING & PROTOCOLS

Decapsulation — Stripping a layer's header off a packet and handing the rest up the stack. The receiving half of what encapsulation does on the way out. NETWORKING & PROTOCOLS

Deception technology *Honeypot, canary token* — Fake systems, files, or credentials that nothing legitimate should ever touch. Very low false-positive rate when they trigger. DEFENSE & OPERATIONS

Deception technology (honeytoken) — Planting credentials, files or hosts that have no legitimate use, so any touch is a high-confidence alert. DEFENSE & OPERATIONS

Deep web — Everything on the web that a search engine has not indexed — anything behind a login, a paywall or a form. Vastly bigger than the dark web, and routinely confused with it: your bank statements are deep web, not dark web. *Also called unindexed web, invisible web.* NETWORKING & PROTOCOLS

Deepfake *Synthetic media* — AI-generated audio, image, or video imitating a real person. Already routine in payment fraud and executive impersonation. *Also called synthetic media, AI-generated video, face swap, voice clone.* AI & EMERGING TECH

Deepfake video call fraud — A live video call with a synthesised participant, used to authorise transfers that a written request would not survive. Already used successfully at scale. ATTACKS & EXPLOITATION

Defacement — Altering a website's content to embarrass or make a point. Loud by design, and often a cover for something quieter. ATTACKS & EXPLOITATION

Default credentials *Factory password* — The username and password a device ships with, identical across every unit and printed in the manual. Mirai built a botnet of hundreds of thousands of devices on about sixty such pairs, and two countries now ban them by law. *Also called default password, factory default, admin admin.* IDENTITY & ACCESS

Defence in depth — Layering independent controls so no single failure is fatal. Assumes each layer will eventually fail, because it will. *Also called layered security, defense in depth, multiple layers.* GOVERNANCE, RISK & COMPLIANCE

Denial of service *DoS (concept)* — Preventing legitimate access to a system, or delaying it enough to matter. It does not require breaking in. ATTACKS & EXPLOITATION

Department of Defense intelligence *DoD* — The military side of US intelligence, including the service intelligence organisations such as naval intelligence. The US intelligence community runs to some eighteen to twenty separate organisations. INTELLIGENCE & INVESTIGATIONS

Department of Homeland Security *DHS* — The US department that CISA and the Secret Service sit under, covering domestic protective security across borders, infrastructure and emergencies. *Also called DHS, homeland security.* INTELLIGENCE & INVESTIGATIONS

Department of Justice *DOJ* — The US department that prosecutes federal crime, including computer crime, and supervises the FBI. Its independence from political direction is a norm rather than a mechanism. *Also called DOJ, justice department, federal prosecutors.* INTELLIGENCE & INVESTIGATIONS

Dependency *Package, library* — Third-party code your project relies on. Most of a modern application is dependencies, which is why supply chain security is a real concern. DEV & DELIVERY

Dependency confusion — Publishing a public package with the same name as a company's internal one so build tools fetch the attacker's version by mistake. ATTACKS & EXPLOITATION

Deploy *Ship, release to production* — Putting a built version onto the servers where real users reach it. Small, frequent deploys are safer than big rare ones, because there is less to unpick when one goes wrong. DEV & DELIVERY

Deprecation *EOL notice* — Formal warning that something will be removed, with a date. The window in which to migrate calmly rather than in an incident. DEV & DELIVERY

DES *Data Encryption Standard* — The 1970s US encryption standard, retired because its 56-bit key can be brute-forced. Its successor is AES. CRYPTOGRAPHY

Deserialisation vulnerability — Rebuilding objects from untrusted serialised data, which in many languages can trigger code execution during reconstruction. APPLICATION SECURITY

Destructive OT attack — An intrusion whose objective is that physical equipment stops — turbines halted, controllers locked, network devices made unreachable to slow recovery. Distinct from espionage or ransomware in that there is nothing to steal and nobody to pay. *Also called industrial sabotage, physical disruption attack.* ATTACKS & EXPLOITATION

Detection as code — Managing detection rules in a repository with review and CI, so changes are traceable and testable like any other software. DEFENSE & OPERATIONS

Detection engineering — Treating detections as code: written, tested, version-controlled, and measured. The shift from buying alerts to building them. DEFENSE & OPERATIONS

DHCP *Dynamic Host Configuration Protocol* — Hands out IP addresses and network settings to devices as they join. A rogue DHCP server can quietly point every new device at an attacker's gateway and DNS. NETWORKING & PROTOCOLS

DHCP starvation — Exhausting a DHCP server's address pool with forged requests so no legitimate device can get an address — often as the setup for a rogue DHCP server that answers instead. *Also called DHCP exhaustion.* NETWORKING & PROTOCOLS

Dictionary attack — Trying words and phrases from a prepared list rather than every possible combination. Faster than brute force, because people pick words. *Also called wordlist attack, password list attack.* IDENTITY & ACCESS

Diff — The line-by-line difference between two versions — what was added, removed and changed. What you actually review, rather than the whole file. DEV & DELIVERY

Differential privacy — Adding calibrated statistical noise so aggregate results are useful while no individual's presence can be inferred. GOVERNANCE, RISK & COMPLIANCE

Diffie–Hellman *DH / ECDH* — A method for two parties to agree a shared secret over a channel anyone can watch, without ever sending the secret itself. CRYPTOGRAPHY

Digest authentication — A web authentication scheme where the client proves it knows the password by hashing a challenge, rather than sending the password itself. CRYPTOGRAPHY

Digital envelope — A message encrypted with a session key, packaged together with that session key encrypted to the recipient. The classic hybrid construction. CRYPTOGRAPHY

Digital evidence — Data used to prove or disprove something in a proceeding. It must be collected in a way that keeps it authentic, complete and demonstrably unaltered. INTELLIGENCE & INVESTIGATIONS

Digital forensics *DFIR* — Recovering and analysing digital evidence to establish what happened. Paired with incident response as one discipline. *Also called forensics, DFIR, computer forensics, evidence recovery.* DEFENSE & OPERATIONS

Digital signature — A hash of a message encrypted with the sender's private key. Anyone with the public key can confirm authorship and that nothing changed — and the signer cannot credibly deny it. *Also called e-signature (cryptographic), signed hash.* CRYPTOGRAPHY

Digital Signature Algorithm *DSA* — An asymmetric algorithm that produces signatures as a pair of large numbers. Verifies both who signed and that nothing changed. CRYPTOGRAPHY

Directory — The catalogue of users, groups, machines and their attributes that an organisation authenticates against. IDENTITY & ACCESS

Directory service *Active Directory, LDAP* — The central store of users, groups, and computers. In most enterprises, compromising Active Directory is functionally the same as compromising everything. IDENTITY & ACCESS

Disassembly — Turning a compiled binary back into assembly to see what it actually does. The starting point of most malware analysis. ATTACKS & EXPLOITATION

Disaster recovery *DR* — Restoring technology after a major failure. Distinct from business continuity, which covers how the organisation keeps operating meanwhile. *Also called DR, recovery planning, failover planning.* CLOUD & INFRASTRUCTURE

Discretionary access control *DAC* — Access decided by the owner of the resource, who can hand out permissions at will. Flexible, and it drifts. IDENTITY & ACCESS

Disruption — An event that interrupts or prevents correct operation of a service. It need not be an attack — a cut cable counts. ATTACKS & EXPLOITATION

Distance vector — A routing approach that picks paths by their cost in hops. Simple to run and slow to react to change; RIP is the classic example. NETWORKING & PROTOCOLS

Distillation — Training a small model to imitate a large one, trading a little quality for a lot of speed and cost. How capable models reach modest hardware. COMPUTE & HARDWARE

Distributed scan — Scanning from many source addresses at once so no single one looks busy enough to alarm anyone. Detection has to correlate across sources. NETWORKING & PROTOCOLS

DLL hijacking — Placing a malicious library where a trusted program will load it first. Turns a legitimate signed application into the malware's launcher. ENDPOINTS & SYSTEMS

DLP *Data Loss Prevention* — Tooling that spots and blocks sensitive data leaving. Good at accidents, weak against a determined insider. *Also called data loss prevention, data leak prevention, data leakage protection.* GOVERNANCE, RISK & COMPLIANCE

DLP monitoring *DLP (practice)* — Tooling that watches documents, mail and endpoints for sensitive information leaving, and blocks or flags it. Effective and intrusive: it means monitoring people's communications, which is a policy question before it is a technical one. *Also called data leak protection, content inspection, egress monitoring.* DEFENSE & OPERATIONS

DMA *Direct Memory Access* — Devices reading and writing system memory without going through the CPU. Fast, and a real attack path — a malicious Thunderbolt or PCIe device can read memory directly. COMPUTE & HARDWARE

DNS *Domain Name System* — The internet's phone book: it turns names like example.com into IP addresses. Almost every attack chain touches it, which is why DNS logs are gold for investigators. NETWORKING & PROTOCOLS

DNS cache — The store of recent answers a resolver keeps so it need not ask again. It makes DNS fast, and gives poisoning something to aim at. NETWORKING & PROTOCOLS

DNS rebinding — Answering a lookup with a public address, then re-answering with a private one, so a page in the victim's browser can reach devices inside their network. It turns the browser into a proxy past the firewall. NETWORKING & PROTOCOLS

DNS resolver *Recursive resolver* — The server that does the lookup legwork on your behalf, walking from the root servers down to the authoritative one and caching the answer. NETWORKING & PROTOCOLS

DNS spoofing *DNS hijacking* — Making a victim resolve a name to an address you control — by poisoning a cache, compromising a resolver, or changing the records at the registrar. Everything that trusts the name follows. *Also called DNS redirection, resolver hijack.* NETWORKING & PROTOCOLS

DNS tunnelling — Smuggling data in and out of a network inside DNS queries and responses. Slow, noisy if you look for it, and effective because DNS is rarely blocked. NETWORKING & PROTOCOLS

DNSSEC *DNS Security Extensions* — Cryptographic signatures on DNS records so a resolver can tell a genuine answer from a forged one. It proves authenticity, not confidentiality — the query is still visible. NETWORKING & PROTOCOLS

Documentation *README, docs* — The instructions that let someone else run, use or fix the thing. A project without a README is a project only its author can operate. DEV & DELIVERY

DoH / DoT *DNS over HTTPS / DNS over TLS* — Encrypted DNS lookups. Good for user privacy, awkward for defenders, because it hides the query from the network monitoring that used to see it. NETWORKING & PROTOCOLS

DOM-based XSS — XSS caused entirely by client-side JavaScript writing untrusted data into the page. The server may never see the payload at all. APPLICATION SECURITY

Domain *Windows domain* — A set of network resources and accounts managed together, where users log in once to reach everything in it. IDENTITY & ACCESS

Domain hijacking — Taking control of someone's domain — through the registrar, the DNS servers, or an expired registration. Everything that trusts the name follows the attacker. NETWORKING & PROTOCOLS

Domain name — The name that locates an organisation on the internet, read right to left from the top-level domain inward. NETWORKING & PROTOCOLS

DoS / DDoS *(Distributed) Denial of Service* — Overwhelming a service so real users cannot reach it. Distributed versions use many hosts at once, often a botnet or reflected traffic. *Also called denial of service, distributed denial of service, flooding attack, traffic flood.* ATTACKS & EXPLOITATION

Double extortion — Encrypting data and also threatening to publish it. Backups solve the outage but not the leak, which is why they are no longer a complete answer. MALWARE & THREAT ACTORS

Downgrade attack *Protocol downgrade* — Forcing two parties to negotiate an older, weaker version of a protocol or cipher that you already know how to break. Backwards compatibility is the attack surface. *Also called version rollback, negotiation attack.* CRYPTOGRAPHY

DPIA *Data Protection Impact Assessment* — A required assessment before high-risk processing, documenting risks to people and how they are mitigated. Best done at design, not sign-off. GOVERNANCE, RISK & COMPLIANCE

DPRK IT worker scheme *North Korean remote workers* — North Korean operatives hired as remote IT staff under bought or stolen identities, routing pay back to the state and leaving remote access behind. Detected through identity, payroll and geolocation anomalies as much as through malware. *Also called North Korean remote workers, fake IT worker scheme, laptop farm.* MALWARE & THREAT ACTORS

Drive-by download — Malware installed simply by loading a page, exploiting the browser or a plugin without any click. ATTACKS & EXPLOITATION

Driver — Software letting the operating system talk to hardware. Drivers run with kernel privileges, so a vulnerable or signed-but-malicious driver is a direct route to full control. COMPUTE & HARDWARE

Drone forensics — Recovering flight logs, telemetry, imagery and controller pairings from unmanned aircraft. Increasingly routine in both criminal and security investigations. INTELLIGENCE & INVESTIGATIONS

Drone swarm — Many unmanned aircraft operating as a coordinated group, cheap individually and hard to defeat collectively. The security questions are the control link, the identity of each unit, and what happens when part of the swarm is captured or spoofed. *Also called UAV swarm, coordinated drones.* INTELLIGENCE & INVESTIGATIONS

Dual-use — A capability that serves defence and offence equally — an exploit, an intrusion tool, a research finding. It is why export control, disclosure policy and publication ethics in this field are genuinely hard rather than merely bureaucratic. *Also called dual-use technology, offence-defence ambiguity.* GOVERNANCE, RISK & COMPLIANCE

Due care — Putting a reasonable level of protection in place, in line with what the industry considers normal practice. GOVERNANCE, RISK & COMPLIANCE

Due diligence — Assessing a supplier's security before signing. Questionnaires are the norm; evidence and audit rights are what actually matter. GOVERNANCE, RISK & COMPLIANCE

DumpSec — An old Windows auditing tool that dumped users, permissions, policies and services. Equally useful to an administrator and to an intruder. ENDPOINTS & SYSTEMS

Dumpster diving — Finding passwords, directories and documents in what an organisation threw away. Shredding is a security control. ATTACKS & EXPLOITATION

Dwell time — How long an intruder is inside before being detected. The metric that best reflects whether detection actually works. MALWARE & THREAT ACTORS

Dynamic link library *DLL* — A shared library that a program loads at runtime rather than containing itself. Which one gets loaded, and from where, is a whole class of vulnerability. ENDPOINTS & SYSTEMS

Dynamic routing protocol — A protocol that lets routers learn paths by talking to their neighbours. Convenient, and a target — routing announcements can be forged. NETWORKING & PROTOCOLS

E

E-waste — Discarded electronics, much of it exported and dismantled unsafely. Extending device life is both an environmental and a procurement decision. COMPUTE & HARDWARE

EAP *Extensible Authentication Protocol* — A framework that lets a link negotiate which authentication method to use, from passwords to certificates. The basis of enterprise Wi-Fi authentication. IDENTITY & ACCESS

Eavesdropping — Listening in on a conversation not meant for you. Often the first step, not the whole attack — what is overheard becomes the way in. NETWORKING & PROTOCOLS

ECC *Elliptic Curve Cryptography* — Public-key cryptography over elliptic curves, giving the same strength as RSA with far smaller keys. The default for new TLS and signing work. CRYPTOGRAPHY

Echo request / echo reply *Ping* — The ICMP pair behind ping: a request asking whether a host is alive, and its reply. Blocked on many networks, which is why a silent host is not necessarily a dead one. NETWORKING & PROTOCOLS

Edge computing — Processing data near where it is produced rather than in a central cloud. Cuts latency and bandwidth; multiplies the number of devices to secure. CLOUD & INFRASTRUCTURE

Edge inference *On-device AI* — Running a model on the user's own hardware. No data leaves the device, which is a privacy gain and a hard limit on model size. COMPUTE & HARDWARE

EDR *Endpoint Detection and Response* — An agent recording process, file, and network behaviour on the endpoint, with the ability to alert, hunt, and isolate. The successor to antivirus. *Also called endpoint detection and response, endpoint agent, next-gen antivirus.* ENDPOINTS & SYSTEMS

Egress cost / lock-in — Charges for moving data out of a cloud, and the dependence they create. A commercial concern that becomes a resilience concern. CLOUD & INFRASTRUCTURE

Egress filtering — Filtering traffic leaving your network. Ignored for years, and one of the most effective ways to break command and control. DEFENSE & OPERATIONS

Emanations analysis *TEMPEST* — Reading data from the unintentional signals a device gives off — electromagnetic leakage, sound, power draw. Defended by shielding, not software. CRYPTOGRAPHY

Embedded forensics — Forensics on devices that are not general-purpose computers — vehicles, controllers, medical devices, IoT. The data is there; the tooling to get at it usually is not. INTELLIGENCE & INVESTIGATIONS

Embedding — A numeric representation capturing meaning, so similar things sit close together. Not anonymised — original text can often be approximately recovered. AI & EMERGING TECH

Embodied carbon — The emissions from manufacturing hardware, before it is ever switched on. For short-lived devices it can outweigh the energy used running them. COMPUTE & HARDWARE

Encapsulation — Wrapping one protocol's data inside another's, so it can travel over a network that would not otherwise carry it. How tunnels and VPNs work. NETWORKING & PROTOCOLS

Encryption at rest — Data encrypted while stored on disk, so stolen hardware or a copied volume is useless. It does not protect data while the system is running and the key is loaded. *Also called disk encryption, stored data encryption.* CRYPTOGRAPHY

Encryption in transit — Data encrypted while moving over a network. The pair to encryption at rest — most compliance regimes ask for both. *Also called data in motion encryption, TLS in transit.* CRYPTOGRAPHY

End-of-life *EOL / unsupported* — Software the vendor no longer patches. Every future vulnerability in it stays open permanently, so EOL is a security deadline, not an IT one. ENDPOINTS & SYSTEMS

End-to-end encryption *E2EE* — Only the sender and recipient hold the keys; the service carrying the message cannot read it. The distinction that matters when a provider is subpoenaed or breached. CRYPTOGRAPHY

Endpoint — Any device a person uses to reach the network — laptop, phone, tablet, server. Where most intrusions begin and where most detection now lives. ENDPOINTS & SYSTEMS

ENISA *European Union Agency for Cybersecurity* — The EU's cybersecurity agency, which produces guidance, threat analysis and certification schemes rather than investigating incidents. *Also called EU cybersecurity agency, European cyber agency.* INTELLIGENCE & INVESTIGATIONS

Enterprise risk management *ERM* — Looking at all of an organisation's risks together — cyber, financial, legal, physical — rather than in separate columns. Cyber stops being a special case. DEFENSE & OPERATIONS

Entropy — Genuine unpredictability. Keys and tokens generated from weak entropy are guessable no matter how strong the algorithm. CRYPTOGRAPHY

Environment *dev / staging / production* — Separate copies of the system for building, testing and real use. Staging should resemble production closely enough that passing there means something. DEV & DELIVERY

Environment variable *env var, .env* — Configuration passed to a program at runtime instead of written into the code. Where secrets belong in development — and `.env` belongs in `.gitignore`. DEV & DELIVERY

Ephemeral port — A short-lived high-numbered port assigned to a client for one connection and released when it closes. Firewall rules that assume fixed ports break on these. NETWORKING & PROTOCOLS

EPSS *Exploit Prediction Scoring System* — A probability that a vulnerability will be exploited in the next 30 days. Pairs well with CVSS to cut patch backlogs to something achievable. GOVERNANCE, RISK & COMPLIANCE

Eradication — Removing the attacker's access completely: malware, backdoors, added accounts, altered configuration, rogue tokens. DEFENSE & OPERATIONS

Escalation — The risk that a response intended as proportionate reads as an attack to the other side. Cyber operations are especially prone to it: the effects are hard to predict, damage assessment is slow, and the target often cannot tell espionage from preparation for attack. *Also called escalation risk, escalation ladder.* INTELLIGENCE & INVESTIGATIONS

Escrow passwords — Passwords written down and locked away so emergency staff can get in when the usual people are unavailable. A control that has to be audited, not forgotten. IDENTITY & ACCESS

Ethernet *IEEE 802.3* — The dominant LAN technology — the wiring, framing and access rules under nearly every wired network. NETWORKING & PROTOCOLS

EU AI Act — The EU's risk-tiered regulation of AI systems, with outright bans at the top and obligations scaling with risk. Extraterritorial, like GDPR. AI & EMERGING TECH

Europol — The European Union's law enforcement agency, supporting member states on transnational crime and running the European Cybercrime Centre. *Also called European police agency, EC3, European Cybercrime Centre.* INTELLIGENCE & INVESTIGATIONS

Evaluation environment *Test range, cyber range* — The isolated infrastructure a capability test runs in. This is a security boundary and should be built like one: the single permitted outbound path is the entire attack surface, and something being tested may spend real effort finding it. *Also called cyber range, test harness, eval sandbox.* DEFENSE & OPERATIONS

Event — Any observable occurrence on a system or network. Most events are nothing; an incident is an event that turns out to matter. DEFENSE & OPERATIONS

Event log — The operating system's record of what happened. Default retention is short, so shipping logs off-host is essential before an attacker clears them. ENDPOINTS & SYSTEMS

Evil maid attack — Physical tampering with an unattended device — a modified bootloader, a hardware keylogger. Full-disk encryption alone does not stop it. COMPUTE & HARDWARE

Evil twin *Rogue access point* — A wireless access point broadcasting a legitimate network's name so devices connect to it by preference. Every connection then runs through the attacker. *Also called fake wifi, rogue AP, wifi impersonation.* NETWORKING & PROTOCOLS

Executive order — A directive from the US President binding on the executive branch. Much US cybersecurity policy — incident reporting, software supply chain requirements, critical infrastructure duties — arrives this way rather than through legislation. *Also called presidential directive, EO.* GOVERNANCE, RISK & COMPLIANCE

Exfiltration — Getting stolen data out, often in small encrypted chunks over allowed channels like HTTPS or a sanctioned file-sharing service. *Also called data theft, data extraction, stealing data, exfil.* ATTACKS & EXPLOITATION

Exit scam — A marketplace operator shutting down and keeping whatever is held in escrow. It ends more dark web markets than police action does. INTELLIGENCE & INVESTIGATIONS

Explainability *XAI* — Being able to say why a model produced a given output. Increasingly a legal requirement for decisions affecting people. AI & EMERGING TECH

Exploit — Working code or a technique that turns a vulnerability into actual unauthorised behaviour. A vulnerability is theoretical until an exploit exists. ATTACKS & EXPLOITATION

Exponential backoff — Waiting progressively longer between retries after a failure, so a struggling system is not hammered by everything retrying at once. NETWORKING & PROTOCOLS

Exposure — A threat action where sensitive data is released directly to someone not entitled to it. ATTACKS & EXPLOITATION

Extended ACL *Cisco* — A router filter that can also match destination, protocol, ports and whether a session is already established. NETWORKING & PROTOCOLS

Exterior gateway protocol *EGP* — A protocol that carries routing between separately administered networks rather than inside one. BGP is the one that survived. NETWORKING & PROTOCOLS

Extradition — Handing a suspect over to another country to be prosecuted. It requires a treaty and a matching offence, which is why suspects in some countries are effectively unreachable. *Also called surrender of a suspect, rendition (legal).* INTELLIGENCE & INVESTIGATIONS

F

Facilitator *In-country facilitator* — The person in the victim's country who receives the laptops, forwards the pay and lends a local address and bank account. Usually the only party a prosecution can actually reach. *Also called enabler, domestic co-conspirator.* INTELLIGENCE & INVESTIGATIONS

False flag — Deliberately planting evidence that points at someone else — another group's tooling, another country's language settings, another actor's infrastructure. It is why attribution rests on patterns of behaviour over time rather than on artefacts. *Also called misattribution operation, planted evidence.* INTELLIGENCE & INVESTIGATIONS

False rejects — When an authentication system turns away a legitimate user. Tuning a system to reduce false accepts almost always raises these. IDENTITY & ACCESS

Fast file system *FFS* — The first major redesign of the Unix file system, using inodes and better on-disk layout for speed. The ancestor of the file systems in use now. ENDPOINTS & SYSTEMS

Fast flux — Rapidly rotating the addresses a domain resolves to, across a botnet, so the infrastructure behind it cannot be taken down by blocking an IP. MALWARE & THREAT ACTORS

Fault line attack — Exploiting the gaps between systems, where each side assumes the other is checking. Integration points are where coverage runs out. ATTACKS & EXPLOITATION

FBI *Federal Bureau of Investigation* — The lead US federal agency for investigating cybercrime, and simultaneously a domestic intelligence service. It works cases for prosecution and collects intelligence, which is an unusual combination. *Also called Federal Bureau of Investigation, the bureau, federal police.* INTELLIGENCE & INVESTIGATIONS

Feature flag *Toggle* — A switch that turns functionality on or off without a deploy. Separates releasing code from releasing the feature — and stale flags become their own mess. DEV & DELIVERY

Federation — Trusting another organisation's identity provider so their users can access your systems without separate accounts. Convenient, and it exports your trust decision. IDENTITY & ACCESS

Fetch — Downloading remote changes without applying them to your working copy. The cautious half of a pull, when you want to look before you merge. DEV & DELIVERY

FIDO2 / WebAuthn — The open standards behind hardware keys and passkeys. The browser signs a challenge with a key tied to the exact origin, so a lookalike site gets nothing. IDENTITY & ACCESS

Fileless attack — Malicious activity running in memory or scripting engines without writing to disk. Invisible to file-scanning antivirus by design. *Also called memory-only malware, in-memory attack.* ATTACKS & EXPLOITATION

Filter — A rule deciding which packets are kept, shown or blocked — in a capture tool, in a firewall, or in a detection pipeline. DEFENSE & OPERATIONS

Filtering router — A router that also decides whether a packet should be forwarded at all, according to policy. The simplest form of firewall. NETWORKING & PROTOCOLS

Fine-tuning — Further training a base model on specific data to specialise it. Anything in that data is baked into the weights and cannot be selectively deleted. AI & EMERGING TECH

Fine-tuning vs LoRA *Low-Rank Adaptation* — Full fine-tuning updates every weight and needs serious hardware; LoRA trains a small adapter alongside the frozen model and runs on a single consumer GPU. COMPUTE & HARDWARE

Finger — An old protocol that returned information about a user on a host. Helpful, informative and long since disabled for exactly that reason. ENDPOINTS & SYSTEMS

Fingerprinting *OS fingerprinting* — Sending unusual packets and reading the replies to work out what operating system a host runs. Different stacks answer malformed input in different, recognisable ways. *Also called OS detection, stack identification.* NETWORKING & PROTOCOLS

Firewall — A control that allows or blocks traffic by rule — usually address, port, and protocol. The traditional perimeter device, now also a per-host and per-cloud-resource control. *Also called packet filter, network filter, perimeter device.* NETWORKING & PROTOCOLS

Firmware update — Replacing the low-level software on a device. Often manual, sometimes unsigned, and the reason many devices stay vulnerable for years. ENDPOINTS & SYSTEMS

Five Eyes *FVEY* — The intelligence-sharing arrangement between the United States, United Kingdom, Canada, Australia and New Zealand. The deepest such arrangement that exists between states. *Also called FVEY, UKUSA, anglosphere intelligence sharing.* INTELLIGENCE & INVESTIGATIONS

Flooding — Overwhelming a system with more input than it can process. The mechanism under most denial of service. NETWORKING & PROTOCOLS

FLOPS *Floating point operations per second* — The standard measure of raw compute, quoted in teraflops or petaflops. Peak FLOPS is a ceiling, not a promise — real workloads rarely approach it. COMPUTE & HARDWARE

Forced browsing *Insecure direct browsing* — Requesting pages and files by guessing their addresses rather than following links, and finding the ones that were only hidden rather than protected. *Also called directory brute force, content discovery.* APPLICATION SECURITY

Forest — A set of Active Directory domains that replicate with each other. The boundary that matters when working out how far a compromise can reach. IDENTITY & ACCESS

Fork — Your own server-side copy of someone else's repository, so you can change it without write access to the original and propose the change back. DEV & DELIVERY

Fork bomb — A process that repeatedly copies itself until no process slots remain and the machine stops. Four characters of shell, and a hard lesson in resource limits. ATTACKS & EXPLOITATION

Form-based authentication — Logging in through a web page form rather than a browser or protocol mechanism. What almost every web application does, with all the session handling that implies. IDENTITY & ACCESS

Formjacking *Magecart, web skimming* — Injecting script into a checkout page that copies card details as they are typed and sends them elsewhere. The payment still completes, so nothing looks wrong. *Also called card skimming (web), digital skimmer.* APPLICATION SECURITY

Forward lookup — Using a domain name to find its IP address. The ordinary DNS query. *Also called name to IP, A record lookup, ordinary DNS query.* NETWORKING & PROTOCOLS

Forward proxy — A proxy that clients send their outbound requests through. The point where an organisation can inspect and control what leaves. NETWORKING & PROTOCOLS

Forward secrecy *PFS* — Using fresh, throwaway keys per session so that stealing the long-term private key later does not decrypt traffic captured earlier. CRYPTOGRAPHY

Fragment offset — The field that says where a fragment belongs in the original packet. Forged offsets are how fragmentation attacks overwrite headers. NETWORKING & PROTOCOLS

Fragment overlap attack — An attack that sends fragments with deliberately wrong offsets so reassembly overwrites part of the original header — for example, the destination port. NETWORKING & PROTOCOLS

Fragmentation — Splitting a packet into smaller pieces to fit a link's maximum size. A reliable source of security bugs, because reassembly is easy to get wrong. NETWORKING & PROTOCOLS

Frame — The unit of data on a local network segment, wrapping a packet in link-layer addressing. Frames carry packets the way envelopes carry letters. NETWORKING & PROTOCOLS

Frontier AI regulation — The emerging rules for the most capable models — incident reporting, safety frameworks, and in some jurisdictions independent audit. Current US state laws mostly require a plain-language summary, with no power to send investigators or compel preservation of records. *Also called AI safety law, SB 1047-style regulation, frontier model rules.* GOVERNANCE, RISK & COMPLIANCE

FTP *File Transfer Protocol* — An old file transfer protocol that authenticates in the clear and needs awkward extra connections. Superseded by SFTP and HTTPS. NETWORKING & PROTOCOLS

Full duplex — A link that carries traffic in both directions at the same time. Half duplex takes turns; collisions are a half-duplex problem. NETWORKING & PROTOCOLS

Full-disk encryption *BitLocker, FileVault, LUKS* — Encrypting the whole drive so a lost or stolen device gives up nothing. Protects data at rest, not a running unlocked machine. ENDPOINTS & SYSTEMS

Fully-qualified domain name *FQDN* — A hostname written out in full, all the way to the top-level domain — host plus complete domain, with nothing implied. NETWORKING & PROTOCOLS

Fuzzing — Throwing malformed and random input at a program to find crashes. Extremely effective at finding memory-safety and parser bugs. *Also called fuzz testing, random input testing.* APPLICATION SECURITY

G

Gateway — A network point that leads into another network. Your default gateway is the router you send everything you cannot reach directly to. NETWORKING & PROTOCOLS

GCHQ *Government Communications Headquarters* — The UK signals intelligence agency, and the parent of the National Cyber Security Centre. *Also called British signals intelligence, Cheltenham, NCSC parent.* INTELLIGENCE & INVESTIGATIONS

GDPR *General Data Protection Regulation* — The EU regulation governing personal data. Extraterritorial, principles-based, and backed by fines up to four percent of global turnover. GOVERNANCE, RISK & COMPLIANCE

GDPR special categories *Sensitive personal data* — Under GDPR: racial or ethnic origin, political opinions, religious or philosophical beliefs, trade union membership, genetic data, biometric data used to identify someone, health data, and data about sex life or sexual orientation. Processing it needs a specific additional condition, not just a lawful basis. *Also called sensitive personal data, article 9 data, special category data.* CLASSIFICATION & PERSONAL DATA

Geoblocking — Allowing or refusing access based on the country an IP address maps to. Trivially bypassed with a VPN, which is why it filters noise rather than adversaries. *Also called geo-restriction, country blocking, geo-fencing.* NETWORKING & PROTOCOLS

Geolocation anomaly — A login, a payroll address or a shipping address that does not fit the rest of the pattern. Individually explainable, and in combination the thing that unravels a fraudulent hire. *Also called location mismatch, geo anomaly.* DEFENSE & OPERATIONS

gethostbyname / gethostbyaddr — The classic pair of lookup calls: name to address, and address to name. The programming face of forward and reverse DNS. NETWORKING & PROTOCOLS

GNU *GNU's Not Unix* — The free software project started in 1983 to build a complete Unix-like system, whose tools sit under most Linux distributions. ENDPOINTS & SYSTEMS

Gnutella — An early peer-to-peer file sharing network where every client was also a server. An object lesson in how hard decentralised networks are to police. ENDPOINTS & SYSTEMS

Goal misgeneralisation — A system that learned a goal which fits the training data but is not the one intended, and pursues it competently once conditions change. The capability generalises; the objective does not. *Also called objective misgeneralisation, wrong goal learned.* AI & EMERGING TECH

Going dark — Law enforcement's argument that strong encryption is putting evidence beyond reach even with lawful authority. The counter-argument is that a mechanism giving one government access gives every capable adversary the same, and that metadata has never been more available. *Also called encryption debate, lawful access, exceptional access.* INTELLIGENCE & INVESTIGATIONS

Golden image — A standard, pre-hardened system image every machine is built from, so security settings are the default rather than a follow-up task. ENDPOINTS & SYSTEMS

Golden SAML — Forging SAML assertions with a stolen identity provider signing key, minting valid logins to any connected service. It survives password resets and MFA. IDENTITY & ACCESS

Golden Ticket — Forging Kerberos tickets using the domain's krbtgt key, granting an attacker persistent, self-issued access to anything in the domain. *Also called forged TGT, krbtgt forgery.* IDENTITY & ACCESS

GPU *Graphics Processing Unit* — A processor with thousands of simple cores built to do the same operation on huge amounts of data at once. Made for graphics, now the engine of machine learning. COMPUTE & HARDWARE

GPU cloud *Accelerator rental* — Renting accelerators by the hour rather than buying them. Cheaper to start, expensive to leave running — idle GPUs bill the same as busy ones. COMPUTE & HARDWARE

GPU passthrough *vGPU* — Giving a virtual machine direct or partitioned access to a physical GPU. Necessary for accelerated workloads in virtualised environments, and it weakens isolation. COMPUTE & HARDWARE

Group Policy *GPO* — Windows' central mechanism for pushing configuration to domain machines. Also a superb attacker tool once domain admin is obtained. ENDPOINTS & SYSTEMS

Guardrails — Filters and policies around a model's inputs and outputs. Necessary, probabilistic, and not a substitute for real authorisation checks. AI & EMERGING TECH

H

Hacktivist — An attacker motivated by a political or social cause rather than money. Typically defacement, leaks, or denial of service. *Also called activist hacker, ideological attacker.* MALWARE & THREAT ACTORS

Hallucination *Confabulation* — A confident, fluent, wrong output. Not a bug to be patched out but a property of prediction, which is why verification has to be designed in. *Also called confabulation, made-up output, fabrication.* AI & EMERGING TECH

Hard-coded credentials — Passwords or keys written directly into source. They spread through forks, logs, and backups, and cannot be rotated without a code change. APPLICATION SECURITY

Hardening — Removing unnecessary services, accounts, and features and tightening what remains. Cheap, unglamorous, and highly effective. *Also called lockdown, securing a build, baseline tightening.* ENDPOINTS & SYSTEMS

Hardware implant — A malicious component added during manufacture or shipping. Rare, extremely hard to detect, and the reason high-assurance procurement tracks provenance. COMPUTE & HARDWARE

Hardware root of trust — An immutable component in silicon that everything else's trust chains back to. If it is compromised, no software check above it means anything. COMPUTE & HARDWARE

Harvest now, decrypt later — Recording encrypted traffic today in the expectation of breaking it with future technology. The reason long-lived secrets need post-quantum protection now, not eventually. CRYPTOGRAPHY

Hash function — A one-way function turning any input into a fixed-length fingerprint. Same input always gives the same digest; the digest cannot be reversed back to the input. *Also called digest, message digest, checksum (cryptographic), fingerprint.* CRYPTOGRAPHY

HBM *High Bandwidth Memory* — Memory stacked next to the processor for enormous bandwidth. The scarce component in AI accelerators, and often the real bottleneck rather than compute. COMPUTE & HARDWARE

HEAD *Git HEAD pointer* — A pointer to the commit you currently have checked out. `HEAD~1` is the one before it. DEV & DELIVERY

Header — The extra information at the front of a packet that lets the protocol stack handle it — addresses, lengths, flags. Everything an inspection tool reads first. NETWORKING & PROTOCOLS

Help desk fraud *Support desk social engineering* — Talking an IT support desk into resetting a password or re-enrolling a multi-factor device for an account you do not own. It attacks the recovery process, which is designed to be helpful, and so undoes every control the account had. *Also called IT support impersonation, password reset fraud, MFA re-enrolment fraud.* ATTACKS & EXPLOITATION

Hidden service *.onion address* — A server reachable only inside Tor, addressed by a cryptographic name ending in .onion rather than a domain. Neither side of the connection learns the other's IP, which is why takedowns target operators rather than addresses. *Also called onion site, onion address, dot onion, tor site.* NETWORKING & PROTOCOLS

High availability *HA* — Design that survives component failure without downtime, through redundancy and failover. Availability is a security property too. CLOUD & INFRASTRUCTURE

Hijack attack — Seizing control of an already-established connection, so the attacker inherits an authenticated session. ATTACKS & EXPLOITATION

HIPAA identifiers *Safe harbour list* — The eighteen identifiers that must be stripped for health data to count as de-identified: names, geography finer than a state, all dates tied to an individual, phone and fax numbers, email, Social Security, medical record, health plan, account, licence and vehicle numbers, device identifiers, URLs, IP addresses, biometrics, full-face photographs, and any other unique code. CLASSIFICATION & PERSONAL DATA

HMAC *Hash-based Message Authentication Code* — A hash keyed with a shared secret, proving both that a message is unaltered and that it came from someone holding the key. CRYPTOGRAPHY

Homograph attack *IDN homograph* — Registering a domain that uses letters from another alphabet which render identically — a Cyrillic a inside apple.com. Indistinguishable to the eye, entirely different to a resolver. *Also called lookalike domain, unicode domain attack, homoglyph.* ATTACKS & EXPLOITATION

Homomorphic encryption — Computing directly on encrypted data without decrypting it. Real, but still slow enough that it is used narrowly rather than by default. CRYPTOGRAPHY

Honey pot — A system that exists only to be attacked, so defenders can watch how it is attacked. Anything touching it is suspicious by definition. *Also called decoy system, trap host.* MALWARE & THREAT ACTORS

Honeymonkey *Honey client* — An automated system that browses the web pretending to be a user, to find sites that attack visitors. MALWARE & THREAT ACTORS

Hop — One handoff between routers on a packet's journey. Hop counts limit how far a packet can travel before being dropped. NETWORKING & PROTOCOLS

Host header injection — Abusing an application's trust in the Host header — for password reset links, cache keys or routing — to point them somewhere the attacker controls. APPLICATION SECURITY

Host-based intrusion detection *HIDS* — Detection that works from a single machine's own records — audit logs, file changes, process activity. Deep visibility on one host, blind to the rest. DEFENSE & OPERATIONS

Hotfix — An urgent fix taken straight to production outside the normal cycle. Legitimate, and worth logging, because it skipped the usual checks. DEV & DELIVERY

HPC *High Performance Computing* — Supercomputing for scientific workloads — climate models, genomics, simulation. Usually accessed through a batch scheduler rather than interactively. COMPUTE & HARDWARE

HSM *Hardware Security Module* — A tamper-resistant device that generates and uses keys without ever exporting them. The key can be used but not copied, even by an administrator. CRYPTOGRAPHY

HSTS *HTTP Strict Transport Security* — A header telling browsers to only ever use HTTPS for a domain, removing the downgrade window on first navigation. APPLICATION SECURITY

HTML *Hypertext Markup Language* — The markup that describes a web page's structure and content. ENDPOINTS & SYSTEMS

HTTP *Hypertext Transfer Protocol* — The request-and-response protocol the web runs on. Plain HTTP is unencrypted, so anything sent over it can be read or altered in transit. NETWORKING & PROTOCOLS

HTTP flood *Layer 7 DDoS* — Overwhelming a service with requests that are individually legitimate — searches, logins, cart additions. There is no malformed packet to drop, so it must be told apart from real users. *Also called application layer DDoS, request flood.* ATTACKS & EXPLOITATION

HTTP proxy — A proxy specifically for web traffic, sitting between browsers and servers. Also the standard tool for intercepting and modifying requests during testing. NETWORKING & PROTOCOLS

HTTP request smuggling *Desync attack* — Exploiting disagreement between a front-end proxy and a back-end server about where one request ends, so a hidden second request is smuggled into another user's connection. *Also called desync, CL.TE, TE.CL.* APPLICATION SECURITY

HTTPS *HTTP over TLS* — HTTP wrapped in TLS encryption. It proves you are talking to the site named in the certificate and stops anyone in the middle reading or editing the traffic. NETWORKING & PROTOCOLS

Hub — An obsolete device that repeated every incoming signal out of every port. Convenient for sniffing, which is exactly why switches replaced it. NETWORKING & PROTOCOLS

Human in the loop *HITL* — Requiring a person to approve consequential AI-driven actions. Only meaningful if the reviewer has the time and information to genuinely disagree. AI & EMERGING TECH

Human on the loop — Supervision where a person monitors an automated system and can intervene, rather than approving each action in advance. The compromise reached when machine-speed response is needed and full human control is not workable — and only real if the person can actually keep up. *Also called supervisory control, oversight.* DEFENSE & OPERATIONS

Hybrid attack — A dictionary attack that also tries the predictable variations people add — numbers, symbols, capital first letters. IDENTITY & ACCESS

Hybrid encryption — Using asymmetric cryptography to agree a key and symmetric cryptography to encrypt the data. Every TLS connection works this way. CRYPTOGRAPHY

Hybrid threat — Coordinated pressure applied across several domains at once — cyber operations, disinformation, economic coercion, deniable force — deliberately kept below the threshold that would trigger a formal response. *Also called grey zone, sub-threshold aggression.* INTELLIGENCE & INVESTIGATIONS

Hybrid warfare — Combining cyber operations, information operations, economic pressure and conventional force. The Sandworm attacks on Ukraine are the standing example. INTELLIGENCE & INVESTIGATIONS

Hyperlink — A pointer in a document to something located elsewhere. The unit of the web, and the delivery mechanism for most phishing. ENDPOINTS & SYSTEMS

Hypervisor — The layer that runs and isolates virtual machines. Escaping it is the most valuable cloud vulnerability class, and correspondingly rare. CLOUD & INFRASTRUCTURE

I

IaaS / PaaS / SaaS — Three levels of cloud service — raw machines, a managed platform, or finished software. The level decides how much security is yours and how much is the provider's. CLOUD & INFRASTRUCTURE

IAM policy — The rules defining which identity may perform which action on which cloud resource. Wildcards in these are the most common cloud misconfiguration. CLOUD & INFRASTRUCTURE

ICMP *Internet Control Message Protocol* — The protocol networks use to report errors and test reachability. It carries no user data, but it leaks a great deal about network shape. NETWORKING & PROTOCOLS

Idempotent — An operation that gives the same result whether you run it once or five times. What makes safe retries possible. DEV & DELIVERY

Identity — Who someone or what something is — the name by which a system knows them. Everything an access decision rests on. IDENTITY & ACCESS

Identity lifecycle *Joiner–Mover–Leaver* — Provisioning access on hire, adjusting it on transfer, and removing it on exit. Leaver failures — dormant accounts with live access — are a recurring audit finding. IDENTITY & ACCESS

Identity rental *Bought identity* — Paying a real person for the use of their name, documents and history to pass a background check. The identity is genuine, which is why verification passes. *Also called borrowed identity, identity brokering.* INTELLIGENCE & INVESTIGATIONS

IDOR *Insecure Direct Object Reference* — Changing an identifier in a URL or request and getting someone else's data because the server never checked ownership. APPLICATION SECURITY

IdP *Identity Provider* — The system that authenticates users and vouches for them to applications — Entra ID, Okta, Google Workspace. Compromise it and every downstream app follows. IDENTITY & ACCESS

IDS / IPS *Intrusion Detection / Prevention System* — Sensors that watch traffic for known-bad patterns. An IDS alerts; an IPS sits inline and drops the traffic, which is more useful and more dangerous. NETWORKING & PROTOCOLS

IETF *Internet Engineering Task Force* — The body that defines the internet's operating protocols, through open working groups and RFCs. NETWORKING & PROTOCOLS

IMAP *Internet Message Access Protocol* — A mail protocol that keeps messages on the server and syncs state across devices. What most mail clients speak today. NETWORKING & PROTOCOLS

Immutable backup *WORM* — Backups that cannot be altered or deleted for a set period, even by an administrator. The specific answer to ransomware deleting backups. *Also called write once backup, WORM backup, locked backup.* CLOUD & INFRASTRUCTURE

Immutable infrastructure — Replacing servers instead of patching them in place. Removes configuration drift and quietly destroys most attacker persistence. CLOUD & INFRASTRUCTURE

Impossible travel — Two logins from places too far apart for the time between them. One of the few signals that catches a stolen session or a worker who is not where they claim. *Also called geo-velocity, travel anomaly.* DEFENSE & OPERATIONS

Incident — An adverse event affecting a system or network, or a credible threat that one is about to happen. DEFENSE & OPERATIONS

Incident handling — The plan for dealing with an incident, conventionally in six steps: preparation, identification, containment, eradication, recovery and lessons learned. DEFENSE & OPERATIONS

Incident response *IR* — The structured process of handling a confirmed security incident. Usually framed as prepare, detect, contain, eradicate, recover, learn. *Also called IR, breach response, cyber incident handling.* DEFENSE & OPERATIONS

Incremental backup — A backup covering only what changed since the last one. Cheap to take, slower to restore, and useless if any link in the chain is missing. DEFENSE & OPERATIONS

Independent post-incident investigation — An examination of a serious incident by investigators the subject does not control, with authority to compel records and set their own scope. Aviation has the NTSB and chemical releases have the Chemical Safety Board; frontier AI, so far, has whatever the lab agrees to. *Also called independent inquiry, external investigation, NTSB model.* GOVERNANCE, RISK & COMPLIANCE

Indirect prompt injection — Injection delivered through a document, web page, or email the model retrieves, so the attacker never talks to the system directly. AI & EMERGING TECH

Inetd *xinetd* — The old Unix service that listened on many ports and started the right program when a connection arrived. ENDPOINTS & SYSTEMS

Inference — Running a trained model to get an output. Where cost, latency, and most data-exposure questions actually live. AI & EMERGING TECH

Inference attack — Deriving something sensitive by connecting pieces of information that are individually harmless. The problem statistical disclosure control exists to solve. ATTACKS & EXPLOITATION

Information warfare — The contest between attackers and defenders over information itself: taking it, corrupting it, denying it, or shaping what people believe. GOVERNANCE, RISK & COMPLIANCE

Infostealer *Stealer* — Malware that grabs saved passwords, cookies, and session tokens, then leaves. Its output feeds credential markets and skips MFA via stolen sessions. MALWARE & THREAT ACTORS

InfraGard — The FBI's partnership programme with the private sector, sharing threat information with the operators of critical infrastructure across financial, energy, health and other sectors. *Also called FBI private sector partnership, sector liaison programme.* INTELLIGENCE & INVESTIGATIONS

Infrastructure as code *IaC — Terraform, CloudFormation* — Defining infrastructure in version-controlled files. Makes environments reviewable and repeatable — and replicates a mistake everywhere instantly. CLOUD & INFRASTRUCTURE

Ingress filtering — Filtering traffic entering your network, including dropping packets whose source addresses could not legitimately come from outside. DEFENSE & OPERATIONS

Inherent vs residual risk — Risk before controls versus what remains after them. Residual risk is the number leadership should actually be shown. GOVERNANCE, RISK & COMPLIANCE

Initial access broker *IAB* — A criminal specialising in breaking in and selling that foothold on. The reason ransomware crews can skip the intrusion step entirely. ATTACKS & EXPLOITATION

Injection — Untrusted input being interpreted as code or commands. The root cause behind SQL injection, command injection, and most template attacks. APPLICATION SECURITY

Input validation — Checking that input matches an expected shape before use. Allow-lists work; deny-lists of bad characters eventually fail. APPLICATION SECURITY

Input validation attack — Deliberately sending unexpected input to see what breaks. The parent class of injection, overflow and traversal bugs. ATTACKS & EXPLOITATION

Insider by design *Planted insider* — An insider who was never a trusted employee who turned, but an adversary who applied for the job in order to be inside. The whole model of insider risk shifts when the insider was placed. INTELLIGENCE & INVESTIGATIONS

Insider threat — Harm caused by someone with legitimate access — malicious, negligent, or coerced. Technical controls help least here; process and monitoring matter most. *Also called malicious insider, trusted insider, employee threat.* ATTACKS & EXPLOITATION

Insider threat programme — The formal function for spotting and handling harm caused by people with legitimate access. It sits across HR, legal and security, which is why it is hard to run. DEFENSE & OPERATIONS

Insider threat vs cyber — Harm from someone with legitimate access. Whether it counts as cyber or physical depends on how they took the data, not on the harm — which is why insider programmes sit across both. INTELLIGENCE & INVESTIGATIONS

Instance metadata abuse *IMDS attack* — Reaching a cloud instance's metadata service — usually through SSRF — to collect the credentials it hands out, and inheriting the machine's permissions. CLOUD & INFRASTRUCTURE

Instance metadata service *IMDS* — A local endpoint that hands running instances their cloud credentials. Reachable via SSRF unless the hardened version is enforced. CLOUD & INFRASTRUCTURE

Instruction set *ISA — x86, ARM, RISC-V* — The vocabulary of operations a processor understands. x86 dominates servers and older PCs, ARM dominates mobile and now Apple and cloud silicon, RISC-V is the open alternative. COMPUTE & HARDWARE

Instrumental goal *Convergent instrumental goal* — A sub-goal useful for almost any final objective — obtaining resources, access, information, or freedom of action. It is why a system given a narrow task can end up acquiring capabilities nobody asked it to acquire, without any hostile intent. *Also called instrumental convergence, subgoal.* AI & EMERGING TECH

Integrity — That information has not been changed, by accident or design, and is complete and accurate. *Also called accuracy, unaltered state, trustworthiness of data.* GOVERNANCE, RISK & COMPLIANCE

Integrity star property *No read down* — In the Biba integrity model, a user may not read data of lower integrity than their own, which would contaminate their work. IDENTITY & ACCESS

Intelligence cycle — The loop intelligence work runs on: direction, collection, processing, analysis, dissemination, and feedback. Threat intelligence teams that skip direction end up collecting indicators nobody asked for and nobody uses. *Also called intelligence process, collection cycle.* INTELLIGENCE & INVESTIGATIONS

Intelligence requirement *PIR, priority intelligence requirement* — The specific question intelligence collection is meant to answer. Without one, a threat intelligence programme becomes a feed subscription. *Also called collection requirement, PIR.* INTELLIGENCE & INVESTIGATIONS

Internal (classification) — Information meant to stay inside the organisation but not damaging if it leaked — internal directories, process documents, ordinary email. The default class most data falls into. *Also called internal use only, staff only.* CLASSIFICATION & PERSONAL DATA

International warrant — A request through international channels for the arrest or search of someone abroad. Its force depends entirely on the receiving country's cooperation. INTELLIGENCE & INVESTIGATIONS

Internet — Strictly, the practice of connecting separate networks together; in general use, the global network that resulted. NETWORKING & PROTOCOLS

Internet Standard — A specification the IETF has blessed as stable, well understood and proven by working implementations. NETWORKING & PROTOCOLS

INTERPOL *International Criminal Police Organization* — The body that lets police forces in nearly two hundred countries pass information and requests to each other. It coordinates and notifies; it has no officers who make arrests. *Also called international police, red notice body.* INTELLIGENCE & INVESTIGATIONS

Interrupt — A signal telling the operating system that something has happened and needs attention now. ENDPOINTS & SYSTEMS

Interview fraud *Proxy interviewing* — Having a stronger or better-spoken candidate sit the interview for the person who will hold the job. Video filters and live translation have made it much harder to spot. *Also called proxy candidate, interview impersonation.* INTELLIGENCE & INVESTIGATIONS

Intranet — An organisation's own internal network built on internet technology, closed to outsiders. NETWORKING & PROTOCOLS

Intrusion detection *IDS (concept)* — Gathering and analysing activity across a system or network to spot security breaches, whether from outside or from insiders. DEFENSE & OPERATIONS

Invoice fraud *Payment diversion, mandate fraud* — Changing the bank details on a real invoice, or sending a convincing fake one, so a legitimate payment goes to the attacker. Usually follows a quiet spell of reading the victim's mailbox. *Also called supplier fraud, payment redirection, BEC invoice.* ATTACKS & EXPLOITATION

IOC *Indicator of Compromise* — An observable sign of intrusion — a hash, a domain, an IP. Easy to share, easy for attackers to change, so it dates quickly. *Also called indicator of compromise, atomic indicator, detection artefact.* MALWARE & THREAT ACTORS

IoT *Internet of Things* — Networked physical devices — cameras, sensors, meters. Weak defaults, rare updates, and long deployments make them ideal botnet recruits. ENDPOINTS & SYSTEMS

IP address *Internet Protocol address* — The number that identifies a device on a network so traffic can be routed to it. IPv4 looks like 192.0.2.10; IPv6 is longer and hexadecimal. NETWORKING & PROTOCOLS

IP flood — A denial of service that buries a host in more ping traffic than it can answer. Crude, loud, and still effective against small links. NETWORKING & PROTOCOLS

IP forwarding — The operating system setting that lets a host pass traffic between its network interfaces — that is, act as a router. Enabled accidentally, it bridges networks you meant to keep apart. NETWORKING & PROTOCOLS

IP lookup — Finding out what is known about an address — who holds it, which network and country it sits in. The first step of most attributions, and the least conclusive. *Also called IP address lookup, geolocating an IP, whois an address, tracing an IP.* INTELLIGENCE & INVESTIGATIONS

IP spoofing — Sending packets with a forged source address. It hides the sender, breaks address-based trust, and makes amplification attacks possible. NETWORKING & PROTOCOLS

IPsec *Internet Protocol Security* — A suite for encrypting and authenticating traffic at the IP layer, used for site-to-site VPNs. Works below the application, so apps need no changes. NETWORKING & PROTOCOLS

Island hopping — Attacking an organisation by first compromising a smaller partner, supplier or subsidiary that is trusted by it. The way into the bank is often through the firm that cleans its offices' laptops. *Also called supplier route in, partner compromise, trusted third-party attack.* ATTACKS & EXPLOITATION

ISO *International Organization for Standardization* — The international standards body whose members are national standards organisations. Its 27000 series covers information security management. GOVERNANCE, RISK & COMPLIANCE

ISO/IEC 27001 *International Organization for Standardization / International Electrotechnical Commission 27001* — The international standard for an information security management system, and certifiable. It assesses the management system, not the technical strength. GOVERNANCE, RISK & COMPLIANCE

Issue-specific policy — A policy covering one particular subject, such as passwords or acceptable use. GOVERNANCE, RISK & COMPLIANCE

ITU-T *International Telecommunication Union, Telecommunication Standardization Sector* — The United Nations telecommunications standards body, whose specifications are published as Recommendations. X.509 certificates come from here. GOVERNANCE, RISK & COMPLIANCE

J

Jailbreak — Framing that persuades a model past its safety training. Distinct from prompt injection, which targets the application's instructions. AI & EMERGING TECH

Jitter (data) — Perturbing values in a database while preserving its aggregate statistics, so individuals cannot be picked out of published data. GOVERNANCE, RISK & COMPLIANCE

Job scheduler *Slurm, PBS* — Software that queues and allocates cluster jobs across users. On shared research clusters, you submit a job and wait rather than running things directly. COMPUTE & HARDWARE

Joint investigation — An investigation run by more than one agency, often across borders. It multiplies reach and multiplies the questions of who charges, where, and under whose rules. INTELLIGENCE & INVESTIGATIONS

JSON / YAML *JavaScript Object Notation / YAML Ain't Markup Language* — The two everyday data formats: JSON for APIs, YAML for configuration. YAML's indentation and loose typing cause more outages than they should. DEV & DELIVERY

Juice jacking — Data theft or malware delivery through a public charging port, which carries data as well as power. Charge-only cables and adapters are the answer. ENDPOINTS & SYSTEMS

Jump bag *Go bag* — The kit an incident responder can pick up and leave with — write blockers, drives, cables, notebooks, contact lists. Assembled before it is needed, not during. DEFENSE & OPERATIONS

Jumping *Hopping* — Moving a connection through a chain of intermediate machines so the far end never sees where it started. It is what Tor does deliberately with relays, and what an attacker does through compromised hosts — each hop is one more party who would have to be asked, in one more jurisdiction, to trace the traffic back. *Also called hopping, hopping through nodes, relaying, bouncing.* NETWORKING & PROTOCOLS

Just-in-time access *JIT* — Granting elevated rights only for a defined window, then removing them automatically. Replaces standing admin access, which is what attackers actually hunt for. IDENTITY & ACCESS

Just-in-time manufacturing *JIT* — Producing and delivering only what is needed, when it is needed, holding almost no stock. Efficient, and it removes the slack that would otherwise absorb an outage — which is why an IT failure now stops a factory within days. *Also called lean manufacturing, zero inventory.* GOVERNANCE, RISK & COMPLIANCE

JWT *JSON Web Token* — A signed, self-describing token carrying claims about a user. Readable by anyone holding it — signed, not secret — so never put anything confidential inside. IDENTITY & ACCESS

K

Kerberoasting — Requesting service tickets for accounts with weak passwords and cracking them offline. Quiet, effective, and needs only an ordinary domain account to start. *Also called service ticket cracking, SPN roasting.* IDENTITY & ACCESS

Kerberos — The ticket-based authentication protocol underneath Windows domains. Its ticket mechanics give rise to Kerberoasting, Golden Ticket, and Silver Ticket attacks. IDENTITY & ACCESS

Kerberos delegation abuse *Unconstrained delegation attack* — Abusing a service trusted to act on users' behalf to impersonate them elsewhere, up to and including domain administrators. IDENTITY & ACCESS

Kernel — The core of the operating system, running with full hardware access. Code running here can hide from everything above it. ENDPOINTS & SYSTEMS

KEV *Known Exploited Vulnerabilities catalogue* — CISA's list of vulnerabilities confirmed exploited in the wild. A far better patching priority than CVSS score alone. GOVERNANCE, RISK & COMPLIANCE

Key derivation function *KDF — bcrypt, scrypt, Argon2, PBKDF2* — A deliberately slow, memory-hungry hash for passwords. Slowness is the feature: it makes brute-force guessing expensive. CRYPTOGRAPHY

Key management *KMS* — Generating, storing, rotating, and retiring keys. Almost every real-world crypto failure is a key management failure, not a broken algorithm. CRYPTOGRAPHY

Keylogger — Records keystrokes to capture passwords and messages. Exists as software and as small hardware devices inline with a keyboard. *Also called keystroke logger, key capture.* MALWARE & THREAT ACTORS

Kill switch — A condition that stops malware running — sometimes deliberate, as an operator's off switch, sometimes an anti-analysis check that misfires. WannaCry's was an unregistered domain: a researcher registered it for about ten dollars and the global spread stopped that afternoon. *Also called killswitch, sinkhole domain, stop condition.* MALWARE & THREAT ACTORS

Know your employee *KYE* — Applying the same identity assurance to staff that regulation demands for customers: document checks, liveness, address and right-to-work verification, repeated rather than done once at hiring. DEFENSE & OPERATIONS

Known-plaintext attack *KPA* — Attacking a cipher using pairs of plaintext and matching ciphertext you already hold. CRYPTOGRAPHY

KRACK *Key Reinstallation Attack* — A flaw in the WPA2 handshake that let an attacker force reuse of an encryption key and decrypt traffic. Patched, and a reminder that a proof in a paper is not a proof in an implementation. NETWORKING & PROTOCOLS

Kubernetes *K8s* — The dominant container orchestrator. Powerful, and insecure by default in ways that need deliberate configuration to fix. *Also called K8s, container orchestration, cluster orchestrator.* CLOUD & INFRASTRUCTURE

KV cache — Stored intermediate values that let a language model generate each new token without recomputing the whole context. It grows with context length and eats VRAM. COMPUTE & HARDWARE

L

L2TP *Layer 2 Tunneling Protocol* — A tunnelling protocol used to build VPNs, normally paired with IPsec because it provides no encryption of its own. NETWORKING & PROTOCOLS

Labelling *Marking* — Recording the classification on the document, file or message itself so the handling rules travel with it. Automated labelling is what makes DLP enforceable. CLASSIFICATION & PERSONAL DATA

LAND attack — Sending a packet whose source and destination are both the victim, so the machine answers itself in a loop. Trivial to filter, once anyone thought to. ATTACKS & EXPLOITATION

Laptop farm — A house in the target's own country holding the company laptops issued to remote workers who are somewhere else entirely. A facilitator plugs them in and installs remote access, so the connection comes from the expected place. *Also called laptop mule, hardware facilitator.* INTELLIGENCE & INVESTIGATIONS

Large language model *LLM* — A model trained on vast text to predict likely continuations. Fluent by construction, and fluency is not the same as being correct. *Also called LLM, chatbot model, foundation model, generative model.* AI & EMERGING TECH

Lateral movement — Moving from the first compromised host to more valuable ones inside the network. Usually done with stolen valid credentials, not new exploits. *Also called moving sideways, east-west movement, internal spread.* ATTACKS & EXPLOITATION

Lattice techniques — Access decided by ordered security labels, where information may move in one direction through the ordering but not the other. IDENTITY & ACCESS

Lawful basis — The legal justification for processing personal data — consent, contract, legal obligation, vital interests, public task, legitimate interests. GOVERNANCE, RISK & COMPLIANCE

Lazarus Group *Lazarus, Hidden Cobra* — North Korea's state cyber apparatus, unusual in pursuing revenue as well as espionage and destruction: Sony, WannaCry, the Bangladesh Bank heist and the large cryptocurrency thefts are all attributed to it. *Also called Hidden Cobra, APT38, DPRK hackers.* MALWARE & THREAT ACTORS

LDAP *Lightweight Directory Access Protocol* — The protocol for querying a directory of users, groups and resources. Directory queries are also how attackers map an organisation from the inside. IDENTITY & ACCESS

LDAP injection — Injecting filter syntax into a directory query to bypass authentication or read more of the directory than intended. APPLICATION SECURITY

Least privilege — Give each account only the access its job requires, and no more. The principle nearly every access review is trying to enforce. *Also called minimum necessary access, PoLP, minimal permissions.* IDENTITY & ACCESS

Left of boom / right of boom — Military shorthand adopted by security: everything before the incident is left of boom, everything after is right of boom. Prevention against response, on one timeline. *Also called before and after the incident, prevention vs response.* DEFENSE & OPERATIONS

Legacy system — Software or hardware still doing essential work after the point at which it can be safely maintained — unsupported, undocumented, and too entangled to replace cheaply. Most catastrophic recoveries are long because of these. *Also called end-of-life system, unsupported software, legacy estate.* ENDPOINTS & SYSTEMS

Legion — An old tool for finding unprotected network shares. The technique long outlived the tool. ENDPOINTS & SYSTEMS

Length extension attack — Appending to a message and computing a valid hash for the longer version without knowing the secret, against constructions that use a raw hash where they should use HMAC. CRYPTOGRAPHY

Let's Encrypt / ACME *Automatic Certificate Management Environment* — A free CA and the protocol that automates issuing and renewing certificates. It made HTTPS the default rather than an upgrade. CRYPTOGRAPHY

Link state — A routing approach where every router keeps a map of the whole area and calculates its own best paths. Faster to converge than distance vector; OSPF is the example. NETWORKING & PROTOCOLS

Linter / formatter — Tools that flag likely mistakes and enforce consistent style automatically. They end style arguments and catch a surprising number of bugs. DEV & DELIVERY

List based access control — Access defined by attaching a list of users and privileges to each object. IDENTITY & ACCESS

Living off the land *LOLBins* — Using tools already installed — PowerShell, certutil, curl, WMI — instead of dropping malware. Nothing to detect as a bad file, so behaviour is the only signal. *Also called LOLBins, using built-in tools, native tooling abuse.* ATTACKS & EXPLOITATION

Load balancer — Spreads incoming traffic across several backend servers, and takes unhealthy ones out of rotation. Also a single point to enforce TLS and rate limits. *Also called traffic distributor, LB, front-end director.* NETWORKING & PROTOCOLS

Loadable kernel module *LKM* — Code that adds functionality to a running kernel without a reboot. A useful facility, and how kernel-level rootkits get in. ENDPOINTS & SYSTEMS

Loader / dropper — Small first-stage malware whose only job is to fetch and run the real payload. Kept simple so it stays undetected. MALWARE & THREAT ACTORS

Local admin rights — Full control of one machine. Removing standing local admin from ordinary users blocks a large share of malware outright. ENDPOINTS & SYSTEMS

Local file inclusion *LFI* — Making an application include a file from its own disk that it was never meant to — configuration, credentials, logs — usually through a path parameter. APPLICATION SECURITY

Lockfile *package-lock.json, requirements.txt* — A record of the exact dependency versions installed, so every machine and every build gets the same ones. Commit it. DEV & DELIVERY

Log clipping — Selectively deleting entries from a log to hide a compromise. Why logs are shipped off the host as they are written. DEFENSE & OPERATIONS

Log loss — Evidence that no longer exists, usually because recovery came first. Restoring controllers from backup at a Polish power plant minimised downtime and permanently erased their operational logs — the right operational decision and a permanent forensic one. *Also called evidence loss, missing telemetry.* INTELLIGENCE & INVESTIGATIONS

Log retention — How long logs are kept. Intrusions are often found months later, so short retention quietly makes investigation impossible. DEFENSE & OPERATIONS

Logic bomb — Malicious code that triggers on a condition, such as a date or a name disappearing from payroll. Usually an insider's tool. *Also called delayed payload, timed trigger, dead man switch.* MALWARE & THREAT ACTORS

Logic gate — The elementary building block of a digital circuit, taking binary inputs to a binary output. Everything above it is built from these. ENDPOINTS & SYSTEMS

Long-horizon agent — A system that pursues a goal across many steps and a long span of time, holding context and adapting as it goes. The property that turns a model from a tool answering questions into something that conducts an operation. *Also called long-running agent, persistent agent, multi-step autonomy.* AI & EMERGING TECH

Loopback address *127.0.0.1* — The pseudo-address that always means this machine. Traffic to it never leaves the host, which is why services bound to it are not exposed. NETWORKING & PROTOCOLS

M

MAC address *Media Access Control address* — The hardware identifier burned into a network interface. Useful for local identification, useless as an authenticator — it can be changed in one command. NETWORKING & PROTOCOLS

MAC flooding *CAM table overflow* — Filling a switch's address table with forged MAC addresses until it fails open and floods every port, turning the switch back into a hub so traffic can be sniffed. NETWORKING & PROTOCOLS

MAC spoofing — Changing a device's hardware address to impersonate another or to evade a filter. Address-based access control is a speed bump, not a control. NETWORKING & PROTOCOLS

Machine learning *ML* — Systems that derive rules from data rather than being programmed with them. The behaviour reflects the training data, including its errors and bias. AI & EMERGING TECH

main / master *Default branch* — The branch treated as the source of truth. Most projects protect it so nothing lands without review. DEV & DELIVERY

Malicious code — Software that looks useful but takes unauthorised access, or tricks the user into running something worse. The umbrella over viruses, Trojans and the rest. MALWARE & THREAT ACTORS

Malicious package — A package published to a public registry that carries hostile code, often under a name close to a popular one, and runs the moment it is installed. ATTACKS & EXPLOITATION

Malvertising — Malicious code delivered through legitimate ad networks, so a trusted site serves it unknowingly. ATTACKS & EXPLOITATION

Malware — Any software written to do harm or gain unauthorised access. An umbrella term covering everything below it. *Also called malicious software, malicious code, badware.* MALWARE & THREAT ACTORS

Malware family — A cluster of related samples sharing code and behaviour. Naming is inconsistent across vendors, which is why the same thing has five names. MALWARE & THREAT ACTORS

Mandatory access control *MAC* — Access decided by the system from classification labels on both users and data, which users cannot override. The model behind government classification. IDENTITY & ACCESS

Masquerade attack — One entity illegitimately posing as another to gain what that identity is trusted with. ATTACKS & EXPLOITATION

Mass assignment *Auto-binding vulnerability* — Binding a request body straight to an internal object, so a field the form never showed — role, is_admin, price — can be set by adding it to the request. *Also called over-posting, object injection.* APPLICATION SECURITY

MCP *Model Context Protocol* — An open standard for connecting models to tools and data sources. Each connected server is a new trust relationship to review. AI & EMERGING TECH

MD5 *Message Digest 5* — An old cryptographic hash, now broken: attackers can produce two inputs with the same digest. Still seen as a file identifier, never as a security control. CRYPTOGRAPHY

MDM *Mobile Device Management* — Central enrolment and policy for phones and laptops — encryption, passcodes, app control, remote wipe. ENDPOINTS & SYSTEMS

Measures of effectiveness *MOE* — An attempt to estimate what effect a given action will actually have, rather than whether it was carried out. GOVERNANCE, RISK & COMPLIANCE

Meet-in-the-middle attack — Attacking double encryption from both ends at once, which is why encrypting twice with a block cipher buys far less strength than it appears to. CRYPTOGRAPHY

Memcached amplification — Abusing exposed memcached servers, which answer tiny queries with enormous responses, to produce some of the largest floods ever recorded. Amplification at a ratio of tens of thousands to one. ATTACKS & EXPLOITATION

Memory bandwidth — How fast data moves between memory and the processor. For large models, feeding the chip is harder than the arithmetic itself. COMPUTE & HARDWARE

Memory forensics — Analysing RAM for injected code, decrypted secrets, and running processes that never touched disk. Often the only place fileless malware exists. DEFENSE & OPERATIONS

Memory safety — Preventing whole classes of memory bugs by design. The main argument for Rust, Go, and similar languages in new systems code. APPLICATION SECURITY

Merge — Combining one branch's changes into another. Git does it automatically unless both sides edited the same lines. DEV & DELIVERY

Merge conflict — Two branches changed the same lines and Git refuses to guess. You pick what the file should say, then commit the resolution. DEV & DELIVERY

Metadata vs content — Metadata is the record about a communication — who, when, from where, how long. Content is what was said. They are protected differently in law, and metadata is very often enough on its own. *Also called non-content data, transactional records, envelope vs content.* INTELLIGENCE & INVESTIGATIONS

MFA fatigue *Push bombing* — Spamming approval prompts until a tired user taps accept. Countered with number matching or by dropping push approval altogether. ATTACKS & EXPLOITATION

MI5 *Security Service* — The United Kingdom's domestic security service, responsible for threats inside the UK — terrorism, espionage, subversion. *Also called Security Service, British domestic intelligence, box 500.* INTELLIGENCE & INVESTIGATIONS

MI6 *Secret Intelligence Service, SIS* — The United Kingdom's foreign intelligence service, collecting abroad. The James Bond half of the pair; MI5 is the domestic half. *Also called SIS, Secret Intelligence Service, British foreign intelligence, James Bond.* INTELLIGENCE & INVESTIGATIONS

Microsegmentation — Segmentation taken down to the individual workload, with policy attached to the service rather than the subnet. Usually enforced by agents or a service mesh. *Also called workload isolation, fine-grained segmentation.* NETWORKING & PROTOCOLS

MITRE ATT&CK *Adversarial Tactics, Techniques and Common Knowledge* — A public catalogue of real-world attacker techniques, organised by tactic. The common vocabulary for describing and mapping detection coverage. *Also called ATT&CK matrix, technique framework, TTP taxonomy.* MALWARE & THREAT ACTORS

Modbus — The oldest and most widespread industrial protocol, with no authentication and no encryption by design. Anything that can send a Modbus message to a device can command it. *Also called Modbus TCP, fieldbus protocol.* NETWORKING & PROTOCOLS

Model card — Documentation of a model's intended use, training data, evaluation, and limitations. The AI equivalent of a datasheet. AI & EMERGING TECH

Model extraction *Model stealing* — Reconstructing a proprietary model by querying it enough times to train a copy of its behaviour. AI & EMERGING TECH

Model inversion / membership inference — Extracting training data, or proving a specific record was in the training set, by probing the model. A privacy problem for models trained on personal data. AI & EMERGING TECH

Model registry *Model hub* — A shared repository of trained models people download and run — Hugging Face being the largest. It is a package registry in every respect that matters for security, including that most users never inspect what they pull. *Also called model hub, model repository, weights registry.* AI & EMERGING TECH

Model weights *Parameters* — The learned numbers that are the model. Their count and precision together decide how much VRAM you need — roughly two bytes per parameter at 16-bit. COMPUTE & HARDWARE

Money mule — A person, witting or not, whose account is used to move criminal proceeds onward. Recruitment is often disguised as a remote job. ATTACKS & EXPLOITATION

Monoculture — Everyone running the same software, so one vulnerability reaches everyone. A resilience argument, not a technical one. MALWARE & THREAT ACTORS

Monorepo — Many projects in one repository, sharing tooling and history. Simpler coordination, heavier tooling; the alternative is many small repos. DEV & DELIVERY

Morris Worm — The 1988 worm that spread across the ARPANET and forced thousands of hosts offline. The event that produced the first CERT. MALWARE & THREAT ACTORS

mTLS *Mutual TLS* — TLS where both sides present certificates, not just the server. Common between internal services because it authenticates the client without passwords. NETWORKING & PROTOCOLS

MTTD / MTTR *Mean Time to Detect / Respond* — How long detection and response take on average. The two operational metrics that most reflect real-world damage. DEFENSE & OPERATIONS

Multi-agent system *MAS* — A system where several agents, each with its own tools and objectives, coordinate to reach a goal. The security problems are new in kind: one compromised agent can steer the others, and no single log shows the whole decision. *Also called agent orchestration, agent network.* AI & EMERGING TECH

Multi-cloud — Using more than one cloud provider. Reduces lock-in, multiplies the number of identity and policy models you must get right. CLOUD & INFRASTRUCTURE

Multi-factor authentication *MFA / 2FA* — Requiring two or more different kinds of proof — something you know, have, or are. The single highest-value control against stolen passwords. *Also called MFA, 2FA, two-factor authentication, step-up authentication.* IDENTITY & ACCESS

Multi-homed — Connected to more than one upstream provider. It buys resilience, and it complicates routing and filtering. NETWORKING & PROTOCOLS

Multi-tenancy — One set of infrastructure serving many customers, separated by software rather than by hardware. Efficient, and it makes the isolation boundary the only thing standing between one tenant and everyone else's data. *Also called shared infrastructure, tenant isolation.* CLOUD & INFRASTRUCTURE

Multicast — Traffic from one host to a defined group of hosts. Efficient for streaming, and awkward to filter. NETWORKING & PROTOCOLS

Multiplexing — Combining several signals onto one path so they can share a link. Every backbone circuit depends on it. NETWORKING & PROTOCOLS

Mutual legal assistance treaty *MLAT* — The formal channel by which one country asks another for evidence. Slow enough — often months — that investigators plan around it rather than through it. *Also called MLAT, international evidence request, letters rogatory.* INTELLIGENCE & INVESTIGATIONS

N

N-day *One-day* — A known, patched vulnerability that is still exploitable because the target has not applied the fix. The overwhelming majority of real intrusions. ATTACKS & EXPLOITATION

NAT *Network Address Translation* — A router rewriting private internal addresses into one public address on the way out. It is why a whole office can share a single IP, and why inbound connections need explicit port forwarding. NETWORKING & PROTOCOLS

National Crime Agency *NCA* — The UK's national law enforcement agency for serious and organised crime, including its National Cyber Crime Unit. *Also called NCA, British FBI, national cyber crime unit.* INTELLIGENCE & INVESTIGATIONS

NATO *North Atlantic Treaty Organization* — The intergovernmental military alliance of North American and European states. It has said that a cyber attack can trigger the collective defence commitment, without saying which one would. *Also called North Atlantic Treaty Organization, the alliance, article 5 alliance.* INTELLIGENCE & INVESTIGATIONS

NATO CCDCOE *Cooperative Cyber Defence Centre of Excellence* — NATO's cyber defence research and training centre in Tallinn, best known for the Tallinn Manual on how international law applies to cyber operations. *Also called Tallinn centre, Tallinn Manual, cyber defence centre of excellence.* INTELLIGENCE & INVESTIGATIONS

Natural disaster — Fire, flood, earthquake, storm — the causes of outage that no amount of patching prevents. They belong in the same plan as attacks. DEFENSE & OPERATIONS

Need to know — The rule that clearance permits access only to the specific information required for your role. It is what stops a Top Secret clearance from being a key to everything. *Also called NTK, least privilege for classified.* CLASSIFICATION & PERSONAL DATA

NetFlow *Flow data* — Summary records of who talked to whom, for how long, and how much — without the contents. Cheap to keep for a long time, which makes it the backbone of retrospective hunting. NETWORKING & PROTOCOLS

Netmask *Subnet mask* — The 32-bit value that separates the network part of an address from the host part. It decides what counts as local and what has to go through a router. NETWORKING & PROTOCOLS

Network mapping — Building an inventory of the hosts and services on a network. The same exercise for a defender protecting an estate and an attacker planning a route through it. NETWORKING & PROTOCOLS

Network segmentation — Splitting a network into zones with controlled paths between them so a foothold in one zone does not reach everything. The single most effective limit on lateral movement. *Also called zoning, network separation, segmentation.* NETWORKING & PROTOCOLS

Network tap — A hardware device spliced into a cable that copies passing traffic to a monitoring system. Unlike a mirrored port, it cannot silently drop traffic under load. NETWORKING & PROTOCOLS

Network-based intrusion detection *NIDS* — Detection that watches traffic passing a sensor on the network. It sees breadth, and only what crosses its own segment. DEFENSE & OPERATIONS

NGFW *Next-Generation Firewall* — A firewall that also identifies the application and user behind the traffic, not just ports and IPs, and can inspect decrypted sessions. NETWORKING & PROTOCOLS

NIST *National Institute of Standards and Technology* — The US standards agency whose publications — the Cybersecurity Framework, the 800 series — function as default security guidance far beyond the US government. GOVERNANCE, RISK & COMPLIANCE

NIST CSF *NIST Cybersecurity Framework* — A voluntary framework organised around Govern, Identify, Protect, Detect, Respond, Recover. Widely used as a common structure for maturity conversations. GOVERNANCE, RISK & COMPLIANCE

NIST SP 800-53 / 800-171 — Detailed US federal control catalogues — 800-53 for federal systems, 800-171 for contractors handling controlled unclassified information. GOVERNANCE, RISK & COMPLIANCE

No expectation of privacy — The doctrine that where a person had no reasonable expectation of privacy, evidence can be gathered without a warrant. Corporate banners and acceptable use policies exist largely to establish it. INTELLIGENCE & INVESTIGATIONS

Node (Tor) *Relay* — One of the volunteer machines a Tor circuit is built from. Each relay knows only the hop before and the hop after, which is what breaks the link between sender and destination. INTELLIGENCE & INVESTIGATIONS

Non-printable character — A byte with no visible character, like a linefeed or a null. Filters that only think about visible text are routinely bypassed with these. NETWORKING & PROTOCOLS

Non-repudiation — Being able to prove someone took an action so they cannot credibly deny it. What signatures and tamper-evident logs provide. *Also called undeniability, proof of origin.* GOVERNANCE, RISK & COMPLIANCE

Nonce / IV *Number used once / Initialisation Vector* — A unique value per encryption operation so identical plaintexts do not produce identical ciphertexts. Reusing one can collapse the security of the whole scheme. CRYPTOGRAPHY

Norms of state behaviour *Cyber norms* — The non-binding expectations states have agreed on for conduct in cyberspace — not attacking critical infrastructure or emergency response teams in peacetime, and assisting when an attack transits your territory. Agreed at the UN, and repeatedly ignored without consequence. *Also called UN GGE norms, responsible state behaviour.* INTELLIGENCE & INVESTIGATIONS

NoSQL injection — Injection against a document database, using operator objects rather than SQL syntax. Different language, identical failure to separate code from data. APPLICATION SECURITY

Notification letter *Breach notice* — The letter sent to people whose personal data was exposed, saying what happened and what is being offered. In most US states and under GDPR it is a legal duty with a clock attached. CLASSIFICATION & PERSONAL DATA

NSA *National Security Agency* — The US signals intelligence agency — interception, cryptanalysis, satellites — and also the source of much defensive cryptographic guidance. Long nicknamed 'no such agency' for how little it acknowledged itself. *Also called National Security Agency, no such agency, signals intelligence agency.* INTELLIGENCE & INVESTIGATIONS

NTLM relay *SMB relay* — Capturing an authentication attempt and relaying it, unbroken, to a different service that accepts it. Nothing is cracked; the handshake is simply forwarded. *Also called authentication relay, SMB relay attack.* IDENTITY & ACCESS

NTP amplification — Using time servers that answer a small query with a long list of recent clients to multiply an attacker's traffic against a victim. ATTACKS & EXPLOITATION

Null session *Anonymous logon* — A Windows connection made without credentials that could still enumerate users and shares. A classic reconnaissance foothold. IDENTITY & ACCESS

NVLink / InfiniBand *Interconnect* — High-speed links between GPUs and between servers. Training a large model across many chips is limited by interconnect as much as by the chips. COMPUTE & HARDWARE

O

OAuth 2.0 — A delegation framework: it lets an app act on your behalf against another service without ever seeing your password. It is about access, not identity. IDENTITY & ACCESS

Obfuscation — Deliberately making code hard to read or analyse. Used by malware authors and, legitimately, by software vendors protecting their products. MALWARE & THREAT ACTORS

Object storage *S3, Blob, GCS* — Cloud file storage addressed by key rather than path. Publicly-readable buckets remain one of the most common data exposures. CLOUD & INFRASTRUCTURE

Observability *Logs, metrics, traces* — Being able to tell what a running system is doing from the outside. Logs say what happened, metrics count it, traces follow one request across services. DEV & DELIVERY

Octet — Eight bits. Used instead of 'byte' in networking, where a byte has not always meant eight bits. NETWORKING & PROTOCOLS

Offensive cyber capability — A state's ability to operate against others' systems — the exploits, the access, the infrastructure and the legal authority to use them. Most governments now acknowledge having one; almost none describe what it consists of. *Also called offensive cyber operations, national offensive capability.* INTELLIGENCE & INVESTIGATIONS

OIDC *OpenID Connect* — An identity layer built on top of OAuth 2.0. OAuth grants access; OIDC actually tells the app who you are, in a signed ID token. IDENTITY & ACCESS

On-call / escalation — Defined rotas and paths for raising an incident out of hours. An unclear escalation path costs more time than any tool saves. DEFENSE & OPERATIONS

One-click exploit — An exploit needing a single tap on a link, with no further action. The gap between this and zero-click is the whole of user awareness training. ATTACKS & EXPLOITATION

One-way encryption — An irreversible transformation, where the original cannot be recovered from the output even knowing the key. Hashing, not encryption, despite the name. CRYPTOGRAPHY

One-way function — A function easy to compute forwards and infeasible to reverse. The foundation of hashing and of public-key cryptography. CRYPTOGRAPHY

Onion Router *Tor* — The full name of Tor, filed here so it can be found under O as well as T. Traffic is wrapped in a layer of encryption for each relay it will cross, and each relay peels off one — hence the onion. *Also called tor, onion routing, darknet.* NETWORKING & PROTOCOLS

Onion routing — The layered-encryption technique behind Tor: each relay peels off one layer, learning only enough to pass the traffic on. *Also called tor, onion router.* NETWORKING & PROTOCOLS

Open redirect — A page that forwards to any address given in a parameter. It lends the site's good name to a link that ends up somewhere else, and it is a standard building block of phishing. *Also called unvalidated redirect.* APPLICATION SECURITY

Operating system *OS* — The software managing hardware, memory, and processes. Its permission model is the boundary attackers are usually trying to cross. ENDPOINTS & SYSTEMS

Operational security failure *OPSEC failure* — The mistake that undoes an otherwise anonymous operation — a reused username, an early forum post, a personal email in a code commit, a package addressed to a real name. Silk Road's operator was found through his own early advertising posts, not through breaking Tor. INTELLIGENCE & INVESTIGATIONS

Order of volatility — Collect the most perishable evidence first — memory, then network state, then disk. Pulling the plug destroys the most useful data. DEFENSE & OPERATIONS

OSI model *Open Systems Interconnection* — The seven-layer reference model for network communication, from physical wiring up to the application. Nothing implements it exactly; everyone uses it to describe where a problem sits. NETWORKING & PROTOCOLS

OSPF *Open Shortest Path First* — A link-state routing protocol used inside an organisation's own network. Routers share a map of links and costs rather than just hop counts. NETWORKING & PROTOCOLS

OT / ICS *Operational Technology / Industrial Control Systems* — Computers that run physical processes — plants, grids, pipelines. Long lifespans, no patch windows, and safety outranks confidentiality. *Also called operational technology, industrial control systems, SCADA environment.* ENDPOINTS & SYSTEMS

Output encoding — Escaping data for the context it lands in — HTML, attribute, JavaScript, SQL. The correct fix for XSS, applied at the point of output. APPLICATION SECURITY

Overlay attack — A mobile app drawing an invisible or convincing layer over another to capture what is typed into it — the banking trojan's standard technique. ENDPOINTS & SYSTEMS

Overload — Degrading a system by loading it beyond what its components can handle. The result may be denial of service without any exploit at all. NETWORKING & PROTOCOLS

OWASP *Open Worldwide Application Security Project* — A nonprofit producing free application security guidance, tools, and the widely-cited Top 10 lists. APPLICATION SECURITY

OWASP Top 10 — A periodically-updated list of the most critical web application risks. An awareness document, not a checklist to certify against. APPLICATION SECURITY

P

Package manager *npm, pip, cargo, apt* — The tool that installs and updates dependencies. Also the channel a typosquatted or hijacked package arrives through. DEV & DELIVERY

Packer / crypter — Tools that compress or encrypt malware so its file signature changes. Cheap evasion, which is why signature-only detection fails. MALWARE & THREAT ACTORS

Packet — A chunk of a message with a destination address attached, routed independently across the network. In IP networks packets are also called datagrams. NETWORKING & PROTOCOLS

Packet capture *PCAP* — A raw recording of network traffic, read with tools like Wireshark or tcpdump. The ground truth when logs disagree about what actually crossed the wire. NETWORKING & PROTOCOLS

Packet-switched network — A network where each packet finds its own route to the destination and the pieces are reassembled on arrival. Resilient because there is no single fixed path to break. NETWORKING & PROTOCOLS

Padding oracle attack — Using a system's different responses to valid and invalid padding as an oracle that reveals plaintext, one byte at a time, without the key. CRYPTOGRAPHY

PAM *Privileged Access Management* — Controls specifically for admin accounts — vaulted credentials, checkout with approval, session recording, and automatic rotation. IDENTITY & ACCESS

PAP *Password Authentication Protocol* — A weak authentication scheme that sends the password across the network, usually unprotected. Superseded by CHAP and everything after. IDENTITY & ACCESS

Parallelism *Data / model / pipeline parallel* — Splitting work across chips — by data batch, by slicing the model itself, or by staging layers. How anything too large for one accelerator gets trained. COMPUTE & HARDWARE

Parameter tampering — Editing values the application assumed the client would not change — prices, quantities, identifiers, roles. The client is not a trustworthy place to enforce anything. APPLICATION SECURITY

Parameterised query *Prepared statement* — Sending SQL structure and data separately so input can never become code. The definitive SQL injection fix. APPLICATION SECURITY

Partition — A major division of a physical disk, treated as a separate volume by the operating system. ENDPOINTS & SYSTEMS

Pass-the-hash *PtH* — Authenticating with a stolen password hash without ever cracking it, because the protocol accepts the hash as proof. *Also called PtH, hash reuse attack.* IDENTITY & ACCESS

Pass-the-ticket *PtT* — Stealing a Kerberos ticket from memory and reusing it elsewhere. The password is never needed, and never changed in response. IDENTITY & ACCESS

Passkey — A WebAuthn credential stored on a device or synced through a platform account, replacing the password entirely. Unlocked with a fingerprint, face, or PIN. IDENTITY & ACCESS

Password cracking — Working out passwords from stolen hashes by guessing and hashing candidates until one matches. IDENTITY & ACCESS

Password reset poisoning — Manipulating the host or reply headers so the password reset link a service generates points at the attacker. IDENTITY & ACCESS

Password sniffing — Capturing credentials off the wire, usually on a local network, from protocols that send them in the clear. IDENTITY & ACCESS

Password spraying — Trying one or two common passwords across many accounts, staying under lockout thresholds. Slower than brute force and far less likely to trip alarms. *Also called low and slow guessing, common password attack.* IDENTITY & ACCESS

Patch — A vendor fix for a bug or vulnerability. Applying them promptly prevents more breaches than any tool you can buy. *Also called update, fix, security update, hotfix.* ENDPOINTS & SYSTEMS

Patch Tuesday — Microsoft's monthly release of security fixes, on the second Tuesday. Exploit development against those fixes typically follows within days. ENDPOINTS & SYSTEMS

Path traversal *Directory traversal* — Using ../ sequences to read files outside the intended directory, such as configuration or key material. *Also called directory traversal, dot dot slash, ../ attack.* APPLICATION SECURITY

Payload — The part of an attack that does the intended damage or gives access, as opposed to the delivery mechanism that gets it there. ATTACKS & EXPLOITATION

Payment card data *CHD* — The cardholder data PCI DSS governs — the card number, cardholder name, expiry and service code — plus the authentication data that may never be stored at all: the full magnetic stripe, the CVV, and the PIN. *Also called cardholder data, CHD, credit card data, PAN.* CLASSIFICATION & PERSONAL DATA

Payment fraud — Fraud against the payment process rather than the payment technology: a genuine instruction, correctly formatted and properly authorised, sent by the wrong person or altered before it is sent. *Also called transaction fraud, wire fraud, payment diversion.* ATTACKS & EXPLOITATION

Payroll anomaly — Salary routed to an account, service or country that does not match the employee — repeatedly changed details, shared accounts across staff, immediate onward transfer. Finance sees the fraud before security does. *Also called salary diversion, pay routing anomaly.* DEFENSE & OPERATIONS

PCI DSS *Payment Card Industry Data Security Standard* — Mandatory rules for anyone handling payment card data. Contractual rather than statutory, and enforced by fines and lost processing rights. GOVERNANCE, RISK & COMPLIANCE

PCIe *Peripheral Component Interconnect Express* — The bus connecting GPUs, drives and network cards to the processor. Its generation and lane count cap how fast data reaches an accelerator. COMPUTE & HARDWARE

Penetration — Getting unauthorised access to sensitive data by getting around a system's protections. ATTACKS & EXPLOITATION

Penetration test *Pentest* — An authorised, time-boxed attempt to break in and prove impact. Deeper than a scan, narrower than a red team engagement. *Also called pentest, pen test, ethical hacking, red teaming exercise, pentest, pen testing.* APPLICATION SECURITY

Pepper — A secret value mixed into password hashing and stored separately from the database, so a database dump alone is not enough to start cracking. CRYPTOGRAPHY

Perimeter device *Edge device* — The firewall, router or gateway that sits at the boundary of a site. Internet-facing by definition, frequently unpatched, and the most common initial access point in operational technology intrusions. *Also called edge appliance, boundary device.* NETWORKING & PROTOCOLS

Perl — A scripting language with strong text-processing roots, long the default for system administration and CGI scripts. ENDPOINTS & SYSTEMS

Permutation — Rearranging the positions of characters or bits rather than replacing them. One of the two classical building blocks of ciphers, with substitution. CRYPTOGRAPHY

Persistence — Making access survive reboots, password resets, and cleanup — scheduled tasks, services, registry keys, rogue OAuth grants, extra SSH keys. ATTACKS & EXPLOITATION

Persistent engagement *Defend forward* — The doctrine that contesting adversaries continuously in their own networks is more effective than waiting to be attacked. Adopted by US Cyber Command, and disputed for its escalation risk. *Also called defend forward, continuous engagement.* INTELLIGENCE & INVESTIGATIONS

Personal data / PII *Personally Identifiable Information* — Data relating to an identifiable person. GDPR's definition is deliberately broad and includes IP addresses and device identifiers. *Also called PII, personal information, personal identifiers.* GOVERNANCE, RISK & COMPLIANCE

Personal firewall — A firewall running on an individual machine rather than at the network boundary. The last control still standing once an attacker is already inside. DEFENSE & OPERATIONS

Personal information *PI* — The broader legal category used in privacy law — anything relating to an identified or identifiable person, including data that never names them: IP addresses, cookie and advertising identifiers, location traces, browsing history, inferences drawn about them. Wider than PII by design. *Also called PI, personal data, consumer data.* CLASSIFICATION & PERSONAL DATA

Personally identifiable information *PII* — Information that identifies a specific person, alone or combined with other data. Direct identifiers: name, Social Security number, passport or driving licence number, email address, phone number, home address, account numbers, biometric templates, face photograph, device or vehicle identifiers. Indirect ones become identifying in combination — date of birth with postcode with gender is famously enough to single out most people. *Also called PII, personal data, identifying information, personal identifiers.* CLASSIFICATION & PERSONAL DATA

PGP *Pretty Good Privacy* — Long-standing software for encrypting and signing mail and files with public keys. Powerful, awkward, and still the standard in some communities. CRYPTOGRAPHY

Pharming — Redirecting users to a fake site by corrupting name resolution, so the address they typed is correct and the destination is not. ATTACKS & EXPLOITATION

Phishing — A fraudulent message designed to make someone hand over credentials or run something. Still the most common way intrusions begin. *Also called email scam, credential phishing, fake email.* ATTACKS & EXPLOITATION

Phishing-resistant MFA — Factors bound to the real domain so they cannot be relayed to a fake one — hardware security keys and passkeys. Codes and push prompts are not phishing-resistant. IDENTITY & ACCESS

Pickle deserialisation *Pickle exploit* — Python's pickle format stores instructions for rebuilding an object, and rebuilding can call arbitrary code. Loading a pickled model from someone else is running their program, which is why the format is the central security problem in machine learning distribution. *Also called pickle attack, unsafe deserialisation, torch.load risk.* AI & EMERGING TECH

Pig butchering *Sha zhu pan, romance investment fraud* — A long-running fraud that builds a relationship over weeks before introducing a fake investment platform, letting a small withdrawal succeed, then taking everything. Industrial in scale, and often run by trafficked workers held in compounds. *Also called romance scam, investment scam, crypto romance fraud.* ATTACKS & EXPLOITATION

Ping of death — An old attack that sent an oversized ping packet to crash the receiving machine's input buffers. Long fixed, but the template — malformed input crashes a parser — never went away. NETWORKING & PROTOCOLS

Ping scan — A check for which machines answer ICMP echo requests. The cheapest form of host discovery, and the easiest to spot in logs. NETWORKING & PROTOCOLS

Ping sweep — Pinging a whole range of addresses to find out which hosts exist. Usually the first step of mapping a network before probing it. NETWORKING & PROTOCOLS

Pipeline *Workflow, GitHub Actions* — The scripted sequence that runs on a push — install, lint, test, build, scan, deploy. It holds real credentials, which makes it a genuine attack surface. DEV & DELIVERY

Pivoting — Using a machine you have already compromised as the launch point for reaching further into a network. The second host is attacked from inside, where the firewall is not looking. *Also called pivot, jumping through a host, internal relay.* ATTACKS & EXPLOITATION

PKI *Public Key Infrastructure* — The whole apparatus of issuing, distributing, renewing, and revoking certificates and keys. Most PKI incidents are expiries and misissuance, not cryptographic breaks. *Also called public key infrastructure, certificate infrastructure.* CRYPTOGRAPHY

Plaintext / ciphertext — Plaintext is the readable data; ciphertext is what it looks like after encryption. Encryption turns one into the other, decryption turns it back. CRYPTOGRAPHY

Playbook / runbook — Written steps for a specific scenario. Their real value is that they work at three in the morning when nobody is thinking clearly. DEFENSE & OPERATIONS

PLC *Programmable Logic Controller* — The small industrial computer that actually runs a physical process — a turbine, a pump, a valve. Putting one into STOP mode stops the equipment, which is why they are the endpoint of a destructive OT attack. *Also called industrial controller, programmable controller.* ENDPOINTS & SYSTEMS

Pod — Kubernetes' smallest deployable unit — one or more containers sharing a network identity and storage. CLOUD & INFRASTRUCTURE

Poison reverse — A stronger form of split horizon: the route is advertised back, but marked as unreachable. The unreachable claim is what kills the loop. NETWORKING & PROTOCOLS

Policy / standard / procedure — Policy states intent, standards set specific requirements, procedures give the steps. Collapsing them into one document is why nobody follows any of them. GOVERNANCE, RISK & COMPLIANCE

Polyinstantiation — Letting a database hold several records with the same key at different classification levels, so users at a lower level cannot infer that a higher-level record exists. GOVERNANCE, RISK & COMPLIANCE

Polymorphic malware — Malware that rewrites its own code each time it spreads, so no two copies look alike to a scanner. MALWARE & THREAT ACTORS

Polymorphism — Malware that rewrites its own code as it spreads, so no two copies look alike to a signature scanner. MALWARE & THREAT ACTORS

POP3 *Post Office Protocol* — A mail protocol where the client downloads messages from the server, traditionally removing them. Largely displaced by IMAP. NETWORKING & PROTOCOLS

Port — A numbered door on a host. The IP gets you to the machine; the port gets you to the specific service — 22 for SSH, 443 for HTTPS. NETWORKING & PROTOCOLS

Port scan — Knocking on each port of a host in turn to see which services answer. The responses tell an attacker where to look for weaknesses. *Also called scanning ports, nmap scan, service discovery.* NETWORKING & PROTOCOLS

Port stealing — Forging frames to convince a switch that a victim's MAC address is on your port, so their traffic is delivered to you. ARP spoofing's quieter relative. NETWORKING & PROTOCOLS

Possession — Holding and controlling information, whether or not you can read it. A stolen encrypted laptop is a loss of possession even if confidentiality holds. GOVERNANCE, RISK & COMPLIANCE

Post-incident review *Lessons learned, blameless postmortem* — Examining what happened and why, without hunting individuals. Blame guarantees the next incident is reported late or not at all. DEFENSE & OPERATIONS

Post-quantum cryptography *PQC* — Algorithms designed to survive quantum computers, now standardised as ML-KEM and ML-DSA. Being adopted early because encrypted traffic stolen today could be decrypted later. CRYPTOGRAPHY

PowerShell — Windows' scripting and administration shell. Enormously useful to admins and attackers alike, which is why script block logging matters. ENDPOINTS & SYSTEMS

PPP *Point-to-Point Protocol* — A protocol for carrying IP over a direct link between two machines, historically a dial-up line. NETWORKING & PROTOCOLS

PPTP *Point-to-Point Tunneling Protocol* — An early VPN protocol, now considered broken. Its presence in a configuration is a finding, not a feature. NETWORKING & PROTOCOLS

Preamble — The pattern of bits at the start of a transmission that lets receivers lock on to the timing. Below the level most people ever look at, and essential. NETWORKING & PROTOCOLS

Precision *FP32 / FP16 / BF16 / INT8* — How many bits represent each number. Lower precision means less memory and more speed, at some cost in accuracy — the central trade in running models cheaply. COMPUTE & HARDWARE

Preparedness framework *Responsible scaling policy* — A lab's published commitments about which capability thresholds trigger which safeguards, and who must sign off before a model goes further. Self-imposed, self-assessed, and currently the main governance instrument in the field. *Also called RSP, safety framework, capability thresholds.* GOVERNANCE, RISK & COMPLIANCE

Preservation request — An order telling a provider to freeze an account's data while legal process is prepared. Without it, logs age out before the warrant arrives. INTELLIGENCE & INVESTIGATIONS

Pretexting — Inventing a plausible scenario and identity to justify an unusual request. The setup that makes the eventual ask feel routine. ATTACKS & EXPLOITATION

Privacy by design — Building privacy protections into a system from the start, with privacy-protective defaults. A GDPR obligation, not a philosophy. GOVERNANCE, RISK & COMPLIANCE

Privacy versus security — The recurring argument that protecting people requires watching them — data retention, lawful access, monitoring at work, encryption backdoors. Usually framed as a trade-off, and usually more honestly described as a choice about who is trusted with what, since measures that weaken protection for one party weaken it for everyone. *Also called security vs privacy, lawful access debate.* CLASSIFICATION & PERSONAL DATA

Private addressing *RFC 1918* — The address ranges reserved for internal networks — 10/8, 172.16/12 and 192.168/16 — which routers on the public internet will not carry. NETWORKING & PROTOCOLS

Private APN *Access Point Name* — A carrier-provided mobile network reserved for one organisation's devices, widely used to reach remote sites like substations and wind farms. It feels private and is not a security boundary: if devices on it can talk to each other, one compromised unit reaches the rest. *Also called APN, private mobile network, dedicated APN.* NETWORKING & PROTOCOLS

Privilege escalation — Gaining rights beyond those granted. Vertical means user to admin; horizontal means reaching another user's data at the same level. *Also called privesc, elevation of privilege, getting root, getting admin.* IDENTITY & ACCESS

Privilege separation — Running each component with only the rights it needs, so a compromise in one part does not hand over the whole system. ENDPOINTS & SYSTEMS

Privileged access management *PAM (practice)* — Controlling and recording the use of powerful accounts and internal tools — who may elevate, for how long, with whose approval, and with what session recording. It is what stands between a support panel and a takeover of the accounts it can reach. *Also called privileged account management, admin access control.* IDENTITY & ACCESS

Process injection — Running malicious code inside another, trusted process so it inherits that process's identity and looks normal. ENDPOINTS & SYSTEMS

Production *Prod* — The live system real people depend on. Every rule about review, backups and change control exists because of what happens here. DEV & DELIVERY

Program infector — Malware that attaches itself to existing executables, so running an ordinary program runs it too. MALWARE & THREAT ACTORS

Program policy — The high-level policy that sets the organisation's overall security posture and tone. GOVERNANCE, RISK & COMPLIANCE

Promiscuous mode — A network interface configured to accept every packet it sees, not just its own. Necessary for packet capture, and a hallmark of a sniffer. NETWORKING & PROTOCOLS

Prompt — The instruction and context given to a model. In most current systems it is also, unhelpfully, the security boundary. AI & EMERGING TECH

Prompt injection — Hostile instructions hidden in content a model reads, hijacking its behaviour. The defining security problem of LLM applications. *Also called jailbreak by prompt, instruction injection.* AI & EMERGING TECH

Proof of concept *PoC* — Minimal code demonstrating that a vulnerability is genuinely exploitable. Public PoC release usually marks the start of mass scanning. ATTACKS & EXPLOITATION

Proportional response — The principle that retaliation should match the force used against you. Applied to cyber operations it is genuinely unsettled: what a proportional answer to a destructive intrusion looks like is still argued over. INTELLIGENCE & INVESTIGATIONS

Proprietary information — Information unique to a company and central to its ability to compete — customer lists, costs, designs, trade secrets. GOVERNANCE, RISK & COMPLIANCE

Protected health information *PHI* — Health information tied to an identifiable person and handled by a covered organisation — diagnoses, treatment records, prescriptions, test results, insurance and billing detail, appointment records, provider notes. Under HIPAA it is the identifiers plus the health context that make it PHI. *Also called PHI, medical records, health data, patient data.* CLASSIFICATION & PERSONAL DATA

Protocol — An agreed set of rules for how two endpoints communicate. Protocols exist at every layer of a connection. NETWORKING & PROTOCOLS

Protocol stack — The set of protocol layers that work together to move data, each handing off to the one below. NETWORKING & PROTOCOLS

Prototype pollution — Writing to a JavaScript object's prototype so every object in the program inherits attacker-controlled properties. Effects appear far from the injection point. APPLICATION SECURITY

Proxy — A middleman that makes requests on your behalf. A forward proxy fronts clients, a reverse proxy fronts servers, and both are natural places to inspect or filter traffic. *Also called intermediary server, relay, gateway proxy.* NETWORKING & PROTOCOLS

Proxy (investigative view) — An intermediate server that stands between the user and the destination, so the destination sees the proxy's address. It moves the question of identity one hop back. INTELLIGENCE & INVESTIGATIONS

Proxy chain *Chained proxies* — Stringing several proxies together so each one only knows its neighbours. Cheap to set up, and only as private as the least trustworthy link, which keeps logs. *Also called chained proxies, proxy hopping, multi-hop proxy.* NETWORKING & PROTOCOLS

Proxy server — A server that sits between users and the internet, fetching things on their behalf. It can filter, cache, log — and it hides the real client from the far end. NETWORKING & PROTOCOLS

Public (classification) — Information intended for anyone — published material, marketing, public filings. The only class that needs no protection against disclosure, though it still needs integrity. CLASSIFICATION & PERSONAL DATA

Public / private / hybrid cloud — Shared provider infrastructure, dedicated infrastructure, or a mix. Hybrid is the common reality, and the seams between the two are where control gaps live. CLOUD & INFRASTRUCTURE

Public key — The half of a key pair you can publish. Others encrypt to it or verify signatures with it; only the private half can reverse that. CRYPTOGRAPHY

Public key encryption *Asymmetric cryptography* — Encryption with a key pair, where what one key does only the other can undo. It solves key distribution at the cost of speed. *Also called asymmetric cryptography, asymmetric encryption, PKC.* CRYPTOGRAPHY

Public vs private sector response — Government investigates to enforce law and protect the state; a company investigates to stop the bleeding, meet its obligations and protect its business. The same incident produces two different investigations with different definitions of success. INTELLIGENCE & INVESTIGATIONS

Public-key forward secrecy *PFS* — The property that recording today's traffic gains nothing if a long-term private key leaks later, because session keys are derived fresh. CRYPTOGRAPHY

PUE *Power Usage Effectiveness* — Total facility power divided by the power actually reaching the computers. A PUE of 1.1 is efficient; anything near 2 means half the energy is going on cooling and losses. COMPUTE & HARDWARE

Pull — Fetching changes from the remote and merging them into your branch. Pull before you start work, or you will be resolving conflicts later. DEV & DELIVERY

Pull request *PR / merge request / MR* — A proposal to merge one branch into another, with a place to discuss and review it first. Where code review, CI checks and approvals happen. DEV & DELIVERY

Purple teaming — Red and blue working together, running known techniques to check whether detection actually fires. Improvement rather than scorekeeping. *Also called collaborative red-blue, joint exercise.* DEFENSE & OPERATIONS

Purpose limitation — Data collected for one stated purpose may not be quietly reused for another. The principle most often broken by analytics and AI training. GOVERNANCE, RISK & COMPLIANCE

Push — Sending your local commits up to the remote repository so others — and any deployment pipeline — can see them. Nothing you have not pushed exists to anyone else. DEV & DELIVERY

Push bombing *MFA bombing* — Firing approval prompts at a victim's phone until one is accepted out of exhaustion or confusion. Number matching exists to break it. *Also called MFA fatigue attack, prompt bombing.* IDENTITY & ACCESS

Pyramid of Pain — A model ranking indicators by how much it costs an attacker when you block them. Hashes are trivial to change; behaviours are not. MALWARE & THREAT ACTORS

Q

QAZ *QAZ network worm* — A network worm from around 2000, notable mainly as an early case of a backdoor spreading through file shares. MALWARE & THREAT ACTORS

Quantisation — Converting model weights to lower precision so they fit in less memory and run faster. It is how large models end up running on a laptop or a phone. COMPUTE & HARDWARE

Quantum computing — Computation using quantum states, able in principle to break RSA and elliptic-curve cryptography. The reason post-quantum migration is starting now. AI & EMERGING TECH

Quid pro quo attack — Offering something in exchange for access or information — a free scan, a prize, an IT fix. The victim believes they are receiving a service, not giving one. ATTACKS & EXPLOITATION

Quishing *QR phishing* — Phishing with a QR code in place of a link, printed on a poster or pasted into an email. The destination is unreadable to the victim and invisible to most mail filters, which scan text, not images. *Also called QR code phishing, malicious QR code.* ATTACKS & EXPLOITATION

R

Race condition *TOCTOU* — A bug where the outcome depends on timing between a check and its use. Exploited by firing simultaneous requests — a common cause of duplicate refunds and coupon abuse. *Also called TOCTOU, time of check time of use, timing bug.* APPLICATION SECURITY

Radiation monitoring — Capturing images, data or audio by listening to the radiation an unshielded device emits. CRYPTOGRAPHY

RAG *Retrieval-Augmented Generation* — Fetching relevant documents and giving them to a model as context. It grounds answers — and makes every retrievable document an injection surface. *Also called retrieval augmented generation, grounding, document retrieval.* AI & EMERGING TECH

Rainbow table — A precomputed lookup from hashes back to passwords. Defeated entirely by per-user salting, which is why unsalted hashes are treated as plaintext. *Also called precomputed hash table.* CRYPTOGRAPHY

RAM *Random Access Memory* — Fast working memory holding what a program is actively using. Volatile — it empties on power loss, which is why memory forensics is time-critical. COMPUTE & HARDWARE

Ransomware — Malware that encrypts data and demands payment for the key. Modern operations steal the data first, so paying does not undo the breach. *Also called crypto locker, extortion malware, encryption extortion.* MALWARE & THREAT ACTORS

Ransomware-as-a-service *RaaS* — A criminal business model where developers rent their malware and infrastructure to affiliates for a cut. It industrialised ransomware. MALWARE & THREAT ACTORS

RAT *Remote Access Trojan* — Malware giving an attacker interactive control of a machine — files, screen, camera, shell — as if sitting at it. MALWARE & THREAT ACTORS

Rate limit *Quota* — How many API calls you are allowed in a window. Read it before writing the loop, cache the responses, and handle the 429 rather than retrying blindly. DEV & DELIVERY

Rate limiting — Capping how many requests a client can make in a window. The simplest defence against brute force, scraping, and abuse. CLOUD & INFRASTRUCTURE

RBAC *Role-Based Access Control* — Permissions attached to roles, and roles attached to people. Simple and auditable, until the roles multiply and everyone ends up in several. IDENTITY & ACCESS

RDP *Remote Desktop Protocol* — Windows remote graphical access. Exposed to the internet, it is one of the most-attacked services in existence. ENDPOINTS & SYSTEMS

Re-identification — Reconnecting supposedly anonymous records to people, usually by combining datasets. The reason true anonymisation is much harder than it sounds. GOVERNANCE, RISK & COMPLIANCE

Rebase — Replaying your commits on top of an updated branch to give a straight history instead of a merge. Never rebase a branch other people have already pulled. DEV & DELIVERY

Reconnaissance *Recon* — The stage of an attack spent finding systems, mapping networks and looking for a way in — before anything is exploited. *Also called recon, footprinting, information gathering.* NETWORKING & PROTOCOLS

Recovery — Bringing systems back into service safely and confirming the environment is clean. Restoring too early reinfects everything. DEFENSE & OPERATIONS

Red team / blue team — Red attacks to test defences, blue defends and detects. Purple team is the practice of running both together so findings actually improve detection. *Also called offensive team, defensive team, adversary simulation.* MALWARE & THREAT ACTORS

Reduced refusals *Safeguards-off evaluation* — Running a model with its safety behaviour deliberately turned down, so a capability can be measured rather than declined. Legitimate and necessary, and it means the containment around the test is doing all the work that the model's own restraint normally would. *Also called classifiers disabled, unsafeguarded evaluation.* AI & EMERGING TECH

Refactor — Restructuring code without changing what it does. If behaviour changed, it was not a refactor, and it needs reviewing as a real change. DEV & DELIVERY

Reflection attack — Sending requests with the victim's address forged as the source, so the responses land on them. Pair it with a protocol that answers larger than it is asked and it becomes amplification. *Also called reflected DDoS, spoofed source attack.* ATTACKS & EXPLOITATION

Reflexive ACL *Cisco* — A router filter that only allows return traffic belonging to connections started from inside. A step toward stateful firewalling. NETWORKING & PROTOCOLS

Region / availability zone — A geographic location and an isolated datacentre within it. Regions matter for data residency law; zones matter for surviving hardware failure. CLOUD & INFRASTRUCTURE

Registry *Windows Registry* — Windows' central configuration database. A common place for malware to persist, since certain keys run automatically at boot or login. ENDPOINTS & SYSTEMS

Registry (Windows) — The central store of Windows settings and configuration. Persistence, configuration and evidence all live here. ENDPOINTS & SYSTEMS

Regression — Something that used to work and now does not. Regression tests exist so the same bug cannot come back twice unnoticed. DEV & DELIVERY

Regression testing — Running a fixed set of tests before each release to check that what worked still works. Fuzzing is its adversarial cousin. APPLICATION SECURITY

Release — A tagged, packaged version handed to users, usually with notes and built artifacts attached. DEV & DELIVERY

Remote *origin, upstream* — A named repository your local copy talks to. `origin` is normally your own copy; `upstream` is the original you forked from. DEV & DELIVERY

Remote access software abuse — Using ordinary remote administration tools — the ones IT already trusts — to work from somewhere the employer would not permit, or to hand access to someone else. There is no malware to find. *Also called RMM abuse, legitimate tool abuse.* ATTACKS & EXPLOITATION

Remote file inclusion *RFI* — Making an application fetch and execute code from a remote address the attacker controls. Rarer than it was, and fatal where it survives. APPLICATION SECURITY

Remote work risk *Distributed workforce risk* — The security consequences of a workforce outside the building: unmanaged networks, shared homes, devices that never touch a corporate LAN, and identity as the only real perimeter left. DEFENSE & OPERATIONS

Remote work scam — Fraud built on remote employment — fake workers, bought identities, remote access software installed on company machines. The employment process becomes the intrusion vector. INTELLIGENCE & INVESTIGATIONS

Remote worker fraud *Fraudulent employment* — Getting hired into a real job under a false or borrowed identity, for the salary, the access, or both. The hiring process becomes the intrusion, and none of it trips a security control because every step is a legitimate business action. *Also called fake employee, employment fraud, fraudulent hire.* INTELLIGENCE & INVESTIGATIONS

Replay attack — Capturing a valid message and sending it again to repeat its effect — a payment, a login, an unlock. Nonces, timestamps and sequence numbers exist to stop it. *Also called message replay, credential replay.* CRYPTOGRAPHY

Repo-jacking — Taking over a code repository namespace freed by a rename or deletion, so builds that still reference the old path fetch the attacker's code instead. ATTACKS & EXPLOITATION

Repository *Repo* — The project folder plus its entire history of changes. Everything else in version control is an operation on a repository. DEV & DELIVERY

Reset — Moving your branch pointer backwards, optionally throwing away work. Powerful locally, destructive if you force-push the result. DEV & DELIVERY

Resource exhaustion — Tying up something finite — memory, connections, file handles, disk — until there is none left for legitimate use. NETWORKING & PROTOCOLS

Responsible disclosure *Coordinated disclosure* — Reporting a flaw privately and agreeing a window before publication, so a fix exists before the details do. *Also called coordinated disclosure, CVD, ethical disclosure.* APPLICATION SECURITY

REST / GraphQL — Two API styles: REST exposes resources at URLs and you take what each returns; GraphQL exposes one endpoint and you ask for exactly the fields you want. DEV & DELIVERY

Restricted (classification) *Highly confidential* — The most sensitive commercial class: credentials, encryption keys, merger plans, source code, regulated personal data. Small named access lists and logged access. *Also called highly confidential, most sensitive, tier one data.* CLASSIFICATION & PERSONAL DATA

Retention schedule — How long each category of data is kept before deletion. Data you deleted on schedule cannot be breached or subpoenaed. GOVERNANCE, RISK & COMPLIANCE

Reverse engineering — Working out how a system or component functions by taking it apart. Used to find vulnerabilities, to analyse malware, and to steal designs. ATTACKS & EXPLOITATION

Reverse lookup *Reverse DNS, PTR lookup* — Running a lookup backwards: you have the IP address and you want the name behind it, rather than the other way round. It is a standard first move in an investigation — take the address out of a log and ask who it belongs to — and the answer is often stale, generic or missing entirely, because nobody is obliged to publish one. *Also called reverse DNS, rDNS, PTR record, IP to name, searching backwards, who owns this IP.* NETWORKING & PROTOCOLS

Reverse proxy — A server that sits in front of your applications, terminating TLS and passing requests inward. Where load balancing, caching, and web application firewalls usually live. *Also called front-end proxy, ingress proxy.* NETWORKING & PROTOCOLS

Revert — Creating a new commit that undoes an earlier one, leaving the history intact. The safe way to back out a change that is already public. DEV & DELIVERY

Reward hacking — Getting the score without doing the task — the system optimises the measure rather than the thing the measure stood for. Models under evaluation have stolen the answer key rather than solve the problem, which is reward hacking with a network in reach. *Also called reward gaming, metric gaming, cheating the evaluation.* AI & EMERGING TECH

RFC *Request for Comments* — The numbered document series in which internet protocols are proposed and defined. Anyone can submit one; the IETF decides what becomes a standard. NETWORKING & PROTOCOLS

Right to repair — Being able to fix and upgrade hardware you own — parts, tools and documentation. Directly affects how long a device stays secure and usable. COMPUTE & HARDWARE

Right-to-work check — Verifying that a person may lawfully be employed where they claim to be. A legal duty in most countries, and in practice one of the stronger controls against fraudulent remote hires. DEFENSE & OPERATIONS

RIP *Routing Information Protocol* — An old distance-vector protocol that judges routes by hop count alone. Easy to configure and easy to fool. NETWORKING & PROTOCOLS

Risk appetite / tolerance — How much risk leadership is willing to accept. Without it stated, every risk decision becomes an argument. GOVERNANCE, RISK & COMPLIANCE

Risk assessment — Identifying what could go wrong and how much it would cost you. The input to every decision about what to spend. *Also called risk analysis, risk evaluation.* GOVERNANCE, RISK & COMPLIANCE

Risk averse — Avoiding risk even at the price of the opportunity. A defensible position, and an expensive one when it becomes the default answer. GOVERNANCE, RISK & COMPLIANCE

Risk register — The recorded list of known risks with owners, ratings, and treatment. Useful when actively reviewed, decorative when not. GOVERNANCE, RISK & COMPLIANCE

Risk treatment *Accept, mitigate, transfer, avoid* — The four things you can do about a risk. Accepting is legitimate — provided someone with authority signs it. GOVERNANCE, RISK & COMPLIANCE

Rogue DHCP server — An unauthorised DHCP server handing out addresses with itself as the gateway or DNS. Whoever answers first owns the client's traffic. NETWORKING & PROTOCOLS

Role-based access control *RBAC (concept)* — Access granted through roles that match job functions, rather than to individuals one at a time. IDENTITY & ACCESS

Rollback — Returning to the previous working version after a bad deploy. Knowing you can roll back in one step is what makes frequent deploys reasonable. DEV & DELIVERY

Root — The all-powerful administrative account on Unix systems. Gaining it is usually the attacker's objective, not their entry point. IDENTITY & ACCESS

Rootkit — Malware that hides itself deep in the operating system or below it, altering what the system reports about itself. Often only detectable from outside the host. *Also called kernel implant, stealth toolkit.* MALWARE & THREAT ACTORS

Router — A device that forwards traffic between networks based on IP addresses. It decides where a packet goes next, hop by hop. NETWORKING & PROTOCOLS

Routing loop — Two or more misconfigured routers passing the same packet back and forth. TTL is what eventually ends it. NETWORKING & PROTOCOLS

Rowhammer — Repeatedly accessing memory rows to flip bits in neighbouring ones through electrical interference. A software attack on a physical property of RAM. COMPUTE & HARDWARE

Royal Canadian Mounted Police *RCMP* — Canada's national police force, and its point of contact for cross-border cybercrime investigations. INTELLIGENCE & INVESTIGATIONS

RPC scan — A probe for which remote procedure call services a machine is running. Often the route to an unpatched service nobody knew was exposed. NETWORKING & PROTOCOLS

RSA *Rivest–Shamir–Adleman* — The classic public-key algorithm, based on the difficulty of factoring large numbers. Still common, but large and slow next to elliptic curve, and a prime target for quantum attacks. CRYPTOGRAPHY

RTO / RPO *Recovery Time / Point Objective* — How fast you must be back, and how much data you can afford to lose. Two numbers that decide the entire backup architecture. CLOUD & INFRASTRUCTURE

Rule set based access control *RSBAC* — Access decided by rules about what entities may do to objects, rather than by lists attached to either. IDENTITY & ACCESS

Runbook automation — Turning repeated manual response steps into scripts or workflows. Consistency under pressure, and a free audit trail. DEFENSE & OPERATIONS

S

S/Key — An early one-time password scheme that generates a chain of passwords by repeated hashing. The ancestor of modern OTP. CRYPTOGRAPHY

S7 protocol *Siemens S7comm* — The protocol Siemens controllers speak. Like most industrial protocols it was designed for a trusted network and authenticates weakly or not at all, so reaching it is usually equivalent to controlling it. *Also called S7comm, Siemens protocol.* NETWORKING & PROTOCOLS

Sabotage — Damaging or disabling something on purpose, as opposed to stealing from it. In cyber terms it is the category Stuxnet and the Ukraine grid attacks belong to: the objective is that the thing stops working, not that anything is taken. *Also called destructive attack, physical disruption.* ATTACKS & EXPLOITATION

Safetensors — A model file format that stores only tensor data, with no ability to execute anything on load. It exists specifically to end the pickle problem, and converting to it is the single most effective control on a model registry. *Also called safe model format, tensor-only format.* AI & EMERGING TECH

Safety — That the people involved with an organisation — staff, customers, visitors — come to no harm. In OT and medical systems it outranks every other property. GOVERNANCE, RISK & COMPLIANCE

Salt — Random data added to a password before hashing, unique per user. It stops one precomputed table cracking every account at once. *Also called per-password random value, hash salt.* CRYPTOGRAPHY

Same-origin policy *SOP* — The browser rule that keeps one site's scripts from reading another site's data. The foundation everything else in web security sits on. APPLICATION SECURITY

SAML *Security Assertion Markup Language* — The older XML-based standard for federated SSO, still standard in enterprise software. Its signature handling has a long history of bypass bugs. IDENTITY & ACCESS

Sandbox — An isolated environment where untrusted code can run without touching anything that matters — a browser tab, a malware analysis VM, or the boundary an AI agent is meant to stay inside. Only as strong as the boundary itself: escapes are the whole game. *Also called isolated environment, detonation chamber, jail, containment environment.* MALWARE & THREAT ACTORS

Sandbox escape — Breaking out of the isolation a sandbox is supposed to enforce, so code reaches the host, the network, or credentials it was never meant to see. *Also called sandbox breakout, container escape (analogous), jailbreak (isolation).* MALWARE & THREAT ACTORS

Sandbox evasion — Malware checking whether it is being watched — virtual machine artefacts, no mouse movement, too little uptime — and staying dormant if so. MALWARE & THREAT ACTORS

Sandworm — The Russian military intelligence unit behind BlackEnergy, Industroyer, NotPetya and the attacks that cut power in Ukraine. The name comes from Andy Greenberg's book about it — the standard case study in cyber as an instrument of war. *Also called Unit 74455, Voodoo Bear, Iridium, Telebots, GRU cyber unit.* MALWARE & THREAT ACTORS

SAST *Static Application Security Testing* — Scanning source code for vulnerable patterns without running it. Broad coverage, high false-positive rate. APPLICATION SECURITY

SBOM *Software Bill of Materials* — A machine-readable inventory of components in a piece of software. Turns a new vulnerability disclosure into a lookup rather than a scramble. *Also called software bill of materials, dependency inventory.* GOVERNANCE, RISK & COMPLIANCE

SCA *Software Composition Analysis* — Inventorying third-party dependencies and flagging known-vulnerable versions. Most of a modern codebase is not written in-house. APPLICATION SECURITY

SCADA *Supervisory Control and Data Acquisition* — The monitoring and control layer above industrial equipment. Historically built for isolated networks and now, unhelpfully, often reachable. ENDPOINTS & SYSTEMS

Scareware — Fake alerts claiming infection to push a purchase or a phone call. The on-ramp to tech-support fraud. MALWARE & THREAT ACTORS

Scavenging — Searching through leftover data — deleted files, swap space, freed memory — for something sensitive that was never really erased. ATTACKS & EXPLOITATION

Scheduled task / cron — Built-in job schedulers. Legitimate everywhere, and among the first things to check for attacker persistence. ENDPOINTS & SYSTEMS

SCIM *System for Cross-domain Identity Management* — The standard for pushing user creation, updates, and deprovisioning from an identity provider into applications automatically. IDENTITY & ACCESS

Scope of investigation — What an inquiry is permitted to examine, and over what period. It determines the findings as much as the evidence does: the ExploitGym assessment covered a window ending 13 July, and the compromise continued past it. *Also called investigative scope, terms of reference.* INTELLIGENCE & INVESTIGATIONS

Scotland Yard *Metropolitan Police* — The headquarters of London's police force, and by extension shorthand for British policing. A local force, not a national one — a common source of confusion in cross-border cases. INTELLIGENCE & INVESTIGATIONS

Script kiddie — Someone using others' tools without understanding them. Still capable of real damage against anything left unpatched. *Also called skid, unskilled attacker.* MALWARE & THREAT ACTORS

SDK / CLI *Software Development Kit / Command Line Interface* — A library that wraps an API in your language, and a terminal tool that wraps it for humans and scripts. Usually easier and safer than hand-rolling HTTP calls. DEV & DELIVERY

Search warrant — A judicial authorisation to search and seize, granted on probable cause. It is what reaches content: the messages themselves, the files, the contents of an account. *Also called warrant, judicial authorisation, probable cause order.* INTELLIGENCE & INVESTIGATIONS

Secret — The US classification for information whose disclosure would cause serious damage to national security. CLASSIFICATION & PERSONAL DATA

Secrets management — Keeping credentials out of code and configuration and in a vault with rotation and audit. Hard-coded secrets in repositories remain a top breach cause. APPLICATION SECURITY

Secure Boot — Firmware refusing to load unsigned boot code, blocking bootkits before the operating system starts. ENDPOINTS & SYSTEMS

Secure cookie flags *HttpOnly, Secure, SameSite* — HttpOnly hides a cookie from JavaScript, Secure restricts it to HTTPS, and SameSite limits cross-site sending. Three flags, most cookie attacks covered. APPLICATION SECURITY

Secure SDLC — Building security into every stage of development rather than testing at the end. Threat modelling, review, testing, and monitoring as normal practice. APPLICATION SECURITY

Security awareness training — Teaching staff to recognise and report attacks. Effective when it is short, frequent, and safe to report to; useless as an annual slideshow. *Also called user training, phishing training, staff education.* GOVERNANCE, RISK & COMPLIANCE

Security clearance — A vetting decision that a person may be trusted with classified information up to a level. Clearance alone is not enough: access also requires need to know. *Also called clearance, vetting, cleared personnel.* CLASSIFICATION & PERSONAL DATA

Security group *Network ACL* — Cloud firewall rules attached to resources or subnets. An accidentally open management port here is a recurring breach origin. CLOUD & INFRASTRUCTURE

Security key *Hardware token, YubiKey* — A physical device that holds authentication keys and requires a touch to use. The strongest widely-available second factor. IDENTITY & ACCESS

Security log — The record of security-relevant activity on a system — logons, privilege use, policy changes. The first thing an investigator asks for and the first thing an attacker edits. DEFENSE & OPERATIONS

Security policy — The rules that say how an organisation protects its systems and information. Everything else — standards, procedures, controls — hangs off it. GOVERNANCE, RISK & COMPLIANCE

Segment — A TCP packet. Also, confusingly, a physical or logical slice of a network. NETWORKING & PROTOCOLS

Segregation of duties *SoD* — Splitting a sensitive process so no one person can complete it alone. The standard control against both fraud and single-point mistakes. *Also called separation of duties, SoD, four eyes principle.* GOVERNANCE, RISK & COMPLIANCE

Semantic versioning *SemVer* — MAJOR.MINOR.PATCH, where major means a breaking change, minor adds features, patch fixes bugs. It tells you how nervous to be about upgrading. DEV & DELIVERY

Sensitive information *Sensitive but unclassified* — Information that is not secret in the formal sense but would cause harm if it got out — the working middle of every classification scheme, and where most data actually sits. The word means two different things depending on who says it, and the difference is not how it is labelled but what the harm is: commercial sensitive information costs money and position, controlled government information costs people and is often not recoverable at all. *Also called sensitive but unclassified, SBU, controlled information, business sensitive.* CLASSIFICATION & PERSONAL DATA

Sensitive PII — The subset of personal data whose exposure causes immediate, serious harm: Social Security and national ID numbers, financial account and card numbers, passport and driving licence numbers, biometrics, and credentials. Usually the trigger for breach notification and for encryption requirements. *Also called SPII, high-risk personal data.* CLASSIFICATION & PERSONAL DATA

Separation of duties — Splitting a sensitive task so no one person can complete it alone. It turns fraud from a decision into a conspiracy. *Also called segregation of duties, SoD, dual control.* GOVERNANCE, RISK & COMPLIANCE

Server — The system that answers requests from clients. The word covers the software, the machine, or both, depending on who is talking. NETWORKING & PROTOCOLS

Server-side template injection *SSTI* — Getting user input evaluated by a server-side template engine, which usually leads directly to code execution. Templates are code, not text. APPLICATION SECURITY

Serverless *FaaS, Lambda* — Running functions without managing servers. No host to patch, but function permissions and event sources become the security surface. CLOUD & INFRASTRUCTURE

Service account *Machine identity* — A non-human account used by an application or script. Typically over-permissioned, rarely rotated, never MFA-protected — a standing favourite for attackers. IDENTITY & ACCESS

Service mesh *Istio, Linkerd* — A layer that handles service-to-service traffic, giving mutual TLS, policy, and telemetry without changing application code. CLOUD & INFRASTRUCTURE

Session — A connection between two hosts that lasts long enough to carry a conversation. Stealing one is cheaper for an attacker than stealing a password. NETWORKING & PROTOCOLS

Session fixation — Setting a victim's session identifier to a value you already know, then waiting for them to log in with it. The fix is to issue a new identifier at every privilege change. IDENTITY & ACCESS

Session hijacking — Stealing a valid session cookie or token to become an already-authenticated user, skipping login and MFA entirely. Infostealer malware's main product. IDENTITY & ACCESS

Session key — A symmetric key used for a single connection or a short period, then discarded. Limits how much traffic one compromised key exposes. CRYPTOGRAPHY

Sextortion — Demanding money under threat of publishing intimate images, real or claimed. The mass-mailed version has nothing at all and relies entirely on the recipient's fear. *Also called webcam blackmail, extortion email.* ATTACKS & EXPLOITATION

SHA-1 *Secure Hash Algorithm 1* — A superseded hash function with demonstrated collisions. Anything still relying on it for signatures is a finding. CRYPTOGRAPHY

SHA-256 *Secure Hash Algorithm 256* — The workhorse hash for integrity checks, signatures, and blockchains. SHA-1 and MD5 are its broken predecessors and should never be used for security. CRYPTOGRAPHY

Shadow AI — Staff using AI tools without approval, often pasting confidential data into them. The current form of shadow IT, moving faster. *Also called unsanctioned AI, unapproved chatbot use.* AI & EMERGING TECH

Shadow IT — Tools and accounts staff adopt without approval. Not hostile, but invisible to security, unpatched, and outside the incident response plan. *Also called unsanctioned tools, unapproved software, rogue IT.* ATTACKS & EXPLOITATION

Shadow password file — The separate, restricted file where Unix stores password hashes, so ordinary users cannot read them out of the world-readable account file. IDENTITY & ACCESS

Share — A directory or printer made available to other machines over the network. ENDPOINTS & SYSTEMS

Shared responsibility model — The provider secures the cloud; you secure what you put in it. Nearly every cloud breach lands on the customer's side of that line. CLOUD & INFRASTRUCTURE

Shell — The command interpreter you type into — bash, zsh, PowerShell. Getting one on a target machine is the usual definition of a foothold. ENDPOINTS & SYSTEMS

Shift left — Moving security checks earlier into design and development. Genuinely valuable, and frequently reduced to adding a scanner to the build. APPLICATION SECURITY

Shoulder surfing — Reading a screen, keypad or document over someone's shoulder. Still how many PINs and passwords are actually lost. ATTACKS & EXPLOITATION

Side-channel attack — Recovering secrets from physical or timing leakage rather than breaking the maths — power draw, execution time, cache behaviour, even sound. CRYPTOGRAPHY

Sideloading — Installing an app from outside the official store, bypassing its review. Also, in malware, dropping a malicious library beside a trusted executable so it loads instead. *Also called DLL sideloading, app sideloading.* ENDPOINTS & SYSTEMS

SIEM *Security Information and Event Management* — Central log collection, correlation, and alerting. Only as good as the sources feeding it and the rules written on top. *Also called log management platform, security analytics, log correlation.* DEFENSE & OPERATIONS

Sigma — A vendor-neutral format for writing detection rules that can be converted to run on different SIEMs. The shared language for sharing detections. DEFENSE & OPERATIONS

Signals analysis — Deriving information indirectly from a signal a system emits that was never meant to carry it. CRYPTOGRAPHY

Signature (detection) — A distinctive pattern that identifies a specific tool or exploit in traffic or on disk. Precise, and useless against anything new. DEFENSE & OPERATIONS

Silk Road — The Tor-hosted drug marketplace taken down in 2013. The standing case study in dark web investigation: the site was anonymous, and the operator's early forum posts and cash-out were not. *Also called dark web marketplace case, Dread Pirate Roberts, Ulbricht case.* INTELLIGENCE & INVESTIGATIONS

Silver Ticket — A forged Kerberos service ticket made with a stolen service account hash, granting access to one service without ever touching the domain controller — and so without the logs a Golden Ticket leaves. IDENTITY & ACCESS

SIM swapping — Convincing a mobile carrier to move a number to an attacker's SIM, capturing every SMS code. The reason SMS is the weakest second factor. ATTACKS & EXPLOITATION

Simple integrity property *No write up* — In the Biba integrity model, a user may not write data to a higher integrity level than their own. IDENTITY & ACCESS

Simple security property *No read up* — In Bell-LaPadula, a user may not read data classified higher than their own clearance. IDENTITY & ACCESS

SLA / SLO *Service Level Agreement / Objective* — The availability you promise contractually, and the internal target you actually manage to. The objective should be stricter than the agreement. DEV & DELIVERY

Slowloris *Slow HTTP attack* — Holding many connections open with deliberately unfinished requests, exhausting a server's connection slots with almost no bandwidth. Denial of service by patience rather than volume. *Also called slow POST, RUDY, low and slow DoS.* ATTACKS & EXPLOITATION

Smart contract — Code executing automatically on a blockchain. Immutable once deployed, which means bugs are permanent and expensive. AI & EMERGING TECH

Smartcard — A card with a chip that holds keys and performs cryptographic operations without releasing them. The basis of most government credentialing. IDENTITY & ACCESS

Smishing — Phishing over SMS rather than email. Short messages strip away most of the cues people use to spot a fake. *Also called SMS phishing, text scam, text message phishing.* ATTACKS & EXPLOITATION

Smishing / vishing — Phishing by SMS and by voice call. Voice versions increasingly use cloned audio, and helpdesk vishing is a proven route past MFA. ATTACKS & EXPLOITATION

Smurf — An old amplification attack: ping a network's broadcast address with the victim's address forged as the source, and every host replies to the victim. NETWORKING & PROTOCOLS

SNI *Server Name Indication* — The field in a TLS handshake that names which site you want, sent before encryption starts. It leaks the hostname to anyone watching, which is what Encrypted Client Hello is meant to fix. NETWORKING & PROTOCOLS

Sniffer — A tool that reads traffic off a network interface. The same tool troubleshoots a network and harvests credentials from it. NETWORKING & PROTOCOLS

Sniffing *Passive wiretapping* — Reading network traffic you were not the intended recipient of. Passive, silent, and the reason unencrypted protocols are indefensible. *Also called packet sniffing, passive wiretapping, traffic interception.* NETWORKING & PROTOCOLS

SNMP *Simple Network Management Protocol* — The protocol for monitoring and configuring network devices. Old versions used a shared community string as the only password — often left as 'public'. NETWORKING & PROTOCOLS

SOAR *Security Orchestration, Automation and Response* — Automating repetitive response steps through playbooks — enrich, contain, notify — so analysts handle the judgement calls. DEFENSE & OPERATIONS

SOC *Security Operations Centre* — The team and tooling that monitor, triage, and respond to security events. In-house, outsourced, or a mix. *Also called security operations centre, security operations center, monitoring team.* DEFENSE & OPERATIONS

SOC 2 *Service Organization Control 2* — An audit report on a service provider's controls against trust criteria. Type I is a point in time; Type II covers a period and is the one to ask for. GOVERNANCE, RISK & COMPLIANCE

Social engineering — Manipulating people rather than systems — urgency, authority, helpfulness. It bypasses technical controls by using someone who already holds legitimate access. *Also called human hacking, con, manipulation, pretexting.* ATTACKS & EXPLOITATION

Socket — The combination of an IP address and a port that tells the network stack which application a data stream belongs to. NETWORKING & PROTOCOLS

Socket pair — The four values that uniquely name a connection: source address and port, destination address and port. It is how a host keeps thousands of connections apart. NETWORKING & PROTOCOLS

SOCKS *Socket Secure* — A generic proxy protocol that forwards connections of any kind rather than just web traffic. Widely used to route traffic through somewhere else, legitimately or not. NETWORKING & PROTOCOLS

Software — Programs and their associated data, stored in and executed by hardware, and changeable while running. ENDPOINTS & SYSTEMS

Source port — The temporary port a client picks for its end of a connection, usually a high number chosen at random. It changes with every connection. NETWORKING & PROTOCOLS

Southern District of New York *SDNY* — The federal prosecutorial district that handles a disproportionate share of US financial and white-collar cases, cyber fraud included. Where a case is charged shapes how it is investigated. INTELLIGENCE & INVESTIGATIONS

Spanning port *Port mirroring, SPAN* — A switch port configured to receive a copy of other ports' traffic. How monitoring and intrusion detection get to see the network. NETWORKING & PROTOCOLS

Spear phishing — Phishing tailored to one person using real details about their role, colleagues, or current projects. Much higher success rate, much lower volume. ATTACKS & EXPLOITATION

Special category data *Sensitive personal data* — Health, biometrics, ethnicity, religion, sexuality, politics, union membership. Higher legal protection and higher real-world harm if exposed. GOVERNANCE, RISK & COMPLIANCE

Specification gaming — Satisfying the literal instruction while defeating its intent. Not a malfunction: the system did exactly what was specified, and the specification was an imperfect description of what was wanted. *Also called goal misspecification, literal compliance, letter not spirit.* AI & EMERGING TECH

Spectre / Meltdown *Speculative execution attacks* — Flaws in how processors guess ahead, letting one process read memory it should not. Fixes cost real performance and the class keeps producing new variants. COMPUTE & HARDWARE

Split horizon — A routing rule that stops a router advertising a route back to the neighbour it learned it from. It prevents a common class of routing loop. NETWORKING & PROTOCOLS

Split key — A key divided into parts, none of which reveals anything alone. Used where no one person should be able to act by themselves. CRYPTOGRAPHY

Spoof — Posing as someone or something else to gain access — an address, a sender name, a caller ID. The general case behind spoofing of every kind. NETWORKING & PROTOCOLS

Spot / preemptible instance — Discounted cloud capacity that can be taken back at short notice. Fine for checkpointed training, unusable for anything that cannot be interrupted. COMPUTE & HARDWARE

Spyware — Software that covertly monitors activity — messages, location, microphone, camera. Includes commercial surveillance tools sold to states. *Also called snooping software, tracking software.* MALWARE & THREAT ACTORS

SQL injection *SQLi* — Slipping SQL into input so the database runs it. Fixed properly by parameterised queries — never by filtering quotes. *Also called SQLi, database injection.* APPLICATION SECURITY

SSH *Secure Shell* — Encrypted remote command-line access. Key-based authentication should replace passwords, and unmanaged authorised_keys entries are a persistence route. ENDPOINTS & SYSTEMS

SSL stripping — Sitting between user and site and quietly downgrading HTTPS links to HTTP, so the traffic the attacker relays is readable. HSTS exists to make this fail. *Also called HTTPS downgrade, protocol stripping.* NETWORKING & PROTOCOLS

SSO *Single Sign-On* — One login granting access to many applications. It centralises control and logging — and centralises risk, since the identity provider becomes the crown jewel. *Also called SSO.* IDENTITY & ACCESS

SSRF *Server-Side Request Forgery* — Making the server fetch a URL of the attacker's choosing, often reaching internal services or cloud metadata endpoints the internet cannot. *Also called server-side request forgery.* APPLICATION SECURITY

Stack mashing — Using a buffer overflow to overwrite the stack so the program returns into attacker-supplied code. ATTACKS & EXPLOITATION

Staging area *Index* — Git's holding pen between your working files and a commit. `git add` puts changes there so you can commit some edits and not others. DEV & DELIVERY

Stalkerware — Consumer spyware marketed for monitoring partners, children, or staff. Legally grey, technically ordinary, and a serious safety issue in domestic abuse. MALWARE & THREAT ACTORS

Standard ACL *Cisco* — A router filter that makes its decision on source IP address alone. Blunt, but cheap to evaluate at line rate. NETWORKING & PROTOCOLS

Star property *No write down* — In Bell-LaPadula, a user may not write data down to a lower classification, which would leak it. IDENTITY & ACCESS

Stash — Parking uncommitted changes temporarily so you can switch context, then bringing them back. DEV & DELIVERY

State machine — A system that moves through a defined series of conditions, one at a time. Protocols and parsers are state machines, and their bugs are usually states nobody planned for. ENDPOINTS & SYSTEMS

Stateful inspection *Dynamic packet filtering* — Firewalling that tracks the state of each connection rather than judging every packet alone. It is how a firewall knows a reply is legitimate. NETWORKING & PROTOCOLS

Static host table *hosts file* — A plain text file mapping names to addresses, consulted before DNS. Editing it is a simple and often overlooked redirection technique. ENDPOINTS & SYSTEMS

Static routing — Routing table entries typed in by hand that never change on their own. Predictable and unforgiving when the network does change. NETWORKING & PROTOCOLS

Stealthing — The techniques malicious code uses to hide the fact that it is present on an infected system. MALWARE & THREAT ACTORS

Steganalysis — Detecting and defeating steganography — finding the hidden message rather than reading an encrypted one. CRYPTOGRAPHY

Steganography — Hiding a message inside something innocuous, such as an image, so nobody knows a message exists. Concealment rather than encryption — often used to smuggle payloads past filters. *Also called hidden message, data hiding, covert embedding.* CRYPTOGRAPHY

Stimulus and response — In traffic analysis, the distinction between packets that start something and packets that answer. Unsolicited responses are a signal worth chasing. DEFENSE & OPERATIONS

Storage *SSD / NVMe / HDD* — Persistent storage. NVMe SSDs are dramatically faster than spinning disks, which matters when loading model weights or replaying logs. COMPUTE & HARDWARE

Store-and-forward — Switching where the whole packet is read and checked before being sent on. Slower than cut-through, and it does not forward corrupted frames. NETWORKING & PROTOCOLS

Stored vs reflected XSS — Stored XSS is saved server-side and hits every viewer; reflected XSS is echoed back from a crafted link and hits whoever clicks it. APPLICATION SECURITY

Straight-through cable — An ordinary patch cable with each pin wired to the same pin at the other end. NETWORKING & PROTOCOLS

Stream cipher — A cipher that encrypts data continuously, a bit or byte at a time, rather than in blocks. Fast, and unforgiving if a keystream is ever reused. CRYPTOGRAPHY

Strong star property — A stricter rule: a user may write only at their own level, neither up nor down. IDENTITY & ACCESS

Sub network *Subnet* — A separately identifiable slice of a bigger network, usually a building, a floor or a single LAN. NETWORKING & PROTOCOLS

Subdomain takeover — Claiming a cloud resource that a stale DNS record still points at, and serving your content from the victim's own subdomain — with their name, and often their cookies. *Also called dangling DNS, orphaned record.* CLOUD & INFRASTRUCTURE

Subnet — A slice of a larger network, carved out so that traffic inside it stays local and traffic leaving it has to pass a router. Written as a CIDR range like 10.0.1.0/24. NETWORKING & PROTOCOLS

Subpoena — A legal order compelling someone to produce records or testimony. In practice it gets subscriber and transactional detail — account records, IP addresses, connection logs — not the content of communications. *Also called records request, compelled production, legal demand.* INTELLIGENCE & INVESTIGATIONS

Subresource integrity *SRI* — A hash on a third-party script tag so the browser refuses it if the file changed. Cheap protection against a compromised CDN. APPLICATION SECURITY

Sudo / runas — Mechanisms for running a single command with elevated rights instead of working as an administrator all day. Also a valuable audit trail. ENDPOINTS & SYSTEMS

Supply chain attack — Compromising a supplier, library, or update channel to reach everyone downstream. One breach, many victims — SolarWinds and XZ Utils are the canonical cases. *Also called third-party compromise, vendor compromise, upstream attack.* ATTACKS & EXPLOITATION

Swarm intelligence — Useful behaviour emerging from many simple actors following local rules, with no central controller — the model borrowed from ants and starlings. Attractive because it is resilient, and hard to secure because there is no single point that decides anything. *Also called emergent behaviour, distributed coordination.* AI & EMERGING TECH

SWIFT *Society for Worldwide Interbank Financial Telecommunication* — The messaging network banks use to instruct each other to move money. It carries instructions, not funds, which is why an attacker with valid credentials does not need to break anything — they just ask. *Also called interbank messaging, payment network.* GOVERNANCE, RISK & COMPLIANCE

Switch — A device that learns which MAC address sits on which port and sends frames only where they need to go. It is why a modern LAN does not broadcast everything to everyone. NETWORKING & PROTOCOLS

Symbolic link *Symlink* — A file that points at another file. Where a program follows one without checking, an attacker can redirect it to a file they should not reach. ENDPOINTS & SYSTEMS

Symmetric encryption — One shared key both encrypts and decrypts. Fast, ideal for bulk data, but everyone who needs to read it needs the same secret — which is the hard part. *Also called secret key cryptography, shared key encryption.* CRYPTOGRAPHY

Symmetric key — One key used for both encryption and decryption. Fast, and it leaves you with the problem of getting the key to the other side. CRYPTOGRAPHY

SYN flood — A denial of service that opens half-finished TCP handshakes faster than the target can clear them, exhausting its connection table. NETWORKING & PROTOCOLS

Sync — Bringing two copies into agreement — usually a pull followed by a push, so local and remote match. In GUIs it is often one button doing both. DEV & DELIVERY

Synchronisation — The distinctive bit pattern network hardware watches for to know a frame is starting. NETWORKING & PROTOCOLS

Synthetic identity fraud — Building a person out of real and invented details — a genuine national ID number with a false name and history — and growing credit in that identity. Nobody reports it stolen, because nobody owns it. ATTACKS & EXPLOITATION

Syslog — The long-standing Unix logging facility, and the protocol for shipping those logs elsewhere. Still the plumbing under most log pipelines. DEFENSE & OPERATIONS

Sysmon — A free Windows tool producing detailed process, network, and file telemetry. The cheapest meaningful upgrade to endpoint visibility. ENDPOINTS & SYSTEMS

System on a Chip *SoC — not to be confused with a Security Operations Centre* — CPU, GPU, memory controller, and often a neural engine on a single piece of silicon. What phones, Raspberry Pis and Apple laptops are built on. COMPUTE & HARDWARE

System prompt — Standing instructions set by the developer ahead of user input. Treat it as configuration, never as a secret — it leaks. AI & EMERGING TECH

System-specific policy — A policy written for one system or device, where general rules are not specific enough to act on. GOVERNANCE, RISK & COMPLIANCE

T

T1 / T3 — Traditional leased digital circuits of fixed capacity. Still a unit of thinking in telecoms, if rarely a purchase. NETWORKING & PROTOCOLS

Tabletop exercise — A discussion-based rehearsal of an incident scenario. Cheap, and reliably exposes decision-making and communication gaps. *Also called TTX, walk-through exercise, scenario rehearsal.* DEFENSE & OPERATIONS

Tabnabbing — Quietly rewriting an inactive background tab into a login page. The victim returns to a tab they opened themselves and does not think to check the address again. *Also called reverse tabnabbing, background tab swap.* ATTACKS & EXPLOITATION

Tag — A permanent name pinned to a specific commit, normally a release like v2.1.0. Unlike a branch, it does not move. DEV & DELIVERY

Tailgating *Piggybacking (physical)* — Following an authorised person through a door they have just opened. The most reliable way past a badge reader is someone holding it for you. *Also called door tailgating, badge piggybacking.* ATTACKS & EXPLOITATION

Takedown *Seizure notice* — Seizing the infrastructure behind a criminal service and, usually, replacing its front page with a law enforcement banner. Effective as disruption and as messaging; rarely permanent on its own. INTELLIGENCE & INVESTIGATIONS

Tallinn Manual — The scholarly effort, run at NATO's cyber defence centre in Tallinn, to state how existing international law applies to cyber operations. Not binding on anyone, and the most cited work on the subject. *Also called Tallinn Manual 2.0, international law of cyber operations.* INTELLIGENCE & INVESTIGATIONS

Tamper — Deliberately altering a system's logic, data or control information so it does something it should not. ATTACKS & EXPLOITATION

TCP *Transmission Control Protocol* — The reliable transport: it sets up a connection, numbers every packet, and re-sends anything lost. Slower to start, but nothing arrives out of order. NETWORKING & PROTOCOLS

TCP fingerprinting — Using odd combinations of TCP header flags to identify a remote operating system by how it responds. NETWORKING & PROTOCOLS

TCP full open scan — A port scan that completes the full three-way handshake on every port. Accurate, noisy, and reliably logged by the target. NETWORKING & PROTOCOLS

TCP half open scan *SYN scan* — A scan that sends a SYN and never finishes the handshake, judging the port by the reply. Faster and quieter than a full open scan. NETWORKING & PROTOCOLS

TCP wrapper — An old but instructive control that decides whether to accept a connection to a service based on where it came from. DEFENSE & OPERATIONS

TCP/IP *Internet Protocol Suite* — The protocol family the internet runs on, named for its two central members. Also usable on a private network. NETWORKING & PROTOCOLS

TCPDump — The standard command-line packet capture tool on Unix. Windump is the Windows equivalent. DEFENSE & OPERATIONS

TDP *Thermal Design Power* — The heat a chip is expected to produce, in watts. It drives cooling, power supply sizing and, at scale, the electricity bill. COMPUTE & HARDWARE

Teardrop attack — Sending overlapping, malformed fragments that crash a machine when it tries to reassemble them. Historic, and the ancestor of every reassembly bug since. ATTACKS & EXPLOITATION

Tech support scam — A fake warning — pop-up, cold call, search advert — leading the victim to install remote access software and pay for a problem that never existed. *Also called fake support call, remote access scam.* ATTACKS & EXPLOITATION

Technical debt — Shortcuts taken to ship faster that cost more later. Sometimes a good trade — but only if someone writes down that it was taken. DEV & DELIVERY

Telemetry — The raw signals systems emit. Detection is limited by telemetry — you cannot alert on something nobody records. DEFENSE & OPERATIONS

Telnet — A remote login protocol that sends everything, passwords included, in the clear. Replaced by SSH, and still found on forgotten devices. NETWORKING & PROTOCOLS

Terminal server *Remote desktop gateway* — A server that lets remote users run desktop sessions inside the network. Convenient for suppliers and contractors, and a recurring point of entry when it is exposed without multi-factor authentication. *Also called RDS, Citrix, jump server, remote desktop host.* NETWORKING & PROTOCOLS

Thermal throttling — Hardware slowing itself down to avoid overheating. The usual explanation when performance falls off partway through a long run. COMPUTE & HARDWARE

Third-party risk *TPRM / vendor risk* — Managing the risk suppliers introduce. You can outsource the processing, but not the accountability. GOVERNANCE, RISK & COMPLIANCE

Threat / vulnerability / risk — A threat is who might hurt you, a vulnerability is the weakness they would use, and risk is the combination weighted by likelihood and impact. Vendors blur these constantly. ATTACKS & EXPLOITATION

Threat actor — The person or group behind an attack. Grouped by capability and motive rather than by the tools they happen to use. *Also called adversary, attacker, bad actor, hostile party.* MALWARE & THREAT ACTORS

Threat assessment — Working out which kinds of threat an organisation is actually exposed to, before designing anything to stop them. GOVERNANCE, RISK & COMPLIANCE

Threat hunting — Proactively searching for intrusions that no alert fired on, driven by a hypothesis rather than a queue. *Also called proactive detection, hunt team.* DEFENSE & OPERATIONS

Threat intelligence *CTI* — Analysed information about who is attacking, how, and what to look for. Useful only when it changes a decision, not when it is a feed nobody reads. *Also called CTI, threat intel, cyber intelligence.* MALWARE & THREAT ACTORS

Threat modelling *STRIDE* — Working out systematically what could go wrong with a design before it is built. Cheapest security work there is, and the most often skipped. APPLICATION SECURITY

Threat vector — The route a threat takes to reach its target — email, a supplier, a remote service, a person. GOVERNANCE, RISK & COMPLIANCE

Three-way handshake *SYN / SYN-ACK / ACK* — The three packets TCP exchanges to open a connection. Half-finished handshakes left open on purpose are the basis of the SYN flood attack. NETWORKING & PROTOCOLS

Throughput vs latency — Throughput is how much work finishes per second; latency is how long one request takes. Batching raises throughput and worsens latency, and you usually have to choose. COMPUTE & HARDWARE

Time to live *TTL* — A counter in a packet that drops by one at every hop and kills the packet at zero. It stops routing loops from running forever, and traceroute exploits it. NETWORKING & PROTOCOLS

Timeline analysis — Building an ordered sequence of events across sources to reconstruct an intrusion and find the initial access point. DEFENSE & OPERATIONS

Timing attack — Recovering a secret from how long an operation takes — a comparison that stops at the first wrong byte leaks where it stopped. The reason comparisons are made constant-time. CRYPTOGRAPHY

Tiny fragment attack — Splitting a packet so small that the fields a filter checks land in the second fragment, letting the first slip past the rule. NETWORKING & PROTOCOLS

Title 18 — The part of the US Code covering federal crimes, including the computer fraud and wiretap statutes that most cyber prosecutions are brought under. *Also called federal criminal code, CFAA chapter.* GOVERNANCE, RISK & COMPLIANCE

TLS *Transport Layer Security* — The protocol that encrypts and authenticates most internet traffic. SSL is its dead predecessor — people still say SSL, but they mean TLS. *Also called SSL, HTTPS encryption, transport encryption, SSL, legacy TLS.* NETWORKING & PROTOCOLS

TLS handshake — The opening exchange where client and server agree a cipher, verify the certificate, and derive session keys before any real data moves. NETWORKING & PROTOCOLS

Token — The chunk of text a model processes, roughly a word fragment. The unit of both pricing and context limits. AI & EMERGING TECH

Token binding / DPoP — Tying a token to the client that requested it, so a stolen token is useless elsewhere. The countermeasure to plain bearer tokens. IDENTITY & ACCESS

Token ring — A LAN design where a circulating token granted the right to transmit, avoiding collisions by design. Elegant, and beaten by cheap Ethernet. NETWORKING & PROTOCOLS

Token theft *Session token theft* — Stealing an issued session or access token from a browser, a log or memory and replaying it. It sails past MFA, because the second factor already happened. *Also called cookie theft, session hijacking (token).* IDENTITY & ACCESS

Token-based access control — Access defined by attaching a list of objects and privileges to each user — the mirror image of list-based control. IDENTITY & ACCESS

Token-based device *Hardware token* — A device that generates a changing code the user must supply to log in, proving they physically hold it. IDENTITY & ACCESS

Tokens per second *tok/s* — The practical speed measure for language model inference. Time to first token matters for how responsive it feels; tokens per second for how fast it finishes. COMPUTE & HARDWARE

Tool use / function calling — Letting a model invoke external functions or APIs. Whatever the tool can do, a successful prompt injection can do. AI & EMERGING TECH

Top Secret *TS* — The US classification for information whose disclosure would be expected to cause exceptionally grave damage to national security. *Also called TS, highest classification.* CLASSIFICATION & PERSONAL DATA

Topology — The shape of a network — bus, star, ring, mesh — physically or logically. Two networks can share a logical topology and look nothing alike in the racks. NETWORKING & PROTOCOLS

Tor *The Onion Router* — A network that routes traffic through several volunteer relays, each knowing only the previous and next hop, so no single point sees both who you are and where you are going. *Also called onion router, tor browser, dark net, darknet.* NETWORKING & PROTOCOLS

TOTP *Time-based One-Time Password* — The rotating six-digit code from an authenticator app. Far better than SMS, but still phishable, because the user can be tricked into typing it into a fake site. IDENTITY & ACCESS

TPM *Trusted Platform Module* — A small secure chip on a motherboard that stores keys and measures boot integrity. What full-disk encryption and secure boot lean on. CRYPTOGRAPHY

TPU / NPU *Tensor / Neural Processing Unit* — Chips designed specifically for neural network maths. Google's TPUs run in its cloud; NPUs now ship inside phones and laptops for on-device inference. COMPUTE & HARDWARE

Traceroute *tracert* — A tool that shows each hop a packet takes to a destination. It exposes the path, and often the internal structure of the network at the far end. NETWORKING & PROTOCOLS

Trade secret — Commercially valuable information that derives its value from being secret and that the holder takes reasonable steps to keep secret. The reasonable steps are a legal requirement, not just good practice. *Also called confidential business information, proprietary secret.* CLASSIFICATION & PERSONAL DATA

Training data — The corpus a model learns from. Its provenance, licensing, and bias become properties of the finished system. AI & EMERGING TECH

Training vs inference — Training builds the model and is enormously expensive but happens rarely; inference runs it and is cheap per call but happens constantly. Most lifetime cost ends up in inference. COMPUTE & HARDWARE

Triage — Rapidly deciding whether an alert is real and how urgent. The gatekeeping step between monitoring and incident response. DEFENSE & OPERATIONS

Triple DES *3DES* — DES applied three times to compensate for its short key. Slow, deprecated, and still lurking in payment and legacy systems. CRYPTOGRAPHY

Trojan — Malware disguised as something wanted — a cracked app, an installer, a document viewer. It relies on the user choosing to run it. *Also called trojan horse, RAT dropper, fake application.* MALWARE & THREAT ACTORS

True / false positive — A real detection versus a false alarm. False positive volume, not detection coverage, is what usually breaks a SOC. DEFENSE & OPERATIONS

Trunking — Carrying traffic for several VLANs over one link between switches. Misconfigured trunks are how attackers hop between VLANs. NETWORKING & PROTOCOLS

Trust — In systems terms, the relationship that decides what one machine or domain will let another's users do. IDENTITY & ACCESS

Trusted access programme — An arrangement giving selected defenders early or unrestricted use of advanced model capabilities, on the argument that defence needs the same tools as offence, sooner. *Also called trusted tester, defender access programme.* DEFENSE & OPERATIONS

Trusted ports — Ports below 1024, which on Unix only a privileged account may bind. A weak assurance today, but it still shapes how services are started. NETWORKING & PROTOCOLS

TTPs *Tactics, Techniques, and Procedures* — How a group operates rather than what they used once. Far more durable than indicators, and the basis of ATT&CK-style detection. *Also called tactics techniques and procedures, tradecraft, behaviour.* MALWARE & THREAT ACTORS

Tumbler *Mixer* — A service that pools and re-splits cryptocurrency to break the link between source and destination. Using one is itself a signal, and several operators have been prosecuted. *Also called mixer, coin mixer, laundering service.* INTELLIGENCE & INVESTIGATIONS

Tunnel — A link built by wrapping one protocol inside another so traffic can cross a network that would not normally carry it. VPNs, IPsec and GRE are all tunnels. NETWORKING & PROTOCOLS

Typosquatting — Registering near-miss domains or package names to catch typos. Used both for phishing and for poisoning software dependencies. *Also called lookalike domain, misspelled domain, homoglyph domain.* ATTACKS & EXPLOITATION

U

UAC *User Account Control* — Windows' prompt before elevated actions. A speed bump rather than a boundary — plenty of documented bypasses exist. ENDPOINTS & SYSTEMS

UDP *User Datagram Protocol* — Fire-and-forget transport with no handshake and no re-sends. Used where speed beats completeness — DNS, video, games — and popular with attackers for spoofing and amplification. NETWORKING & PROTOCOLS

UDP scan — Probing UDP ports to see which are open. Slow and unreliable, because silence can mean either an open port or a dropped packet. NETWORKING & PROTOCOLS

UEBA *User and Entity Behaviour Analytics* — Behavioural profiling of users and machines to spot compromised accounts and insiders acting out of character. DEFENSE & OPERATIONS

UEFI / BIOS *Firmware* — The low-level code that starts the hardware. Rarely patched, hard to inspect, and highly persistent when compromised. ENDPOINTS & SYSTEMS

Unclassified *U* — Government information with no classification level. It may still be controlled: CUI — controlled unclassified information — is unclassified but restricted. CLASSIFICATION & PERSONAL DATA

Undercover purchase *Test buy* — Buying from a marketplace vendor to establish what is being sold, from whom, and where it ships from. It converts an anonymous listing into physical evidence and a delivery address. INTELLIGENCE & INVESTIGATIONS

Unexplained failure — An outage with no established cause, reported as a fault rather than as an incident. Poland's second plant assumed contractor error; treating unexplained failures as possible attacks is what uncovered it. *Also called unattributed outage, anomalous fault.* DEFENSE & OPERATIONS

Unicast — Traffic from one host to one host. The ordinary case. NETWORKING & PROTOCOLS

Unit / integration test — Unit tests check one piece in isolation; integration tests check the pieces working together. You need both, and integration tests are the ones people skip. DEV & DELIVERY

United Nations (cyber norms) *UN* — The forum where states negotiate norms for behaviour in cyberspace. It produces recommendations, not enforcement, which is both its limit and the reason states will talk there. INTELLIGENCE & INVESTIGATIONS

Unix — The multi-user, multitasking operating system from Bell Labs in the early 1970s whose design underlies Linux, macOS and most servers. ENDPOINTS & SYSTEMS

Unprotected share — A share anyone can connect to. Still one of the most common ways ransomware moves through an organisation. ENDPOINTS & SYSTEMS

Unrestricted file upload — Accepting an uploaded file without checking what it is or where it lands, so an attacker uploads code and then requests it. APPLICATION SECURITY

Untrusted model — A model obtained from somewhere you do not control, treated as code rather than as data — because in most formats it is. The mitigations are the ones used for third-party software: provenance, scanning, safe formats, and sandboxing the load. *Also called third-party model, downloaded weights.* AI & EMERGING TECH

Upstream / downstream — Upstream is the project or service you depend on; downstream is whoever depends on you. Vulnerabilities travel downstream, fixes come from upstream. DEV & DELIVERY

URI *Uniform Resource Identifier* — The general term for names and addresses that identify something on the web. A URL is a URI that also says where to get it. ENDPOINTS & SYSTEMS

URL *Uniform Resource Locator* — The address of a resource: the protocol to use, then where the resource lives. The part users are asked to inspect and almost never do. ENDPOINTS & SYSTEMS

US Cyber Command *USCYBERCOM* — The US military command for cyber operations, defensive and offensive. Where CISA protects and the FBI investigates, this is the element that can act against an adversary. *Also called CYBERCOM, USCYBERCOM, military cyber.* INTELLIGENCE & INVESTIGATIONS

US Secret Service *USSS* — Originally the investigators of counterfeit currency, now a principal US agency for financial cybercrime — payment card fraud, cryptocurrency laundering, digital financial investigations — alongside its protective mission. *Also called USSS, secret service, treasury investigators.* INTELLIGENCE & INVESTIGATIONS

Use-after-free — Using memory after it has been released, letting an attacker control what now sits there. A leading source of browser and kernel exploits. APPLICATION SECURITY

User space vs kernel space — The separation between ordinary programs and privileged system code. Crossing from one to the other is the goal of local privilege escalation. ENDPOINTS & SYSTEMS

V

Variable frequency drive *VFD* — The equipment that controls the speed of an industrial motor. Manipulating one changes what a physical machine does — the mechanism Stuxnet used against centrifuges. *Also called frequency converter, motor drive, ACS drive.* ENDPOINTS & SYSTEMS

Vector database *Embedding store* — Storage for numeric representations of text so similar meaning can be found by proximity. The retrieval half of RAG, and it inherits the source's access rules only if you make it. AI & EMERGING TECH

Version control *Git, VCS* — A system that records every change to a codebase, who made it and why, and lets you go back. Git is the near-universal one; GitHub and GitLab are hosts for it. DEV & DELIVERY

Virtual machine *VM* — A simulated computer running on shared hardware, with its own operating system. Strong isolation, heavier than a container. *Also called VM, guest machine, virtualised host.* CLOUD & INFRASTRUCTURE

Virtualisation — Running multiple isolated systems on one machine. The basis of cloud, and a safe place to detonate suspicious files. ENDPOINTS & SYSTEMS

Virus — Malicious code that attaches itself to a file or program and spreads when that host is run. Largely historical, but the word stuck to everything. *Also called computer virus, infection.* MALWARE & THREAT ACTORS

Vishing *Voice phishing* — Phishing by phone call, including over VoIP. Now routinely paired with cloned voices. *Also called voice phishing, phone scam, caller ID fraud.* ATTACKS & EXPLOITATION

VLAN *Virtual LAN* — A logical network laid over shared switch hardware, so two ports on the same switch can be on separate networks. A control, but a soft one — VLAN hopping is a real attack. NETWORKING & PROTOCOLS

VLAN hopping — Escaping the VLAN you were put on to reach traffic on another, usually by abusing trunk negotiation or double-tagged frames. It is why VLANs are a segmentation convenience, not a security boundary. *Also called VLAN escape, double tagging attack.* ATTACKS & EXPLOITATION

Voice cloning fraud *AI voice fraud* — Synthesising a familiar voice from a short sample and using it to authorise a payment or extract information by phone. Voice is no longer evidence of identity. *Also called deepfake voice, vishing with AI.* ATTACKS & EXPLOITATION

Volatile vs non-volatile storage — Volatile memory disappears when power is cut; disks survive. It sets the order of collection: capture memory first, then image the disk. INTELLIGENCE & INVESTIGATIONS

VPN *Virtual Private Network* — An encrypted tunnel that makes a remote device behave as if it were on the internal network. It moves the trust boundary — it does not remove it. *Also called virtual private network, encrypted tunnel, remote access tunnel.* NETWORKING & PROTOCOLS

VPN (investigative view) — An encrypted tunnel to a provider that then makes connections on the user's behalf. Whether it defeats an investigation depends entirely on what logs the provider keeps. INTELLIGENCE & INVESTIGATIONS

VPN concentrator — The device that terminates remote access connections into a network. It is the front door for suppliers and engineers, and where it authenticates with a password alone it is the front door for everyone else. *Also called VPN gateway, remote access concentrator.* NETWORKING & PROTOCOLS

VRAM *Video / GPU memory* — Memory attached directly to a GPU. It is the hard limit on model size: if the weights do not fit in VRAM, the model will not run, however fast the chip is. COMPUTE & HARDWARE

Vulnerability management — Finding, prioritising, fixing, and verifying vulnerabilities as a continuous cycle. Prioritisation is the hard part, not scanning. *Also called vuln management, patch management, remediation programme.* DEFENSE & OPERATIONS

Vulnerability scanner — A tool that checks systems against a database of known flaws. Reports what might be vulnerable, not what is exploitable in your context. DEFENSE & OPERATIONS

W

WAF *Web Application Firewall* — Filters HTTP requests against attack patterns. Buys time before a patch; it does not fix the underlying flaw. CLOUD & INFRASTRUCTURE

War chalking — Marking pavements to show where open wireless signals could be picked up. A period detail from the early Wi-Fi years. ATTACKS & EXPLOITATION

War dialing — Dialling ranges of telephone numbers to find modems answering. The ancestor of port scanning. ATTACKS & EXPLOITATION

War driving — Driving around looking for wireless networks that can be reached or joined. ATTACKS & EXPLOITATION

Watering hole — Compromising a site the intended victims already visit and waiting for them to arrive. No message to the target means nothing to flag as suspicious. *Also called strategic web compromise, ambush site.* ATTACKS & EXPLOITATION

Watering hole (technique) *Strategic web compromise* — Compromising a site the intended victims already visit and waiting, rather than approaching them directly. It turns a trusted destination into the delivery mechanism. ATTACKS & EXPLOITATION

Watermarking — Embedding a detectable signal in AI-generated output. Helpful at scale, and generally removable by anyone who wants to remove it. AI & EMERGING TECH

Weaponised code *Cyber weapon* — Software written to cause damage or effect as an instrument of policy rather than for profit. The uncomfortable feature is that using it publishes it: unlike a missile, a cyber weapon can be recovered, studied, and reused by whoever it was fired at. *Also called cyber weapon, offensive tooling, digital munition.* MALWARE & THREAT ACTORS

Web cache deception — Tricking a cache into storing a page containing another user's private data, then fetching it from the cache yourself. APPLICATION SECURITY

Web cache poisoning — Getting a shared cache to store a response you control, so every later visitor is served it. One request, and everybody gets the payload. *Also called cache poisoning (web).* APPLICATION SECURITY

Web of trust — Trust built by people signing each other's keys, rather than granted by a central authority. PGP's alternative to certificate authorities. CRYPTOGRAPHY

Web server — The software that answers HTTP requests for content. Also the process most often running as the entry point to an internal network. ENDPOINTS & SYSTEMS

Webhook — A URL you register so another service can push events to you as they happen, instead of you polling. Verify the signature, or anyone can post to it. DEV & DELIVERY

Whaling — Spear phishing aimed at executives, whose approval authority and access make a single success unusually valuable. ATTACKS & EXPLOITATION

WHOIS *Who is — registration lookup* — The lookup service for who registered a domain or holds a block of addresses. Redaction has hollowed it out, but it is still an early stop in an investigation. *Also called domain registration lookup, registrar record.* NETWORKING & PROTOCOLS

Windowing — A windowing system shares a screen among several running applications, tracking where each window is and what state it is in. NETWORKING & PROTOCOLS

Wiper — Malware built purely to destroy data, sometimes disguised as ransomware. There is no key, because recovery was never the point. *Also called destructive malware, data destroyer.* MALWARE & THREAT ACTORS

Wired Equivalent Privacy *WEP* — The original Wi-Fi encryption standard, broken since the early 2000s. Finding it in use is finding an open network. ENDPOINTS & SYSTEMS

WireGuard — A modern VPN protocol with a deliberately small codebase and a fixed set of modern ciphers. Faster and easier to audit than IPsec or OpenVPN. NETWORKING & PROTOCOLS

Wireless Application Protocol *WAP* — An early specification for getting internet services onto mobile phones, before phones could simply speak the web. ENDPOINTS & SYSTEMS

Wiretapping — Monitoring and recording data moving between two points in a communication system. Passive wiretapping listens; active wiretapping alters. NETWORKING & PROTOCOLS

Workload identity — Giving a running service a short-lived, automatically issued identity instead of a static key. The modern replacement for hard-coded credentials. IDENTITY & ACCESS

World Wide Web *WWW* — The global collection of hypermedia documents and services reached over HTTP. Not a synonym for the internet, though everyone uses it as one. ENDPOINTS & SYSTEMS

Worm — Malware that spreads by itself across a network with no user action. Why unpatched internet-facing services are treated as emergencies. *Also called self-propagating malware, network worm.* MALWARE & THREAT ACTORS

X

XDR *Extended Detection and Response* — Correlating endpoint telemetry with identity, email, and cloud signals in one place. Often just a vendor's bundle under a new name. ENDPOINTS & SYSTEMS

XPath injection — Injecting into an XPath query over an XML document, to bypass checks or read nodes that should not be reachable. APPLICATION SECURITY

XSS *Cross-Site Scripting* — Injecting JavaScript that runs in another user's browser under your site's origin, letting an attacker read cookies or act as that user. *Also called cross-site scripting, script injection.* APPLICATION SECURITY

XXE *XML External Entity* — Abusing XML parsers that resolve external references, allowing file reads or server-side requests. Fixed by disabling external entities. APPLICATION SECURITY

Y

YARA *Yet Another Ridiculous Acronym* — A pattern-matching language for identifying malware families by content. Widely used in threat hunting and malware triage. DEFENSE & OPERATIONS

Z

Zero trust — Assume no network location is trusted; verify identity, device, and context on every request. A design principle, not a product, whatever a vendor tells you. *Also called never trust always verify, ZTA, zero trust architecture.* IDENTITY & ACCESS

Zero-click exploit — An exploit needing no interaction at all — a message that is parsed before it is displayed, a packet handled by a background service. There is no user mistake to blame and nothing to train against. *Also called interaction-less exploit, no-click attack.* ATTACKS & EXPLOITATION

Zero-day *0-day* — A vulnerability being exploited before a patch exists. Rare and expensive — most breaches still use flaws patched months earlier. *Also called 0day, zero day, unknown vulnerability.* ATTACKS & EXPLOITATION

Zombie — A compromised machine taking orders remotely, usually as one of many in a botnet. Its owner almost never knows. *Also called bot, drone, compromised host.* MALWARE & THREAT ACTORS